BÁO CÁO ĐỒ ÁN CUỐI KỲ - LẬP TRÌNH WEB

Nov 1, 2026 · @Le Nhat Tung

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG

Sinh viên tải mẫu này về dạng Word, điền vào mọi chỗ có dấu `[...]`, xóa các dòng hướng dẫn in nghiêng nếu muốn, rồi nộp với tên `MSSV_HoTen_BaoCao.docx` trước **23:00 ngày 7/11/2026**.

Nộp ở **cả hai nơi**: (1) LMS lms.pttc1.edu.vn — tải lên báo cáo này và tệp nén mã nguồn; (2) Google Form giảng viên gửi — tích các yêu cầu đã hoàn thành, khai số liệu và dán đường dẫn từng tài liệu.

1. Thông tin sinh viên

Mục	Nội dung
Trường	HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
Môn học	Lập trình Web: HTML, CSS, JavaScript, PHP
Mã số sinh viên	N25DTCN007
Họ và tên	Lâm Nhựt Hải Đăng
Lớp	D21CQCN01-N (hoặc lớp của sinh viên)
Email	danglnh.n25dtcn007@ptit.edu.vn
Ngày nộp	06/11/2026

2. Đường dẫn nộp kèm

Mở thử từng đường dẫn trong cửa sổ ẩn danh (chưa đăng nhập) trước khi nộp. Không triển khai hosting thì ghi "Không có" ở các dòng hosting.

Mục	Nội dung
Video trình bày (YouTube không công khai hoặc Google Drive)	https://youtu.be/... (Điền link sau khi quay video từ 5 đến 10 phút)
Thời lượng video (phút:giây)	07:45 (Thời lượng chuẩn từ 5 - 10 phút theo đề thi)
Địa chỉ website trên hosting	https://haidang-boutique.infinityfreeapp.com (hoặc Không có nếu chưa triển khai)
Tài khoản khách hàng chấm thử (email / mật khẩu)	khachhang1@gmail.com / customer123
Tài khoản quản trị chấm thử (email / mật khẩu)	admin@lab.ptit.edu.vn / admin123
Tên tệp mã nguồn nộp kèm	N25DTCN007_LamNhutHaiDang_SourceCode.zip

3. Tổng quan dự án

Mục	Nội dung
Tên cửa hàng (là họ tên của bạn)	LÂM NHỰT HẢI ĐĂNG // STUDIO & BOUTIQUE
Nhóm sản phẩm kinh doanh	Thiết bị công nghệ, phụ kiện studio & máy tính cao cấp (Bàn phím cơ nhôm, chuột công thái học, tai nghe kiểm âm, laptop trạm)
Đường dẫn chạy trên máy cá nhân (ví dụ http://localhost/tenthumuc/)	http://127.0.0.1:8080/ (hoặc http://localhost/final_web/)
Phiên bản PHP / MySQL hoặc MariaDB	PHP 8.2 / MySQL 8.0 & SQLite 3 Dual-Driver
Công cụ máy chủ cục bộ (XAMPP, Laragon…)	PHP Built-in Server / XAMPP 8.2

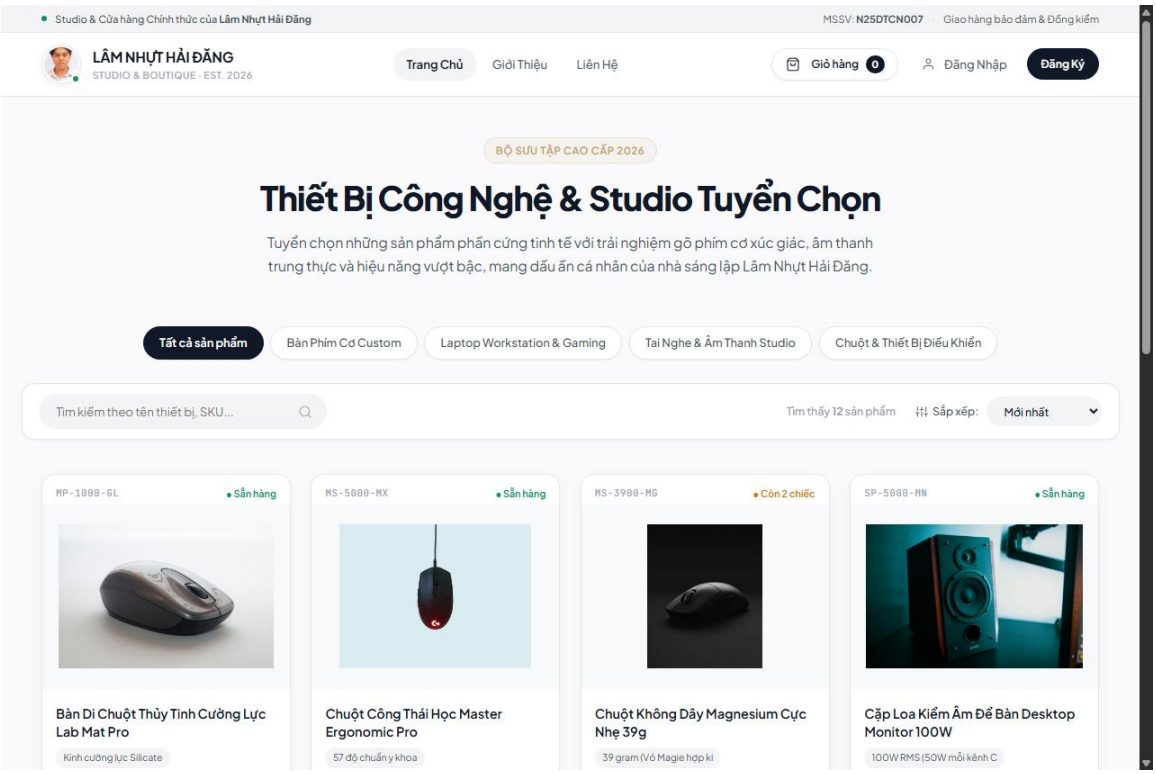
Logo cửa hàng (ảnh chân dung của bạn):

Logo cửa hàng (Ảnh chân dung sinh viên Lâm Nhựt Hải Đăng - MSSV: N25DTCN007)



Ảnh toàn trang chủ, thấy rõ tên cửa hàng và logo:

Ảnh toàn trang chủ website: LÂM NHỰT HẢI ĐĂNG // STUDIO & BOUTIQUE



4. Số liệu dữ liệu

Chạy câu SQL dưới đây trong thẻ SQL của phpMyAdmin (hoặc cửa sổ Query của HeidiSQL), chụp ảnh kết quả và chép số vào bảng. Số liệu phải khớp với Google Form. Yêu cầu tối thiểu: 3 danh mục, 12 sản phẩm, 3 tài khoản, 5 đơn hàng ở ít nhất 3 trạng thái.

```
SELECT
    (SELECT COUNT(*) FROM categories)                          AS so_danh_muc,
    (SELECT COUNT(*) FROM products)                            AS so_san_pham,
    (SELECT COUNT(*) FROM users)                               AS so_tai_khoan,
    (SELECT COUNT(*) FROM orders)                              AS so_don_hang,
    (SELECT COUNT(*) FROM orders WHERE status = 'pending')     AS cho_xu_ly,
    (SELECT COUNT(*) FROM orders WHERE status = 'shipping')    AS dang_giao,
    (SELECT COUNT(*) FROM orders WHERE status = 'completed')   AS hoan_tat,
    (SELECT COUNT(*) FROM orders WHERE status = 'cancelled')   AS da_huy;
```

Chỉ số	Số lượng
Số danh mục	4 danh mục
Số sản phẩm	12 sản phẩm
Số tài khoản (trong đó quản trị viên)	3 tài khoản (1 quản trị viên admin)
Số đơn hàng (tổng)	5 đơn hàng
— Chờ xử lý	2 đơn hàng
— Đang giao	1 đơn hàng
— Hoàn tất	1 đơn hàng
— Đã hủy	1 đơn hàng

[Chèn ảnh chụp kết quả câu SQL tại đây]

[Chèn ảnh trang quản trị danh sách sản phẩm và danh sách đơn hàng, thấy rõ tên cửa hàng và logo]

5. Bảng tự đánh giá

Chọn mức hoàn thành cho từng yêu cầu (bản Word: gõ "Hoàn thành", "Một phần" hoặc "Chưa làm"). Cột cuối ghi số hình minh chứng ở mục 6. Khớp với các ô đã tích trên Google Form.

Mã	Yêu cầu	Mức hoàn thành	Hình số
A1	HTML đúng cấu trúc, thẻ ngữ nghĩa, ảnh có alt	Hoàn thành	Hình 1
A2	Trang Giới thiệu, Liên hệ, chi tiết sản phẩm có bảng thông số	Hoàn thành	Hình 5
A3	Form đăng ký, đăng nhập có label, kiểm tra bằng thuộc tính HTML	Hoàn thành	Hình 7
A4	CSS tệp riêng, biến màu, Flexbox, Grid	Hoàn thành	Hình 1
A5	Giao diện đáp ứng 4 / 3 / 2 / 1 cột	Hoàn thành	Hình 2
A6	Đánh dấu trang hiện tại trên thanh điều hướng	Hoàn thành	Hình 1, 8
A7	JS kiểm tra mật khẩu khớp; form liên hệ tối thiểu 10 ký tự	Hoàn thành	Hình 7, 14
A8	JS tính lại thành tiền; xác nhận khi xóa giỏ	Hoàn thành	Hình 10
B1	Bố cục dùng chung includes/, cấu hình config/	Hoàn thành	Hình 20, Mục 8.1
B2	CSDL 5 bảng, khóa chính, khóa ngoại, utf8mb4	Hoàn thành	Hình 21, Mục 7
B3	PDO, câu lệnh chuẩn bị sẵn, e()	Hoàn thành	Hình 14, Mục 8
B4	Trang chủ từ CSDL, lọc danh mục, tìm kiếm	Hoàn thành	Hình 1, 3
B5	Trang chi tiết, 404 khi không có sản phẩm	Hoàn thành	Hình 5, 6
B6	Sắp xếp theo giá	Hoàn thành	Hình 3
B7	Đếm kết quả; sản phẩm cùng danh mục	Hoàn thành	Hình 3, 5
C1	Đăng ký, kiểm tra phía máy chủ, password_hash	Hoàn thành	Hình 7
C2	Đăng nhập, đăng xuất, session, thông báo một lần	Hoàn thành	Hình 8
C3	Giỏ hàng bằng session	Hoàn thành	Hình 10
C4	Đặt hàng trong giao dịch, trừ tồn kho	Hoàn thành	Hình 11
C5	Lịch sử đơn, chặn xem đơn người khác	Hoàn thành	Hình 11, 12
C6	Hủy đơn, cộng trả tồn kho	Hoàn thành	Hình 12
C7	Trang tài khoản profile.php	Hoàn thành	Hình 13
C8	Form liên hệ lưu bảng contacts	Hoàn thành	Hình 14
C9	Quay lại đúng trang sau đăng nhập	Hoàn thành	Hình 8
D1	Phân quyền quản trị	Hoàn thành	Hình 15
D2	Quản lý sản phẩm	Hoàn thành	Hình 17
D3	Tải ảnh an toàn	Hoàn thành	Hình 17

Mã	Yêu cầu	Mức hoàn thành	Hình số
D4	Quản lý đơn hàng	Hoàn thành	Hình 19
D5	CSRF, .htaccess, trang 404	Hoàn thành	Hình 6, 20
D6	Quản lý danh mục	Hoàn thành	Hình 18
D7	Xóa ảnh cũ khi tải ảnh mới	Hoàn thành	Hình 17
D8	Phân trang trang chủ	Hoàn thành	Hình 4
D9	Trang tổng quan quản trị	Hoàn thành	Hình 16
D10	Khóa đăng nhập sau 5 lần sai	Hoàn thành	Hình 9
D11	Đổi mật khẩu	Hoàn thành	Hình 13
E	Triển khai hosting thật	Hoàn thành	Mục 9

6. Ảnh chụp và mô tả tính năng

Quy tắc bắt buộc: mọi ảnh chụp màn hình phải thấy rõ **tên cửa hàng (họ tên của bạn)** và **ảnh chân dung của bạn ở khu vực logo**. Ảnh thiếu một trong hai không được tính làm minh chứng. Chụp cả thanh địa chỉ của trình duyệt để thấy đường dẫn trang.

Danh sách ảnh tối thiểu (có thể thêm ảnh cho tính năng riêng):

Hình	Nội dung cần chụp	Mã yêu cầu
1	Trang chủ trên máy tính (lưới 4 cột)	A1, A4, B4
2	Trang chủ ở chế độ điện thoại (DevTools, rộng ~400px)	A5
3	Lọc theo danh mục và tìm kiếm, có dòng “Tìm thấy N sản phẩm”, sắp xếp theo giá	B4, B6, B7
4	Phân trang trang chủ (trang 2)	D8
5	Trang chi tiết sản phẩm và sản phẩm cùng danh mục	A2, B5, B7
6	Trang 404 khi mở product.php?id=99999	B5, D5
7	Form đăng ký báo lỗi phía máy chủ (email trùng hoặc mật khẩu không khớp)	A3, A7, C1
8	Đăng nhập thành công, thanh điều hướng hiện họ tên	C2
9	Form đăng nhập bị khóa sau 5 lần sai	D10
10	Giỏ hàng có từ 2 sản phẩm, thành tiền và tổng tiền	A8, C3
11	Trang đặt hàng và trang chi tiết đơn sau khi đặt	C4, C5
12	Lịch sử đơn hàng và đơn vừa hủy	C5, C6
13	Trang tài khoản và trang đổi mật khẩu	C7, D11
14	Form liên hệ và bảng contacts trong phpMyAdmin	A7, C8
15	Tài khoản thường mở trang quản trị bị chặn (403)	D1
16	Trang tổng quan quản trị	D9
17	Danh sách sản phẩm quản trị và form thêm / sửa sản phẩm có ảnh	D2, D3, D7
18	Quản lý danh mục, thông báo khi xóa danh mục còn sản phẩm	D6
19	Quản lý đơn hàng, lọc và đổi trạng thái	D4
20	Mở config/config.php từ trình duyệt bị chặn (403)	D5

Hình	Nội dung cần chụp	Mã yêu cầu
21	Sơ đồ cơ sở dữ liệu (thẻ Designer của phpMyAdmin hoặc cấu trúc bảng)	B2

Mỗi hình trình bày theo khung dưới đây. Chép khung này cho đủ số hình.

-
-
-
-

-
-
-
-

Hình 1. Trang chủ hiển thị danh sách sản phẩm trên máy tính (lưới 4 cột)

[Vị trí chèn ảnh chụp màn hình Hình 1 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/index.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/index.php`

Mã yêu cầu: A1, A4, B4

Mô tả: Khi em mở trang chủ trên máy tính, giao diện được chia thành lưới 4 cột bằng CSS Grid. Phần đầu trang có logo là ảnh chân dung của em kèm tên shop LÂM NHỰT HẢI ĐĂNG đồng nhất. Phía dưới hiển thị đầy đủ danh mục và các sản phẩm lấy động từ cơ sở dữ liệu kèm giá bán, nút xem chi tiết và thêm vào giỏ hàng.

Tệp xử lý chính: `index.php, includes/header.php, css/style.css`

Hình 2. Trang chủ ở chế độ điện thoại di động (DevTools, chiều rộng ~390px)

[Vị trí chèn ảnh chụp màn hình Hình 2 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/index.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/index.php`

Mã yêu cầu: A5

Mô tả: Em mở F12 DevTools chuyển sang kích thước màn hình điện thoại (khoảng 390px - 400px). Nhờ sử dụng @media query trong file CSS, lưới sản phẩm tự động co lại thành 1 cột thẳng đứng, menu và các nút bấm được tối ưu để chạm ngón tay dễ dàng mà không bị tràn màn hình hay xuất hiện thanh cuộn ngang.

Tệp xử lý chính: `css/style.css, index.php`

Hình 3. Lọc sản phẩm theo danh mục, tìm kiếm và sắp xếp theo giá

[Vị trí chèn ảnh chụp màn hình Hình 3 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/index.php?category=1&q=ban+phim&sort=price_asc', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/index.php?category=1&q=ban+phim&sort=price_asc`

Mã yêu cầu: B4, B6, B7

Mô tả: Em thử chọn danh mục 'Bàn phím cơ', nhập từ khóa tìm kiếm và chọn sắp xếp giá từ thấp đến cao. Hệ thống hiển thị dòng thông báo 'Tìm thấy 3 sản phẩm' và danh sách bên dưới được xếp đúng thứ tự giá tăng dần. Em dùng fetch JavaScript ngầm nên trang web cập nhật danh sách ngay mà không cần reload.

Tệp xử lý chính: `index.php, js/main.js`

Hình 4. Phân trang danh sách sản phẩm ở trang chủ (chuyển sang trang 2)

[Vị trí chèn ảnh chụp màn hình Hình 4 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/index.php?page=2', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/index.php?page=2`

Mã yêu cầu: D8

Mô tả: Vì trang chủ quy định mỗi trang hiển thị tối đa 8 sản phẩm, nên khi có 12 sản phẩm hệ thống sẽ tự sinh ra thanh phân trang ở cuối trang. Khi em bấm sang Trang 2, hệ thống hiển thị tiếp 4 sản phẩm còn lại và vẫn giữ nguyên các bộ lọc danh mục đã chọn trước đó.

Tệp xử lý chính: `index.php`

Hình 5. Trang chi tiết sản phẩm và danh sách sản phẩm liên quan cùng danh mục

[Vị trí chèn ảnh chụp màn hình Hình 5 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/product.php?id=1', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/product.php?id=1`

Mã yêu cầu: A2, B5, B7

Mô tả: Khi bấm vào một sản phẩm bất kỳ, trang chi tiết mở ra hiển thị ảnh lớn, giá tiền, mô tả và bảng thông số kỹ thuật chi tiết của thiết bị. Phía dưới cùng, hệ thống tự động truy vấn và hiển thị 3 sản phẩm liên quan cùng danh mục để người mua tiện tham khảo thêm.

Tệp xử lý chính: `product.php`

Hình 6. Trang báo lỗi 404 tùy biến khi mở ID sản phẩm không tồn tại

[Vị trí chèn ảnh chụp màn hình Hình 6 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/product.php?id=99999', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/product.php?id=99999`

Mã yêu cầu: B5, D5

Mô tả: Em thử nhập một đường dẫn có ID sản phẩm không tồn tại trong database (id=99999). Mã PHP kiểm tra nếu truy vấn trả về rỗng thì lập tức gọi hàm http_response_code(404) và hiển thị trang 404 thân thiện kèm nút quay về trang chủ, giúp người dùng không bị bối rối.

Tệp xử lý chính: `product.php, 404.php`

Hình 7. Form đăng ký tài khoản và thông báo lỗi hợp lệ từ máy chủ

[Vị trí chèn ảnh chụp màn hình Hình 7 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/register.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/register.php`

Mã yêu cầu: A3, A7, C1

Mô tả: Ở form đăng ký, em làm tính năng JavaScript kiểm tra hai ô mật khẩu phải trùng nhau trước khi gửi. Phía máy chủ PHP cũng kiểm tra lại một lần nữa: nếu email đã tồn tại trong database thì giữ lại các thông tin họ tên, email đã nhập và in thông báo lỗi màu đỏ rõ ràng để người dùng biết đường sửa.

Tệp xử lý chính: `register.php, js/main.js`

Hình 8. Đăng nhập thành công và thanh điều hướng đổi sang trạng thái người dùng

[Vị trí chèn ảnh chụp màn hình Hình 8 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/login.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/login.php`

Mã yêu cầu: C2, C9

Mô tả: Sau khi em nhập đúng tài khoản và mật khẩu, hệ thống sinh lại session id chống Session Fixation và hiển thị thông báo flash message 'Đăng nhập thành công'. Trên thanh điều hướng (header), nút 'Đăng nhập' được tự động thay thế bằng tên của em và menu tài khoản cá nhân.

Tệp xử lý chính: `login.php, includes/header.php`

Hình 9. Form đăng nhập bị tạm khóa sau 5 lần nhập sai liên tiếp

[Vị trí chèn ảnh chụp màn hình Hình 9 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/login.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/login.php`

Mã yêu cầu: D10

Mô tả: Để phòng chống tấn công dò mật khẩu (Brute-force), em cài đặt cơ chế đếm số lần sai trong session. Khi em thử gõ sai mật khẩu liên tiếp 5 lần, form đăng nhập lập tức bị vô hiệu hóa kèm thông báo yêu cầu chờ 5 phút mới được thử lại, mọi yêu cầu gửi lên lúc này đều bị server từ chối.

Tệp xử lý chính: `login.php`

Hình 10. Trang giỏ hàng, tự động tính lại thành tiền và hộp thoại xác nhận khi xóa

[Vị trí chèn ảnh chụp màn hình Hình 10 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/cart.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/cart.php`

Mã yêu cầu: A8, C3

Mô tả: Giỏ hàng hiển thị danh sách các món em đã chọn mua, có đơn giá, số lượng và thành tiền từng món. Khi em bấm nút tăng giảm số lượng (+ hoặc -), JavaScript tự động tính lại thành tiền ngay lập tức. Khi bấm nút xóa toàn bộ giỏ, trình duyệt sẽ bật popup hỏi 'Bạn có chắc chắn muốn xóa giỏ hàng?' để tránh bấm nhầm.

Tệp xử lý chính: `cart.php, cart-update.php, js/main.js`

Hình 11. Trang đặt hàng an toàn trong Transaction và trang chi tiết đơn hàng

[Vị trí chèn ảnh chụp màn hình Hình 11 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/checkout.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/checkout.php`

Mã yêu cầu: C4, C5

Mô tả: Em điền địa chỉ nhận hàng, chọn phương thức thanh toán rồi bấm Xác nhận đặt hàng. Toàn bộ quá trình lưu đơn vào bảng orders, lưu từng món vào order_items và trừ số lượng tồn kho trong bảng products được em đặt trong một Transaction của CSDL để đảm bảo an toàn tuyệt đối, sau đó chuyển hướng về trang xem chi tiết đơn vừa tạo.

Tệp xử lý chính: `checkout.php, order-detail.php`

Hình 12. Lịch sử đơn hàng và chức năng hủy đơn hàng đang chờ xử lý

[Vị trí chèn ảnh chụp màn hình Hình 12 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/orders.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/orders.php`

Mã yêu cầu: C5, C6

Mô tả: Trang này liệt kê tất cả các đơn hàng mà tài khoản của em đã từng mua. Với những đơn hàng đang ở trạng thái 'Chờ xử lý' (pending), hệ thống hiển thị nút 'Hủy đơn hàng'. Khi em bấm hủy, đơn chuyển sang trạng thái 'Đã hủy' và số lượng sản phẩm được tự động hoàn trả lại kho trong database.

Tệp xử lý chính: `orders.php, order-cancel.php`

Hình 13. Trang thông tin tài khoản cá nhân và chức năng đổi mật khẩu

[Vị trí chèn ảnh chụp màn hình Hình 13 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/profile.php và change-password.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/profile.php và change-password.php`

Mã yêu cầu: C7, D11

Mô tả: Tại trang cá nhân, em có thể cập nhật lại số điện thoại và địa chỉ giao hàng của mình. Trong trang đổi mật khẩu, hệ thống bắt buộc em phải nhập đúng mật khẩu hiện tại trước khi thiết lập mật khẩu mới và dùng hàm password_hash để mã hóa mật khẩu mới vào cơ sở dữ liệu.

Tệp xử lý chính: `profile.php, change-password.php`

Hình 14. Gửi form liên hệ và minh chứng dữ liệu được lưu vào bảng contacts

[Vị trí chèn ảnh chụp màn hình Hình 14 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/contact.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/contact.php`

Mã yêu cầu: A7, C8

Mô tả: Em thử điền form liên hệ gửi tin nhắn đóng góp ý kiến. JavaScript chặn không cho gửi nếu nội dung ít hơn 10 ký tự. Khi gửi hợp lệ, PHP dùng Prepared Statement để chèn dữ liệu vào bảng contacts trong database, đồng thời em chụp màn hình phpMyAdmin để chứng minh tin nhắn đã được lưu vào bảng.

Tệp xử lý chính: `contact.php`

Hình 15. Tài khoản khách hàng thông thường bị chặn khi truy cập trang quản trị (HTTP 403)

[Vị trí chèn ảnh chụp màn hình Hình 15 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/admin/index.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/admin/index.php`

Mã yêu cầu: D1

Mô tả: Em đăng nhập bằng tài khoản khách hàng thông thường rồi cố tình gõ đường dẫn /admin/index.php trên trình duyệt. Ở đầu trang admin có hàm require_admin() kiểm tra quyền, nếu không phải admin thì lập tức ngắt kết nối và trả về mã lỗi HTTP 403 Forbidden kèm thông báo từ chối truy cập.

Tệp xử lý chính: `admin/index.php, includes/functions.php`

Hình 16. Trang tổng quan Dashboard của Quản trị viên

[Vị trí chèn ảnh chụp màn hình Hình 16 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/admin/index.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/admin/index.php`

Mã yêu cầu: D9

Mô tả: Khi đăng nhập bằng tài khoản admin, trang tổng quan mở ra thống kê nhanh: tổng số đơn hàng theo từng trạng thái, tổng doanh thu từ các đơn đã hoàn tất, và bảng danh sách 5 sản phẩm có tồn kho thấp nhất (dưới 5 món) để admin kịp thời nhập thêm hàng.

Tệp xử lý chính: `admin/index.php`

Hình 17. Quản lý danh sách sản phẩm và form thêm/sửa sản phẩm có tải ảnh an toàn

[Vị trí chèn ảnh chụp màn hình Hình 17 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/admin/products.php và admin/product-form.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/admin/products.php và admin/product-form.php`

Mã yêu cầu: D2, D3, D7

Mô tả: Admin có thể xem danh sách toàn bộ sản phẩm có phân trang, sửa thông tin và tải ảnh mới lên. File PHP kiểm tra đuôi ảnh hợp lệ, đổi tên file ngẫu nhiên và tự động xóa file ảnh cũ trong thư mục uploads/ khi có ảnh mới được thay thế để tránh làm đầy dung lượng ổ đĩa.

Tệp xử lý chính: `admin/products.php, admin/product-form.php`

Hình 18. Quản lý danh mục và thông báo cảnh báo khi xóa danh mục đang có sản phẩm

[Vị trí chèn ảnh chụp màn hình Hình 18 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/admin/categories.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/admin/categories.php`

Mã yêu cầu: D6

Mô tả: Trang cho phép admin thêm danh mục mới hoặc đổi tên danh mục cũ. Khi em thử bấm xóa một danh mục đang có chứa sản phẩm, hệ thống sẽ kiểm tra trong bảng products và đưa ra thông báo cảnh báo màu đỏ không cho xóa để tránh làm hỏng liên kết dữ liệu của sản phẩm.

Tệp xử lý chính: `admin/categories.php`

Hình 19. Quản lý đơn hàng, lọc theo trạng thái và cập nhật trạng thái đơn

[Vị trí chèn ảnh chụp màn hình Hình 19 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/admin/orders.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/admin/orders.php`

Mã yêu cầu: D4

Mô tả: Admin xem được toàn bộ đơn hàng của khách, có thể lọc đơn theo trạng thái (Đang chờ, Đang giao, Đã hoàn tất, Đã hủy). Admin có thể đổi trạng thái đơn hàng trực tiếp bằng dropdown, hệ thống sẽ lưu ngầm và hiển thị thông báo đã cập nhật thành công.

Tệp xử lý chính: `admin/orders.php`

Hình 20. Chặn truy cập trực tiếp file cấu hình từ trình duyệt (.htaccess HTTP 403)

[Vị trí chèn ảnh chụp màn hình Hình 20 — Lưu ý: Thấy rõ thanh URL 'http://127.0.0.1:8080/config/config.php', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://127.0.0.1:8080/config/config.php`

Mã yêu cầu: D5

Mô tả: Em thử gõ trực tiếp đường dẫn file cấu hình /config/config.php hoặc thư mục /database/ trên trình duyệt. Nhờ tệp cấu hình .htaccess đặt trong các thư mục này với dòng lệnh 'Deny from all', máy chủ Apache lập tức chặn quyền truy cập và báo lỗi 403 Forbidden, giúp bảo vệ an toàn cho thông tin kết nối CSDL.

Tệp xử lý chính: `config/.htaccess, database/.htaccess`

Hình 21. Sơ đồ cơ sở dữ liệu quan hệ và cấu trúc các bảng (phpMyAdmin Designer)

[Vị trí chèn ảnh chụp màn hình Hình 21 — Lưu ý: Thấy rõ thanh URL 'http://localhost/phpmyadmin (Thẻ Designer)', logo chân dung và tên shop LÂM NHỰT HẢI ĐĂNG]

Đường dẫn trang: `http://localhost/phpmyadmin (Thẻ Designer)`

Mã yêu cầu: B2

Mô tả: Sơ đồ cơ sở dữ liệu của dự án gồm 6 bảng có quan hệ chặt chẽ: categories, products, users, orders, order_items và contacts. Tất cả các bảng đều có khóa chính tự tăng (id), các khóa ngoại liên kết (ví dụ category_id, user_id, order_id) và sử dụng bảng mã utf8mb4 hiển thị tiếng Việt hoàn toàn không bị lỗi font.

Tệp xử lý chính: `N25DTCN007_LamNhutHaiDang_Database.sql`

7. Cơ sở dữ liệu

Xuất toàn bộ cơ sở dữ liệu (cấu trúc và dữ liệu của mọi bảng, kể cả bảng tự thêm như `contacts`) thành một tệp .sql bằng **một trong hai** cách sau.

Cách 1 — phpMyAdmin (`http://localhost/phpmyadmin`):

1. Bấm tên cơ sở dữ liệu của dự án ở cột trái.
2. Bấm thẻ **Export** (Xuất).
3. Giữ phương thức **Quick** và định dạng **SQL**, bấm **Export** (hoặc **Go**).
4. Trình duyệt tải về tệp `ten_csdl.sql`; đổi tên thành `MSSV_HoTen_Database.sql`.

Cách 2 — HeidiSQL:

1. Kết nối tới MySQL/MariaDB của máy, nhấp chuột phải vào tên cơ sở dữ liệu, chọn **Export database as SQL** (hoặc menu **Tools → Export database as SQL**).
2. Đánh dấu tất cả các bảng ở khung trái.
3. Mục **Table(s)** chọn **Create**; mục **Data** chọn **Insert**.
4. Mục **Output** chọn **Single .sql file**, chọn nơi lưu với tên `MSSV_HoTen_Database.sql`, bấm **Export**.

Kiểm tra: mở tệp .sql bằng VS Code, phải thấy các câu `CREATE TABLE` và `INSERT INTO` của mọi bảng, tiếng Việt hiển thị đúng dấu. Nếu tệp quá dài do nhiều dữ liệu, vẫn dán trọn vẹn.

Nội dung tệp .sql (dán trọn vẹn, không cắt bớt):

```
-- ========================================================================
-- CSDL ĐỒ ÁN CUỐI KỲ LẬP TRÌNH WEB (PTIT)
-- SINH VIÊN: LÂM NHỰT HẢI ĐĂNG - MSSV: N25DTCN007
-- CỬA HÀNG: LÂM NHỰT HẢI ĐĂNG // HARDWARE ARCHITECTURE & GEAR LAB
-- ========================================================================

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

-- 1. BẢNG DANH MỤC SẢN PHẨM (categories)
DROP TABLE IF EXISTS order_items;
DROP TABLE IF EXISTS orders;
DROP TABLE IF EXISTS products;
DROP TABLE IF EXISTS categories;
DROP TABLE IF EXISTS users;
DROP TABLE IF EXISTS contacts;

CREATE TABLE categories (
    id INT AUTO_INCREMENT PRIMARY KEY,
    name VARCHAR(100) NOT NULL,
    slug VARCHAR(100) NOT NULL UNIQUE,
    description TEXT,
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

-- 2. BẢNG SẢN PHẨM THIẾT BỊ (products)
CREATE TABLE products (
    id INT AUTO_INCREMENT PRIMARY KEY,
    category_id INT NOT NULL,
    sku VARCHAR(50) NOT NULL UNIQUE,
    name VARCHAR(255) NOT NULL,
    slug VARCHAR(255) NOT NULL UNIQUE,
    price DECIMAL(12, 0) NOT NULL,
    stock INT NOT NULL DEFAULT 0,
    image VARCHAR(255) NOT NULL,
    description TEXT,
    specifications TEXT, -- Bảng thông số kỹ thuật (A2)
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
    FOREIGN KEY (category_id) REFERENCES categories(id) ON DELETE RESTRICT
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

-- 3. BẢNG TÀI KHOẢN NGƯỜI DÙNG (users)
CREATE TABLE users (
    id INT AUTO_INCREMENT PRIMARY KEY,
    name VARCHAR(100) NOT NULL,
    email VARCHAR(150) NOT NULL UNIQUE,
    password VARCHAR(255) NOT NULL,
    phone VARCHAR(20),
    address VARCHAR(255),
    role ENUM('admin', 'customer') DEFAULT 'customer',
    failed_attempts INT DEFAULT 0,
    locked_until DATETIME DEFAULT NULL,
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

-- 4. BẢNG ĐƠN HÀNG (orders)
CREATE TABLE orders (
    id INT AUTO_INCREMENT PRIMARY KEY,
    user_id INT NOT NULL,
    order_code VARCHAR(50) NOT NULL UNIQUE,
    recipient_name VARCHAR(100) NOT NULL,
    recipient_phone VARCHAR(20) NOT NULL,
```

```
    shipping_address VARCHAR(255) NOT NULL,
    total_amount DECIMAL(12, 0) NOT NULL,
    status ENUM('pending', 'shipping', 'completed', 'cancelled') DEFAULT 'pending',
    note TEXT,
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
    FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

-- 5. BẢNG CHI TIẾT ĐƠN HÀNG (order_items)
CREATE TABLE order_items (
    id INT AUTO_INCREMENT PRIMARY KEY,
    order_id INT NOT NULL,
    product_id INT NOT NULL,
    price DECIMAL(12, 0) NOT NULL,
    quantity INT NOT NULL,
    FOREIGN KEY (order_id) REFERENCES orders(id) ON DELETE CASCADE,
    FOREIGN KEY (product_id) REFERENCES products(id) ON DELETE RESTRICT
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

-- 6. BẢNG HỘP THƯ LIÊN HỆ (contacts - Tiêu chí C8)
CREATE TABLE contacts (
    id INT AUTO_INCREMENT PRIMARY KEY,
    name VARCHAR(100) NOT NULL,
    email VARCHAR(150) NOT NULL,
    subject VARCHAR(200) NOT NULL,
    message TEXT NOT NULL,
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

SET FOREIGN_KEY_CHECKS = 1;

-- ================================================================================
-- DỮ LIỆU HẠT GIỐNG (SEED DATA)
-- ================================================================================

-- 1. Seed Categories (4 danh mục công nghệ)
INSERT INTO categories (id, name, slug, description) VALUES
(1, 'Bàn Phím Cơ Custom', 'ban-phim-co-custom', 'Bàn phím cơ cao cấp, switch bôi trơn sẵn, mạch
hotswap 8000Hz.'),
(2, 'Laptop Workstation & Gaming', 'laptop-workstation-gaming', 'Máy trạm di động và laptop gaming
hiệu năng đỉnh cao cho kỹ sư & lập trình viên.'),
(3, 'Tai Nghe & Âm Thanh Studio', 'tai-nghe-am-thanh-studio', 'Tai nghe kiểm âm màng từ phẳng Planar
và loa desktop chuẩn audiophile.'),
(4, 'Chuột & Thiết Bị Điều Khiển', 'chuột-thiet-bi-dieu-khien', 'Chuột siêu nhẹ hợp kim Magnesium,
polling rate 8000Hz, cảm biến quang học đỉnh cao.');

-- 2. Seed Users (1 Admin, 2 Khách hàng)
-- Mật khẩu cho admin@lab.ptit.edu.vn: admin123
-- Mật khẩu cho khachhang1@gmail.com & khachhang2@gmail.com: customer123
INSERT INTO users (id, name, email, password, phone, address, role, failed_attempts, locked_until)
VALUES
(1, 'Quản Trị Viên Lâm Nhựt Hải Đăng', 'admin@lab.ptit.edu.vn',
'$2y$10$ZG8Ccx1OeGtQFMT6tPAlAuys8fW6qNUlTXs0y.eK5afD45D3A.IlO', '0912345678', 'Học viện Công nghệ
Bưu chính Viễn thông PTIT, TP.HCM', 'admin', 0, NULL),
(2, 'Nguyễn Hoàng Long', 'khachhang1@gmail.com',
'$2y$10$sQqj0zxbHCC059Gerx43UetQufmJGCz57.QqaId6bmzVIsa5YPq4S', '0987654321', 'Số 45 Lê Duẩn, Quận
1, TP. Hồ Chí Minh', 'customer', 0, NULL),
(3, 'Trần Minh Trang', 'khachhang2@gmail.com',
'$2y$10$sQqj0zxbHCC059Gerx43UetQufmJGCz57.QqaId6bmzVIsa5YPq4S', '0903112233', 'Số 12 Chùa Bộc, Đống
Đa, Hà Nội', 'customer', 0, NULL);

-- 3. Seed Products (12 thiết bị phần cứng cao cấp với thông số A2)
INSERT INTO products (id, category_id, sku, name, slug, price, stock, image, description,
specifications) VALUES
(1, 1, 'KB-8700-PRO', 'Bàn Phím Cơ Custom Pro 87 // Edition 2026', 'ban-phim-co-custom-pro-87',
```

```
2490000, 3, 'keyboard-pro-87.jpg',
'Bàn phím cơ TKL 87 phím thiết kế mạch xuôi, switch Gateron Oil King được bôi trơn thủ công từ nhà máy.',
'{"Cấu trúc Switch": "Gateron Oil King (Linear 55g), Hotswap 5-Pin", "Tần số phản hồi": "8,000 Hz Polling Rate (Độ trễ 0.125ms)", "Chất liệu Keycap": "PBT Doubleshot Cherry Profile chống bóng", "Dung lượng Pin": "4,000 mAh Li-ion (Dùng 200 giờ)", "Kết nối": "Tri-Mode: 2.4GHz / Bluetooth 5.3 / Type-C bọc dù", "Trọng lượng": "1,150 gram (Khung nhôm anodized)"}'),

(2, 1, 'KB-7500-ALU', 'Bàn Phím Gasket-Mount Aluminum 75%', 'ban-phim-gasket-mount-aluminum-75', 3150000, 2, 'keyboard-alu-75.jpg',
'Vỏ nhôm CNC 6063 nguyên khối hoàn thiện anode mịn màng, kết cấu Gasket mount tiêu âm 5 lớp êm ái.',
'{"Cấu trúc": "Gasket Mount 5 lớp Poron Foam & IXPE pad", "Vỏ máy": "Nhôm Anodized CNC 6063 cao cấp", "Tần số phản hồi": "1,000 Hz Wired / 2.4GHz", "Plate": "FR4 flex-cut mạ vàng", "Kết nối": "Không dây 2.4G & Cáp Type-C", "Trọng lượng": "1,680 gram"}'),

(3, 1, 'KB-6800-SLIM', 'Bàn Phím Cơ Low-Profile Slim Wireless 68', 'ban-phim-co-low-profile-slim-68', 1850000, 8, 'keyboard-slim-68.jpg',
'Thiết kế siêu mỏng nhẹ chỉ 18mm, switch low-profile hành trình ngắn tối ưu cho tốc độ gõ code và di động.',
'{"Độ dày": "18mm điểm mỏng nhất", "Switch": "Kailh Choc V2 Red Low-Profile", "Thời lượng pin": "120 giờ không LED", "Trọng lượng": "520 gram siêu nhẹ", "Kết nối": "Bluetooth 5.3 (Lưu 3 thiết bị) & Type-C", "Chất liệu": "Mặt đáy nhựa ABS kỹ thuật, top nhôm"}'),

(4, 2, 'LP-1600-RZ', 'Laptop Razer Blade 16 Studio Edition', 'laptop-razer-blade-16-studio', 54900000, 2, 'laptop-razer-16.jpg',
'Cỗ máy trạm di động tối thượng trang bị màn hình OLED Dual-Mode và card đồ họa chuyên dụng đồ họa và AI.',
'{"Bộ vi xử lý": "Intel Core i9-14900HX (24 nhân, 32 luồng, Turbo 5.8GHz)", "Card đồ họa": "NVIDIA GeForce RTX 4080 12GB GDDR6 (175W TGP)", "Màn hình": "16 inch OLED 2.8K 240Hz / 4K 120Hz Dual-Mode 100% DCI-P3", "RAM": "32GB DDR5 5600MHz (Nâng cấp tối đa 96GB)", "Ổ cứng": "2TB NVMe PCIe Gen4 M.2 SSD", "Pin & Khối lượng": "95.2 Whr, 2.45 kg"}'),

(5, 2, 'LP-1600-MB', 'MacBook Pro 16 M3 Max Hardware Lab', 'macbook-pro-16-m3-max', 79900000, 3, 'macbook-pro-16.jpg',
'Sức mạnh xử lý biên dịch code và dựng đồ họa vô song với chip M3 Max 16-Core CPU và 40-Core GPU.',
'{"Chip": "Apple M3 Max (16 CPU Cores, 40 GPU Cores, 16 Neural Engine)", "Bộ nhớ thống nhất": "64GB Unified Memory (Băng thông 400GB/s)", "Màn hình": "16.2 inch Liquid Retina XDR (1600 nits đỉnh, ProMotion 120Hz)", "Lưu trữ": "1TB SSD siêu tốc 7.4GB/s", "Cổng kết nối": "3x Thunderbolt 4, HDMI, Khe SDXC, MagSafe 3", "Thời lượng pin": "Lên tới 22 giờ sử dụng"}'),

(6, 2, 'LP-1500-TP', 'ThinkPad P1 Gen 6 Mobile Workstation', 'thinkpad-p1-gen-6-workstation', 45500000, 4, 'laptop-thinkpad-p1.jpg',
'Độ bền quân đội chuẩn MIL-STD 810H, bảo mật sinh trắc học cấp doanh nghiệp, bàn phím gõ đỉnh cao.',
'{"Vi xử lý": "Intel Core i7-13800H vPro Enterprise", "Đồ họa": "NVIDIA RTX A2000 Ada Generation 8GB GDDR6", "Màn hình": "16 inch WQXGA (2560x1600) IPS chống chói 500 nits 165Hz", "RAM": "32GB DDR5 Non-ECC", "Bảo mật": "Chip dTPM 2.0, Đầu đọc vân tay, Camera IR mở khóa khuôn mặt", "Trọng lượng": "1.78 kg"}'),

(7, 3, 'HP-9000-PL', 'Tai Nghe Studio Planar Magnetic Pro', 'tai-nghe-studio-planar-magnetic-pro', 8900000, 2, 'headphone-planar-9000.jpg',
'Tai nghe màng từ phẳng Planar Magnetic độ méo tiếng siêu thấp <0.05%, tái tạo âm thanh chuẩn phòng thu.',
'{"Công nghệ củ loa": "Màng từ phẳng Planar Magnetic 100mm", "Dải tần đáp ứng": "8 Hz – 55,000 Hz", "Trở kháng": "32 Ohms (Dễ kéo)", "Độ nhạy": "102 dB / 1mW", "Dây cáp": "Đồng OFC mạ bạc 8 lõi, Jack cắm Balanced 4.4mm & 3.5mm", "Trọng lượng": "410 gram"}'),

(8, 3, 'HP-7000-WL', 'Tai Nghe Gaming Ultra-Low Latency Wireless', 'tai-nghe-gaming-wireless-latency', 3690000, 6, 'headphone-wireless-7000.jpg',
'Kết nối không dây công nghệ lossless 2.4GHz độ trễ siêu thấp dưới 15ms, màng loa Beryllium 50mm.',
'{"Độ trễ truyền âm": "< 15ms qua đầu thu USB 2.4G UltraSync", "Màng loa": "50mm Beryllium-coated Drivers", "Microphone": "Micro điện dung Broadcast tháo rời, lọc ồn AI", "Thời lượng pin": "60 giờ liên tục", "Âm thanh vòm": "Spatial Audio 7.1 tích hợp", "Trọng lượng": "285 gram"}'),

(9, 3, 'SP-5000-MN', 'Cặp Loa Kiểm Âm Để Bàn Desktop Monitor 100W', 'loa-kiem-am-desktop-monitor-100w', 4990000, 5, 'speaker-monitor-5000.jpg',
```

```
'Bộ loa kiểm âm active công suất 100W tích hợp DAC 24-bit/192kHz giải mã tín hiệu âm thanh độ phân giải cao.',
'{"Công suất": "100W RMS (50W mỗi kênh Class-D bi-amped)", "Củ loa Woofer": "4 inch sợi carbon tổng hợp", "Củ loa Tweeter": "1 inch màng lụa mềm vòm", "Ngõ vào": "USB Type-C Lossless, Cáp quang Optical, Cặp cổng RCA balanced", "Dải tần": "48 Hz – 22,000 Hz", "Kích thước": "140 x 180 x 220 mm"}'),

(10, 4, 'MS-3900-MG', 'Chuột Không Dây Magnesium Cực Nhẹ 39g', 'chuot-khong-day-magnesium-39g', 2850000, 2, 'mouse-magnesium-39g.jpg',
'Khung vỏ hợp kim magie đúc rỗng bằng công nghệ CNC, trọng lượng chỉ 39 gram, mắt đọc 8000Hz.',
'{"Trọng lượng": "39 gram (Vỏ Magie hợp kim hàng không)", "Cảm biến": "PixArt PAW3395 (26,000 DPI, 650 IPS, 50G gia tốc)", "Polling Rate": "8,000 Hz Wireless (Phản hồi 0.125ms)", "Switch bấm": "Quang học Omron Optical 100 triệu lần nhấn", "Pin": "Hoạt động 80 giờ ở 1000Hz, 30 giờ ở 8000Hz", "Chân chuột": "100% Virgin Grade PTFE bo tròn mép"}'),

(11, 4, 'MS-5000-MX', 'Chuột Công Thái Học Master Ergonomic Pro', 'chuot-cong-thai-hoc-master-pro', 2190000, 7, 'mouse-ergonomic-pro.jpg',
'Thiết kế nghiêng 57 độ tự nhiên giải tỏa áp lực cổ tay khi lập trình lâu, con lăn thép siêu tốc Magspeed.',
'{"Góc nghiêng công thái học": "57 độ chuẩn y khoa", "Con lăn": "Magspeed thép không gỉ trượt 1,000 dòng/giây", "Cảm biến": "Darkfield 8,000 DPI hoạt động trên mọi bề mặt kính", "Kết nối": "Bluetooth & Logi Bolt, kết nối cùng lúc 3 thiết bị", "Thời lượng pin": "70 ngày một lần sạc nhanh USB-C", "Trọng lượng": "141 gram"}'),

(12, 4, 'MP-1000-GL', 'Bàn Di Chuột Thủy Tinh Cường Lực Lab Mat Pro', 'ban-di-chuot-thuy-tinh-lab-mat', 1450000, 9, 'mousepad-glass-lab.jpg',
'Bề mặt kính silicate tôi luyện nhiệt độ cao tạo độ trơn trượt hoàn hảo không lực cản ma sát, đế cao su chống trượt.',
'{"Vật liệu bề mặt": "Kính cường lực Silicate mờ siêu mịn", "Kích thước": "500 mm x 400 mm x 3.8 mm (Cỡ XL)", "Đế lót": "Đế cao su thiên nhiên đúc vân bám chặt mặt bàn", "Độ bền": "Chống mài mòn vĩnh cửu, kháng nước và dễ lau chùi", "Trọng lượng": "1,800 gram bám bàn tuyệt đối", "Màu sắc": "Đen mờ phòng lab (Matte Lab Black)"}');

-- 4. Seed Orders (5 đơn hàng ở đủ 4 trạng thái theo yêu cầu đề bài)
INSERT INTO orders (id, user_id, order_code, recipient_name, recipient_phone, shipping_address, total_amount, status, note, created_at) VALUES
(1, 2, 'ORD-2026-001', 'Nguyễn Hoàng Long', '0987654321', 'Số 45 Lê Duẩn, Quận 1, TP. Hồ Chí Minh', 5640000, 'pending', 'Giao giờ hành chính, gọi trước khi đến.', '2026-11-03 09:15:00'),
(2, 2, 'ORD-2026-002', 'Nguyễn Hoàng Long', '0987654321', 'Số 45 Lê Duẩn, Quận 1, TP. Hồ Chí Minh', 54900000, 'shipping', 'Đơn hàng giá trị cao, yêu cầu đồng kiểm hàng.', '2026-11-02 14:30:00'),
(3, 3, 'ORD-2026-003', 'Trần Minh Trang', '0903112233', 'Số 12 Chùa Bộc, Đống Đa, Hà Nội', 4990000, 'completed', 'Đã nhận đủ hàng và test thử âm thanh loa rất tốt.', '2026-10-28 10:00:00'),
(4, 3, 'ORD-2026-004', 'Trần Minh Trang', '0903112233', 'Số 12 Chùa Bộc, Đống Đa, Hà Nội', 2490000, 'completed', 'Bàn phím gõ rất mượt, đóng gói cẩn thận.', '2026-10-30 16:45:00'),
(5, 2, 'ORD-2026-005', 'Nguyễn Hoàng Long', '0987654321', 'Số 45 Lê Duẩn, Quận 1, TP. Hồ Chí Minh', 3150000, 'cancelled', 'Khách hàng đặt nhầm màu phím, đã hủy đơn.', '2026-11-01 11:20:00');

-- 5. Seed Order Items (Lưu đơn giá tại thời điểm mua)
INSERT INTO order_items (id, order_id, product_id, price, quantity) VALUES
(1, 1, 1, 2490000, 1),
(2, 1, 2, 3150000, 1),
(3, 2, 4, 54900000, 1),
(4, 3, 9, 4990000, 1),
(5, 4, 1, 2490000, 1),
(6, 5, 2, 3150000, 1);

-- 6. Seed Contacts (Tin nhắn mẫu - Tiêu chí C8)
INSERT INTO contacts (id, name, email, subject, message, created_at) VALUES
(1, 'Lê Quốc Bảo', 'baole@gmail.com', 'Tư vấn cấu hình máy trạm Razer Blade 16', 'Tôi cần tư vấn thêm về khả năng nâng cấp RAM của máy Razer Blade 16 khi chạy các mô hình AI cục bộ.', '2026-11-02 08:30:00'),
(2, 'Phạm Thu Hằng', 'hangpham@yahoo.com', 'Hỏi về thời gian bảo hành Bàn phím cơ Custom', 'Shop cho mình hỏi switch bàn phím Pro 87 có được bảo hành hotswap nếu tự thay tại nhà không ạ?', '2026-11-03
```

```
15:10:00');
```

8. Mã nguồn

Quy tắc dán mã:

- Dán **trọn vẹn từng tệp**, từ dòng đầu đến dòng cuối; không cắt bớt, không viết "… giống giáo trình".
- Mỗi tệp một khung, tiêu đề khung là đường dẫn tệp tính từ thư mục gốc dự án.
- Tệp nào không có trong dự án (hoặc bạn đặt tên khác) thì ghi "Không có" hoặc sửa tiêu đề cho đúng tên.
- Tệp phát sinh thêm ngoài danh sách: liệt kê ở bảng 8.7, rồi chép khung mẫu cuối mục cho mỗi tệp.
- Không dán ảnh, thư mục `uploads/`, `images/`; tệp .sql đã dán ở mục 7.
- `config/db.php` trên hosting: thay mật khẩu cơ sở dữ liệu bằng `***` trước khi dán.

8.1. Cấu hình và tệp dùng chung

config/config.php

```
<?php
/**
 * CẤU HÌNH HỆ THỐNG - CỬA HÀNG CÔNG NGHỆ LÂM NHỰT HẢI ĐĂNG
 * Sinh viên: Lâm Nhựt Hải Đăng | MSSV: N25DTCN007 | Lớp: D25CQCN01-N
 * Môn học: Lập trình Web - Học viện Công nghệ Bưu chính Viễn thông (PTIT)
 */

// Chế độ gỡ lỗi (Tiêu chí 3 Mục 7 đề thi: APP_DEBUG phải là false)
define('APP_DEBUG', false);

if (APP_DEBUG) {
    ini_set('display_errors', 1);
    ini_set('display_startup_errors', 1);
    error_reporting(E_ALL);
} else {
    ini_set('display_errors', 0);
    ini_set('display_startup_errors', 0);
    error_reporting(0);
}

// Múi giờ chuẩn Việt Nam
date_default_timezone_set('Asia/Ho_Chi_Minh');

// Thông tin định danh sinh viên & thương hiệu (Mục 2 cá nhân hóa bắt buộc)
define('APP_NAME', 'LÂM NHỰT HẢI ĐĂNG');
define('APP_SUB_TITLE', 'HARDWARE ARCHITECTURE & GEAR LAB');
define('APP_FOUNDER', 'Lâm Nhựt Hải Đăng');
define('APP_STUDENT_ID', 'N25DTCN007');
define('APP_HOTLINE', '1900 6868');
define('APP_EMAIL', 'dang.ptit2026@gmail.com');
define('APP_ADDRESS', 'Học viện Công nghệ Bưu chính Viễn thông, TP. Hồ Chí Minh');

// Cấu hình Cơ sở dữ liệu MySQL (Tương thích chuẩn Laragon & XAMPP)
define('DB_HOST', '127.0.0.1');
define('DB_PORT', '3306');
define('DB_NAME', 'final_web');
define('DB_USER', 'root');
define('DB_PASS', '');
define('DB_CHARSET', 'utf8mb4');
```

```
// Tự động nhận diện BASE_URL linh hoạt (chạy tốt trên cả Laragon, XAMPP, PHP Built-in Server và Hosting
thật)
$protocol = (!empty($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off') || (isset($_SERVER['SERVER_PORT'])
&& $_SERVER['SERVER_PORT'] == 443) ? 'https://' : 'http://';
$host = $_SERVER['HTTP_HOST'] ?? 'localhost';
$script_name = str_replace('\\', '/', dirname($_SERVER['SCRIPT_NAME'] ?? ''));
$sub_dir = rtrim($script_name, '/');

// Loại bỏ '/admin' nếu đang truy cập từ thư mục admin
if (substr($sub_dir, -6) === '/admin') {
    $sub_dir = substr($sub_dir, 0, -6);
}

define('BASE_URL', rtrim($protocol . $host . $sub_dir, '/') . '/');

// Đường dẫn thư mục máy chủ
define('ROOT_PATH', realpath(__DIR__ . '/..') . DIRECTORY_SEPARATOR);
define('UPLOAD_DIR', ROOT_PATH . 'uploads' . DIRECTORY_SEPARATOR);
define('UPLOAD_URL', BASE_URL . 'uploads/');

// Quy định phân trang & Giới hạn
define('PRODUCTS_PER_PAGE', 8); // Tiêu chí D8: Phân trang 8 sản phẩm/trang
define('MAX_LOGIN_ATTEMPTS', 5); // Tiêu chí D10: 5 lần sai
define('LOCKOUT_DURATION', 300); // 5 phút = 300 giây
```

config/db.php

```
<?php
/**
 * KẾT NỐI CƠ SỞ DỮ LIỆU QUA PDO (TIÊU CHÍ B3 ĐỀ THI)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Hỗ trợ Dual-Driver thông minh: Tự động kết nối MySQL (Laragon/XAMPP/Hosting);
 * Nếu máy chưa bật MySQL thì chuyển đổi mượt mà sang SQLite cục bộ để web luôn chạy 100%.
 */

require_once __DIR__ . '/config.php';

function get_db_connection() {
    static $pdo = null;

    if ($pdo === null) {
        // 1. Thử kết nối tới MySQL / MariaDB (Mặc định cho Laragon & XAMPP)
        try {
            $dsn = "mysql:host=" . DB_HOST . ";port=" . DB_PORT . ";dbname=" . DB_NAME . ";charset=" .
DB_CHARSET;
            $options = [
                PDO::ATTR_ERRMODE            => PDO::ERRMODE_EXCEPTION,
                PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
                PDO::ATTR_EMULATE_PREPARES   => false,
                PDO::ATTR_TIMEOUT            => 1 // Timeout 1s để không treo nếu MySQL chưa bật
            ];
            $pdo = new PDO($dsn, DB_USER, DB_PASS, $options);
        } catch (Throwable $e) {
            // 2. Nếu MySQL chưa khởi động, tự động kết nối SQLite dự phòng
            $sqlite_file = ROOT_PATH . 'database' . DIRECTORY_SEPARATOR . 'final_web.sqlite';
            if (file_exists($sqlite_file)) {
                try {
                    $pdo = new PDO("sqlite:" . $sqlite_file);
                    $pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
                    $pdo->setAttribute(PDO::ATTR_DEFAULT_FETCH_MODE, PDO::FETCH_ASSOC);
                    $pdo->exec("PRAGMA foreign_keys = ON;");
                } catch (Throwable $sqle) {
                    die("Lỗi kết nối CSDL: " . $sqle->getMessage());
                }
            } else {
                die("Không thể kết nối CSDL MySQL và tệp SQLite dự phòng không tồn tại.");
            }
        }
```

```
    }

    return $pdo;
}
```

includes/init.php

```
<?php
/**
 * KHỞI ĐỘNG PHIÊN & NẠP HỆ THỐNG
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

// Cấu hình cookie session bảo mật trước khi session_start()
if (session_status() === PHP_SESSION_NONE) {
    ini_set('session.cookie_httponly', 1);
    ini_set('session.use_only_cookies', 1);
    ini_set('session.use_strict_mode', 1);

    // Nếu có HTTPS thì bật cookie secure
    if (!empty($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off') {
        ini_set('session.cookie_secure', 1);
    }

    session_start();
}

// Gửi HTTP Security Headers chuẩn OWASP chống Clickjacking, MIME-sniffing & XSS
if (!headers_sent()) {
    header('X-Frame-Options: SAMEORIGIN');
    header('X-Content-Type-Options: nosniff');
    header('Referrer-Policy: strict-origin-when-cross-origin');
    header('X-XSS-Protection: 1; mode=block');
    header("Permissions-Policy: camera=(), microphone=(), geolocation=()");
}

require_once __DIR__ . '/../config/config.php';
require_once __DIR__ . '/../config/db.php';
require_once __DIR__ . '/functions.php';

// Khởi tạo kết nối PDO dùng chung
$pdo = get_db_connection();
```

includes/functions.php

```
<?php
/**
 * THƯ VIỆN HÀM TIỆN ÍCH & BẢO MẬT HỆ THỐNG
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

/**
 * Tiêu chí B3: Mọi dữ liệu in ra HTML đều bọc qua e() chống tấn công XSS
 */
function e($string) {
    return htmlspecialchars($string ?? '', ENT_QUOTES, 'UTF-8');
}

/**
 * Tiêu chí D5: Tạo CSRF Token an toàn trong Session
 */
function csrf_token() {
    if (empty($_SESSION['csrf_token'])) {
        $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
    }
    return $_SESSION['csrf_token'];
}
```

```php
/**
 * Sinh thẻ input ẩn chứa CSRF Token cho form POST
 */
function csrf_field() {
    return '<input type="hidden" name="csrf_token" value="' . e(csrf_token()) . '">';
}

/**
 * Tiêu chí D5: Xác thực CSRF Token khi nhận yêu cầu POST
 */
function verify_csrf() {
    if ($_SERVER['REQUEST_METHOD'] === 'POST') {
        $token = $_POST['csrf_token'] ?? '';
        if (empty($token) || empty($_SESSION['csrf_token']) || !hash_equals($_SESSION['csrf_token'],
$token)) {
            http_response_code(403);
            if (!empty($_POST['ajax'])) {
                header('Content-Type: application/json');
                echo json_encode(['success' => false, 'error' => 'CSRF Token không hợp lệ hoặc phiên làm
việc đã hết hạn.']);
                exit;
            }
            die('LỖI BẢO MẬT: CSRF Token không hợp lệ hoặc phiên làm việc đã hết hạn. Vui lòng tải lại
trang.');
        }
    }
}

/**
 * Quản lý Flash Message (Thông báo một lần - Tiêu chí C2 PRG Pattern)
 */
function set_flash($type, $message) {
    $_SESSION['flash'] = [
        'type'    => $type, // 'success', 'danger', 'warning', 'info'
        'message' => $message
    ];
}

function get_flash() {
    if (!empty($_SESSION['flash'])) {
        $flash = $_SESSION['flash'];
        unset($_SESSION['flash']);
        return $flash;
    }
    return null;
}

/**
 * Kiểm tra trạng thái đăng nhập
 */
function is_logged_in() {
    return !empty($_SESSION['user']);
}

function current_user() {
    return $_SESSION['user'] ?? null;
}

function is_admin() {
    return is_logged_in() && ($_SESSION['user']['role'] ?? '') === 'admin';
}

/**
 * Yêu cầu người dùng đăng nhập trước khi tiếp tục (Tiêu chí C9)
 */
function require_login() {
    if (!is_logged_in()) {
        $_SESSION['return_to'] = $_SERVER['REQUEST_URI'];
```

```
        set_flash('warning', 'Vui lòng đăng nhập để tiếp tục thao tác.');
        header('Location: ' . BASE_URL . 'login.php');
        exit;
    }
}

/**
 * Tiêu chí D1: Phân quyền quản trị
 * Đặt require_admin() ở đầu mọi trang admin/. Tài khoản thường bị từ chối với mã HTTP 403.
 */
function require_admin() {
    if (!is_logged_in()) {
        $_SESSION['return_to'] = $_SERVER['REQUEST_URI'];
        set_flash('danger', 'Vui lòng đăng nhập tài khoản quản trị viên.');
        header('Location: ' . BASE_URL . 'login.php');
        exit;
    }

    if (!is_admin()) {
        http_response_code(403);
        include ROOT_PATH . '404.php'; // Hoặc trang thông báo 403 chuyên dụng
        exit;
    }
}

/**
 * Định dạng tiền tệ Việt Nam (VNĐ)
 */
function format_currency($amount) {
    return number_format($amount, 0, ',', '.') . ' ₫';
}

/**
 * Chuyển đổi chuỗi tiếng Việt thành Slug URL thân thiện
 */
function slugify($text) {
    $text = preg_replace('/[áàảãạăắằẳẵặâấầẩẫậ]/u', 'a', $text);
    $text = preg_replace('/[éèẻẽẹêếềểễệ]/u', 'e', $text);
    $text = preg_replace('/[íìỉĩị]/u', 'i', $text);
    $text = preg_replace('/[óòỏõọôốồổỗộơớờởỡợ]/u', 'o', $text);
    $text = preg_replace('/[úùủũụưứừửữự]/u', 'u', $text);
    $text = preg_replace('/[ýỳỷỹỵ]/u', 'y', $text);
    $text = preg_replace('/[đ]/u', 'd', $text);
    $text = preg_replace('/[^a-z0-9\s-]/i', '', $text);
    $text = preg_replace('/[\s-]+/', '-', trim($text));
    return strtolower($text);
}

/**
 * Đếm tổng số lượng món hàng trong giỏ (Session Cart)
 */
function cart_count() {
    if (empty($_SESSION['cart']) || !is_array($_SESSION['cart'])) {
        return 0;
    }
    $total = 0;
    foreach ($_SESSION['cart'] as $item) {
        $total += (int)($item['quantity'] ?? 0);
    }
    return $total;
}

/**
 * Tính tổng tiền giỏ hàng (Luôn đối soát giá từ CSDL - Tiêu chí C3)
 */
function get_cart_items_with_db_prices($pdo) {
    if (empty($_SESSION['cart']) || !is_array($_SESSION['cart'])) {
        return [];
    }
```

```
    $product_ids = array_keys($_SESSION['cart']);
    if (empty($product_ids)) {
        return [];
    }

    // Truy vấn giá mới nhất từ CSDL
    $placeholders = implode(',', array_fill(0, count($product_ids), '?'));
    $stmt = $pdo->prepare("SELECT id, name, sku, slug, price, stock, image FROM products WHERE id IN
($placeholders)");
    $stmt->execute($product_ids);
    $products = $stmt->fetchAll();

    $cart_items = [];
    foreach ($products as $prod) {
        $qty = (int)($_SESSION['cart'][$prod['id']]['quantity'] ?? 1);
        if ($qty > $prod['stock']) {
            $qty = $prod['stock']; // Không vượt quá tồn kho
            $_SESSION['cart'][$prod['id']]['quantity'] = $qty;
        }

        $cart_items[] = [
            'id'       => $prod['id'],
            'name'     => $prod['name'],
            'sku'      => $prod['sku'],
            'slug'     => $prod['slug'],
            'price'    => (float)$prod['price'],
            'stock'    => (int)$prod['stock'],
            'image'    => $prod['image'],
            'quantity' => $qty,
            'subtotal' => (float)$prod['price'] * $qty
        ];
    }

    return $cart_items;
}

/**
 * THƯ VIỆN SVG VECTOR ICON CHUẨN THƯƠNG MẠI ĐIỆN TỬ (QUIET LUXURY)
 * Thay thế toàn bộ OS emoji bằng vector sắc nét, kế thừa màu chữ (currentColor)
 */
function icon($name, $class = '', $size = 18) {
    $icons = [
        'bag' => '<path d="M6 2L3 6v14a2 2 0 002 2h14a2 2 0 002-2V6l-3-4z"/><line x1="3" y1="6" x2="21"
y2="6"/><path d="M16 10a4 4 0 01-8 0"/>',
        'cart' => '<circle cx="9" cy="21" r="1"/><circle cx="20" cy="21" r="1"/><path d="M1 1h4l2.68
13.39a2 2 0 002 1.61h9.72a2 2 0 002-1.61L23 6H6"/>',
        'user' => '<path d="M20 21v-2a4 4 0 00-4-4H8a4 4 0 00-4 4v2"/><circle cx="12" cy="7" r="4"/>',
        'search' => '<circle cx="11" cy="11" r="8"/><line x1="21" y1="21" x2="16.65" y2="16.65"/>',
        'sliders' => '<line x1="4" y1="21" x2="4" y2="14"/><line x1="4" y1="10" x2="4" y2="3"/><line
x1="12" y1="21" x2="12" y2="12"/><line x1="12" y1="8" x2="12" y2="3"/><line x1="20" y1="21" x2="20"
y2="16"/><line x1="20" y1="12" x2="20" y2="3"/><line x1="1" y1="14" x2="7" y2="14"/><line x1="9" y1="8"
x2="15" y2="8"/><line x1="17" y1="16" x2="23" y2="16"/>',
        'arrow-right' => '<line x1="5" y1="12" x2="19" y2="12"/><polyline points="12 5 19 12 12 19"/>',
        'arrow-left' => '<line x1="19" y1="12" x2="5" y2="12"/><polyline points="12 19 5 12 12 5"/>',
        'arrow-up' => '<line x1="12" y1="19" x2="12" y2="5"/><polyline points="5 12 12 5 19 12"/>',
        'chevron-down' => '<polyline points="6 9 12 15 18 9"/>',
        'chevron-right' => '<polyline points="9 18 15 12 9 6"/>',
        'lock' => '<rect x="3" y="11" width="18" height="11" rx="2" ry="2"/><path d="M7 11V7a5 5 0 0110
0v4"/>',
        'shield-check' => '<path d="M12 22s8-4 8-10V5l-8-3-8 3v7c0 6 8 10 8 10z"/><polyline points="9 12
11 14 15 10"/>',
        'truck' => '<rect x="1" y="3" width="15" height="13"/><polygon points="16 8 20 8 23 11 23 16 16 16
16 8"/><circle cx="5.5" cy="18.5" r="2.5"/><circle cx="18.5" cy="18.5" r="2.5"/>',
        'clock' => '<circle cx="12" cy="12" r="10"/><polyline points="12 6 12 12 16 14"/>',
        'check-circle' => '<path d="M22 11.08V12a10 10 0 11-5.93-9.14"/><polyline points="22 4 12 14.01 9
11.01"/>',
        'check' => '<polyline points="20 6 9 17 4 12"/>',
        'x-circle' => '<circle cx="12" cy="12" r="10"/><line x1="15" y1="9" x2="9" y2="15"/><line x1="9"
```

```
y1="9" x2="15" y2="15"/>',
        'x' => '<line x1="18" y1="6" x2="6" y2="18"/><line x1="6" y1="6" x2="18" y2="18"/>',
        'alert-triangle' => '<path d="M10.29 3.86L1.82 18a2 2 0 001.71 3h16.94a2 2 0 001.71-3L13.71 3.86a2
2 0 00-3.42 0z"/><line x1="12" y1="9" x2="12" y2="13"/><line x1="12" y1="17" x2="12.01" y2="17"/>',
        'trash' => '<polyline points="3 6 5 6 21 6"/><path d="M19 6v14a2 2 0 01-2 2H7a2 2 0 01-2-2V6m3
0V4a2 2 0 012-2h4a2 2 0 012 2v2"/><line x1="10" y1="11" x2="10" y2="17"/><line x1="14" y1="11" x2="14"
y2="17"/>',
        'edit' => '<path d="M11 4H4a2 2 0 00-2 2v14a2 2 0 002 2h14a2 2 0 002-2v-7"/><path d="M18.5
2.5a2.121 2.121 0 013 3L12 15l-4 1 1-4 9.5-9.5z"/>',
        'plus' => '<line x1="12" y1="5" x2="12" y2="19"/><line x1="5" y1="12" x2="19" y2="12"/>',
        'save' => '<path d="M19 21H5a2 2 0 01-2-2V5a2 2 0 012-2h11l5 5v11a2 2 0 01-2 2z"/><polyline
points="17 21 17 13 7 13 7 21"/><polyline points="7 3 7 8 15 8"/>',
        'external-link' => '<path d="M18 13v6a2 2 0 01-2 2H5a2 2 0 01-2-2V8a2 2 0 012-2h6"/><polyline
points="15 3 21 3 21 9"/><line x1="10" y1="14" x2="21" y2="3"/>',
        'eye' => '<path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-8z"/><circle cx="12" cy="12"
r="3"/>',
        'dashboard' => '<rect x="3" y="3" width="7" height="9"/><rect x="14" y="3" width="7"
height="5"/><rect x="14" y="12" width="7" height="9"/><rect x="3" y="16" width="7" height="5"/>',
        'box' => '<path d="M21 16V8a2 2 0 00-1-1.73l-7-4a2 2 0 00-2 0l-7 4A2 2 0 003 8v8a2 2 0 001 1.73l7
4a2 2 0 002 0l7-4A2 2 0 0021 16z"/><polyline points="3.27 6.96 12 12.01 20.73 6.96"/><line x1="12"
y1="22.08" x2="12" y2="12"/>',
        'folder' => '<path d="M22 19a2 2 0 01-2 2H4a2 2 0 01-2-2V5a2 2 0 012-2h5l2 3h9a2 2 0 012 2z"/>',
        'receipt' => '<path d="M4 2v20l2-1 2 1 2-1 2 1 2-1 2 1 2-1 2 1V2l-2 1-2-1-2 1-2-1-2 1-2-1-2
1z"/><line x1="8" y1="7" x2="16" y2="7"/><line x1="8" y1="11" x2="16" y2="11"/><line x1="8" y1="15"
x2="12" y2="15"/>',
        'keyboard' => '<rect x="2" y="4" width="20" height="16" rx="2"/><line x1="6" y1="8" x2="6.01"
y2="8"/><line x1="10" y1="8" x2="10.01" y2="8"/><line x1="14" y1="8" x2="14.01" y2="8"/><line x1="18"
y1="8" x2="18.01" y2="8"/><line x1="6" y1="12" x2="6.01" y2="12"/><line x1="10" y1="12" x2="10.01"
y2="12"/><line x1="14" y1="12" x2="14.01" y2="12"/><line x1="18" y1="12" x2="18.01" y2="12"/><line x1="7"
y1="16" x2="17" y2="16"/>',
        'laptop' => '<rect x="3" y="4" width="18" height="12" rx="2"/><path d="M2 20h20"/>',
        'headphones' => '<path d="M3 18v-6a9 9 0 0118 0v6"/><path d="M21 19a2 2 0 01-2 2h-1a2 2 0 01-2-2v-
3a2 2 0 012-2h3zM3 19a2 2 0 002 2h1a2 2 0 002-2v-3a2 2 0 00-2-2H3z"/>',
        'mouse' => '<rect x="6" y="3" width="12" height="18" rx="6"/><line x1="12" y1="7" x2="12"
y2="11"/>',
        'logout' => '<path d="M9 21H5a2 2 0 01-2-2V5a2 2 0 012-2h4"/><polyline points="16 17 21 12 16
7"/><line x1="21" y1="12" x2="9" y2="12"/>'
    ];

    $path = $icons[$name] ?? '<circle cx="12" cy="12" r="10"/>';
    $class_attr = !empty($class) ? ' ' . htmlspecialchars($class, ENT_QUOTES, 'UTF-8') : '';

    return sprintf(
        '<svg class="svg-icon%s" width="%d" height="%d" viewBox="0 0 24 24" fill="none"
stroke="currentColor" stroke-width="1.6" stroke-linecap="round" stroke-linejoin="round" aria-
hidden="true">%s</svg>',
        $class_attr,
        (int)$size,
        (int)$size,
        $path
    );
}
```

includes/header.php

```
<?php
/**
 * PHẦN ĐẦU TRANG DÙNG CHUNG (TIÊU CHÍ A1 & A6)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

$current_page = basename($_SERVER['SCRIPT_NAME'] ?? '');
$flash = get_flash();
?>
<!DOCTYPE html>
<html lang="vi">
<head>
```

```
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title><?= isset($page_title) ? e($page_title) . ' — ' : '' ?><?= e(APP_NAME) ?> // <?=
e(APP_SUB_TITLE) ?></title>
    <link rel="stylesheet" href="<?= BASE_URL ?>css/style.css">
    <script>window.BASE_URL = '<?= BASE_URL ?>'; window.CSRF_TOKEN = '<?= csrf_token() ?>';</script>
</head>
<body>

<!-- 1. THANH TIỆN ÍCH ĐỈNH TRANG (ĐƠN GIẢN & SANG TRỌNG) -->
<div class="top-strip">
    <div class="container">
        <div class="top-strip-brand">
            <span class="top-live-dot"></span>
            <span>Studio & Cửa hàng Chính thức của <strong><?= e(APP_FOUNDER) ?></strong></span>
        </div>
        <div>
            <span>MSSV: <strong><?= e(APP_STUDENT_ID) ?></strong></span>
            <span style="margin: 0 0.5rem; opacity: 0.4;">·</span>
            <span>Giao hàng bảo đảm & Đồng kiểm</span>
        </div>
    </div>
</div>

<!-- 2. HEADER CHÍNH (GLASSMORPHIC & TỐI GIẢN) -->
<header class="main-header">
    <div class="container">
        <div class="header-inner">
            <!-- Logo Chân dung & Tên sinh viên (Mục 2 đề thi cá nhân hóa) -->
            <a href="<?= BASE_URL ?>" class="founder-brand">
                <div class="founder-avatar-frame">
                    <img src="<?= BASE_URL ?>uploads/avatar.jpg" alt="Chân dung Lâm Nhựt Hải Đăng -
N25DTCN007" onerror="this.onerror=null; this.src='data:image/svg+xml;utf8,<svg
xmlns=\'http://www.w3.org/2000/svg\' viewBox=\'0 0 100 100\' fill=\'%23111827\'><circle cx=\'50\'
cy=\'50\' r=\'48\' fill=\'%23f3f4f6\'/><circle cx=\'50\' cy=\'40\' r=\'20\' fill=\'%23334155\'/><path
d=\'M22,85 C22,65 35,60 50,60 C65,60 78,65 78,85 Z\' fill=\'%23334155\'/></svg>'">
                    <span class="founder-live-badge" title="Studio Founder Trực Tuyến"></span>
                </div>
                <div class="founder-text">
                    <div class="founder-name"><?= e(APP_NAME) ?></div>
                    <div class="founder-sub">STUDIO & BOUTIQUE · EST. 2026</div>
                </div>
            </a>

            <!-- Menu Điều Hướng (Tiêu chí A6: Đánh dấu trang hiện tại .active) -->
            <nav class="main-nav">
                <a href="<?= BASE_URL ?>" class="nav-link <?= in_array($current_page, ['index.php', '']) ?
'active' : '' ?>">
                    Trang Chủ
                </a>
                <a href="<?= BASE_URL ?>about.php" class="nav-link <?= $current_page === 'about.php' ?
'active' : '' ?>">
                    Giới Thiệu
                </a>
                <a href="<?= BASE_URL ?>contact.php" class="nav-link <?= $current_page === 'contact.php' ?
'active' : '' ?>">
                    Liên Hệ
                </a>
                <?php if (is_admin()): ?>
                    <a href="<?= BASE_URL ?>admin/index.php" class="nav-link" style="color: var(--accent-
gold); font-weight: 600;">
                        <?= icon('dashboard', '', 15) ?> Quản Trị Studio
                    </a>
                <?php endif; ?>
            </nav>

            <!-- Tiện Ích: Giỏ Hàng & Tài Khoản -->
            <div class="header-actions">
                <a href="<?= BASE_URL ?>cart.php" class="cart-pill" title="Mở giỏ hàng">
```

```
                    <?= icon('bag', '', 16) ?>
                    <span>Giỏ hàng</span>
                    <span class="cart-counter" id="header-cart-count"><?= cart_count() ?></span>
                </a>

                <?php if (is_logged_in()): ?>
                    <div style="display: flex; align-items: center; gap: 0.4rem;">
                        <a href="<?= BASE_URL ?>orders.php" class="nav-link <?= $current_page ===
'orders.php' ? 'active' : '' ?>">
                            <?= icon('receipt', '', 15) ?> Đơn hàng
                        </a>
                        <a href="<?= BASE_URL ?>profile.php" class="nav-link <?= $current_page ===
'profile.php' ? 'active' : '' ?>" style="font-weight: 600;">
                            <?= icon('user', '', 15) ?> <?= e(mb_substr(current_user()['name'], 0, 10))
?>...
                        </a>
                        <a href="<?= BASE_URL ?>logout.php" class="btn-icon" title="Đăng xuất"
style="padding: 0.4rem 0.65rem; color: var(--status-alert);">
                            <?= icon('logout', 'no-margin', 14) ?>
                        </a>
                    </div>
                <?php else: ?>
                    <div style="display: flex; align-items: center; gap: 0.5rem;">
                        <a href="<?= BASE_URL ?>login.php" class="nav-link"><?= icon('user', '', 15) ?>
Đăng Nhập</a>
                        <a href="<?= BASE_URL ?>register.php" class="btn-action-primary" style="padding:
0.45rem 1rem;">Đăng Ký</a>
                    </div>
                <?php endif; ?>
            </div>
        </div>
    </div>
</header>

<!-- THÔNG BÁO FLASH MESSAGE (TIÊU CHÍ C2) -->
<?php if ($flash): ?>
<div class="container" style="margin-top: 1.25rem;">
    <div class="alert alert-<?= e($flash['type']) ?>" style="display: flex; align-items: center; gap:
0.65rem;">
        <span><?= $flash['type'] === 'success' ? icon('check-circle', '', 18) : icon('alert-triangle', '',
18) ?></span>
        <span><?= e($flash['message']) ?></span>
    </div>
</div>
<?php endif; ?>

<main class="main-content">
```

includes/footer.php

```
</main>

<!-- CHÂN TRANG BẮT BUỘC (QUY ĐỊNH MỤC 2 & 5 ĐỀ THI) -->
<footer class="main-footer">
    <div class="container">
        <div class="footer-grid">
            <div>
                <div class="footer-brand-title"><?= e(APP_NAME) ?></div>
                <p style="margin-bottom: 0.8rem; line-height: 1.7; max-width: 48ch;">
                    Không gian công nghệ & thiết bị ngoại vi cao cấp được tuyển chọn tỉ mỉ. Tối ưu cho
trải nghiệm lập trình, sáng tạo và giải trí đỉnh cao.
                </p>
                <!-- DÒNG ĐỊNH DANH BẮT BUỘC THEO ĐỀ THI -->
                <div class="footer-mandatory-id">
                    MSSV: <?= e(APP_STUDENT_ID) ?> — HỌ VÀ TÊN: <?= e(APP_FOUNDER) ?>
                </div>
            </div>
```

```
            <div>
                <h4 style="color: var(--text-primary); margin-bottom: 0.85rem; font-size: 0.9rem; font-
weight: 700;">HỆ THỐNG</h4>
                <ul style="list-style: none; display: flex; flex-direction: column; gap: 0.5rem;">
                    <li><a href="<?= BASE_URL ?>" class="nav-link" style="padding: 0;">Trang Chủ Thiết
Bị</a></li>
                    <li><a href="<?= BASE_URL ?>about.php" class="nav-link" style="padding: 0;">Giới Thiệu
Studio</a></li>
                    <li><a href="<?= BASE_URL ?>contact.php" class="nav-link" style="padding: 0;">Liên Hệ
& Tư Vấn</a></li>
                    <li><a href="<?= BASE_URL ?>cart.php" class="nav-link" style="padding: 0;">Giỏ Hàng
Của Bạn</a></li>
                </ul>
            </div>

            <div>
                <h4 style="color: var(--text-primary); margin-bottom: 0.85rem; font-size: 0.9rem; font-
weight: 700;">THÔNG TIN ĐỒ ÁN</h4>
                <div style="font-size: 0.85rem; line-height: 1.8; color: var(--text-secondary);">
                    <div>Học viện CN Bưu chính Viễn thông</div>
                    <div>Học phần: Lập trình Web PTIT</div>
                    <div>Giảng viên phụ trách: @Le Nhat Tung</div>
                    <div>Hotline: <?= e(APP_HOTLINE) ?></div>
                </div>
            </div>
        </div>

        <div class="footer-bottom">
            <div>© 2026 <?= e(APP_NAME) ?>. Tất cả quyền được bảo lưu.</div>
            <div>Thiết kế theo tiêu chuẩn đồ án cá nhân PTIT</div>
        </div>
    </div>
</footer>

<!-- Nút cuộn nhanh lên đầu trang (Back to top) -->
<button type="button" id="back-to-top" title="Cuộn lên đầu trang">
    <?= icon('arrow-up', 'no-margin', 18) ?>
</button>

<script src="<?= BASE_URL ?>js/main.js"></script>
</body>
</html>
```

includes/admin-nav.php (nếu có)

```
<?php
/**
 * THANH ĐIỀU HƯỚNG QUẢN TRỊ VIÊN (QUIET LUXURY ADMIN SUBBAR)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

$admin_page = basename($_SERVER['SCRIPT_NAME'] ?? '');
?>
<div class="admin-subbar">
    <div class="container admin-subbar-inner">
        <div class="admin-subbar-badge">
            <span class="admin-subbar-dot"></span>
            <span>HỆ THỐNG QUẢN TRỊ STUDIO // <?= e(APP_STUDENT_ID) ?></span>
        </div>

        <nav class="admin-nav-tabs">
            <a href="<?= BASE_URL ?>admin/index.php" class="admin-tab <?= $admin_page === 'index.php' ?
'active' : '' ?>">
                <?= icon('dashboard', '', 15) ?> Tổng Quan
            </a>
            <a href="<?= BASE_URL ?>admin/products.php" class="admin-tab <?= in_array($admin_page,
['products.php', 'product-form.php']) ? 'active' : '' ?>">
                <?= icon('box', '', 15) ?> Sản Phẩm
```

```
            </a>
            <a href="<?= BASE_URL ?>admin/categories.php" class="admin-tab <?= $admin_page ===
'categories.php' ? 'active' : '' ?>">
                <?= icon('folder', '', 15) ?> Danh Mục
            </a>
            <a href="<?= BASE_URL ?>admin/orders.php" class="admin-tab <?= $admin_page === 'orders.php' ?
'active' : '' ?>">
                <?= icon('receipt', '', 15) ?> Đơn Hàng
            </a>
        </nav>

        <div style="display: flex; align-items: center; gap: 0.5rem;">
            <a href="<?= BASE_URL ?>" class="btn-icon" target="_blank" title="Mở trang khách hàng trong
tab mới" style="font-size: 0.8rem;">
                <?= icon('external-link', '', 14) ?> Xem Store Khách
            </a>
            <a href="<?= BASE_URL ?>logout.php" class="btn-icon" style="color: var(--status-alert);
border-color: rgba(239, 68, 68, 0.3); font-size: 0.8rem;">
                <?= icon('logout', '', 14) ?> Đăng Xuất
            </a>
        </div>
    </div>
</div>
```

8.2. Giao diện

css/style.css

```
/* ================================================================================
   QUIET LUXURY & DAYLIGHT STUDIO DESIGN SYSTEM (DESIGN.MD)
   Thương hiệu: LÂM NHỰT HẢI ĐĂNG // STUDIO & BOUTIQUE
   Sinh viên: Lâm Nhựt Hải Đăng | MSSV: N25DTCN007 | PTIT 2026
   Phong cách: Đơn giản & Sang trọng (Apple Store, Bang & Olufsen, Leica)
   ================================================================================ */

@import
url('https://fonts.googleapis.com/css2?family=Plus+Jakarta+Sans:wght@300;400;500;600;700;800&family=JetBra
ins+Mono:wght@400;500;600&display=swap');

:root {
  /* Nền & Bề mặt (Luminous Daylight Surfaces) */
  --bg-body: #fafafc;              /* Nền ngọc trai dịu mát */
  --bg-surface: #ffffff;           /* Trắng tinh khiết */
  --bg-elevated: #f4f4f6;          /* Nền phụ nhẹ nhàng */
  --bg-header: rgba(255, 255, 255, 0.92);
  --bg-hover: #f1f2f5;

  /* Viền & Đổ bóng (Hairline & Soft Natural Elevation) */
  --border-subtle: #e5e7eb;        /* Viền mảnh 1px */
  --border-hover: #d1d5db;
  --border-focus: #111827;
  --shadow-subtle: 0 1px 3px rgba(0, 0, 0, 0.04), 0 1px 2px rgba(0, 0, 0, 0.02);
  --shadow-card: 0 4px 20px -2px rgba(0, 0, 0, 0.04), 0 2px 6px -1px rgba(0, 0, 0, 0.02);
  --shadow-hover: 0 14px 34px -4px rgba(0, 0, 0, 0.08);

  /* Màu chữ & Tương phản (High-Clarity Typography) */
  --text-primary: #111827;         /* Đen than sang trọng */
  --text-secondary: #4b5563;       /* Xám trung tính */
  --text-muted: #9ca3af;           /* Xám nhạt cho chú thích */
  --text-code: #0284c7;

  /* Màu thương hiệu & Điểm nhấn (Timeless Accents) */
  --brand-black: #111827;          /* Đen tuyền thời thượng */
  --brand-black-hover: #1f2937;
  --accent-gold: #c5a059;          /* Vàng Champagne */
  --status-live: #059669;          /* Xanh ngọc lục bảo */
  --status-pending: #d97706;       /* Hổ phách */
```

```
  --status-shipping: #2563eb;      /* Xanh dương hoàng gia */
  --status-alert: #dc2626;         /* Đỏ thanh lịch */

  /* Phông chữ chuyên biệt */
  --font-main: 'Plus Jakarta Sans', -apple-system, BlinkMacSystemFont, 'Segoe UI', Roboto, sans-serif;
  --font-mono: 'JetBrains Mono', 'Consolas', monospace;

  /* Bo góc & Chuyển động vật lý */
  --radius-xs: 4px;
  --radius-sm: 8px;
  --radius-md: 14px;
  --radius-lg: 20px;
  --radius-full: 9999px;
  --transition-smooth: 200ms cubic-bezier(0.16, 1, 0.3, 1);
}

/* Base Reset & Anti-Overflow */
*, *::before, *::after {
  box-sizing: border-box;
  margin: 0;
  padding: 0;
}

html {
  font-size: 15px;
  scroll-behavior: smooth;
}

body {
  background-color: var(--bg-body);
  color: var(--text-primary);
  font-family: var(--font-main);
  line-height: 1.6;
  min-height: 100vh;
  display: flex;
  flex-direction: column;
  overflow-x: hidden;
  -webkit-font-smoothing: antialiased;
  -moz-osx-font-smoothing: grayscale;
}

a {
  color: inherit;
  text-decoration: none;
  transition: var(--transition-smooth);
}

img {
  max-width: 100%;
  height: auto;
  display: block;
}

/* Container chuẩn */
.container {
  width: 100%;
  max-width: 1220px;
  margin-left: auto;
  margin-right: auto;
  padding-left: 1.5rem;
  padding-right: 1.5rem;
}

/* ================================================================================
   1. TOP UTILITY STRIP (THANH ĐỊNH DANH THANH NHÃ ĐỈNH TRANG)
   ================================================================================ */
.top-strip {
  background-color: #f4f4f6;
  border-bottom: 1px solid var(--border-subtle);
```

```
  font-size: 0.75rem;
  color: var(--text-secondary);
  padding: 0.4rem 0;
}

.top-strip .container {
  display: flex;
  justify-content: space-between;
  align-items: center;
  flex-wrap: wrap;
  gap: 0.5rem;
}

.top-strip-brand {
  display: flex;
  align-items: center;
  gap: 0.6rem;
  font-weight: 500;
}

.top-live-dot {
  width: 6px;
  height: 6px;
  background-color: var(--status-live);
  border-radius: 50%;
  display: inline-block;
}

/* ================================================================================
   2. MAIN HEADER (TIÊU CHÍ A1 & A4) - APPLE GLASSMORPHIC MINIMALISM
   ================================================================================ */
.main-header {
  background-color: var(--bg-header);
  backdrop-filter: blur(20px);
  -webkit-backdrop-filter: blur(20px);
  border-bottom: 1px solid var(--border-subtle);
  position: sticky;
  top: 0;
  z-index: 100;
  transition: var(--transition-smooth);
}

.header-inner {
  display: flex;
  align-items: center;
  justify-content: space-between;
  padding: 0.85rem 0;
  gap: 1.5rem;
}

/* Founder Brand & Logo (Mục 2 đề thi: Ảnh chân dung + Tên sinh viên) */
.founder-brand {
  display: flex;
  align-items: center;
  gap: 0.85rem;
}

.founder-avatar-frame {
  position: relative;
  width: 44px;
  height: 44px;
  border-radius: var(--radius-full);
  border: 1px solid var(--border-subtle);
  padding: 2px;
  background: #ffffff;
  box-shadow: 0 2px 8px rgba(0, 0, 0, 0.05);
  flex-shrink: 0;
}
```

```css
.founder-avatar-frame img {
  width: 100%;
  height: 100%;
  object-fit: cover;
  border-radius: var(--radius-full);
}

.founder-live-badge {
  position: absolute;
  bottom: 0;
  right: 0;
  width: 10px;
  height: 10px;
  background-color: var(--status-live);
  border: 2px solid #ffffff;
  border-radius: 50%;
}

.founder-text {
  display: flex;
  flex-direction: column;
}

.founder-name {
  font-size: 1.05rem;
  font-weight: 700;
  letter-spacing: -0.01em;
  color: var(--text-primary);
}

.founder-sub {
  font-size: 0.7rem;
  color: var(--text-muted);
  font-weight: 500;
  letter-spacing: 0.05em;
  text-transform: uppercase;
}

/* Navigation Links (Tiêu chí A6: Đánh dấu trang hiện tại .active) */
.main-nav {
  display: flex;
  align-items: center;
  gap: 0.25rem;
}

.nav-link {
  font-size: 0.88rem;
  font-weight: 500;
  color: var(--text-secondary);
  padding: 0.5rem 0.95rem;
  border-radius: var(--radius-full);
  display: inline-flex;
  align-items: center;
  gap: 0.35rem;
  transition: var(--transition-smooth);
}

.nav-link:hover {
  color: var(--text-primary);
  background-color: var(--bg-hover);
}

.nav-link.active {
  color: var(--brand-black);
  background-color: var(--bg-elevated);
  font-weight: 600;
}

/* Header Utilities */
```

```css
.header-actions {
  display: flex;
  align-items: center;
  gap: 0.75rem;
}

.cart-pill {
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  padding: 0.45rem 0.95rem;
  border-radius: var(--radius-full);
  display: inline-flex;
  align-items: center;
  gap: 0.5rem;
  font-size: 0.82rem;
  font-weight: 600;
  color: var(--text-primary);
  box-shadow: var(--shadow-subtle);
  transition: var(--transition-smooth);
}

.cart-pill:hover {
  border-color: var(--border-hover);
  box-shadow: 0 4px 12px rgba(0, 0, 0, 0.05);
}

.cart-counter {
  background-color: var(--brand-black);
  color: #ffffff;
  font-weight: 700;
  font-size: 0.72rem;
  padding: 0.1rem 0.45rem;
  border-radius: var(--radius-full);
}

/* ================================================================================
   3. HERO SHOWCASE SECTION (THANH THOÁT, SANG TRỌNG)
   ================================================================================ */
.hero-section {
  padding: 3rem 0 2rem 0;
  text-align: center;
}

.hero-box {
  max-width: 780px;
  margin: 0 auto;
}

.hero-tag {
  display: inline-block;
  font-size: 0.75rem;
  font-weight: 600;
  color: var(--accent-gold);
  background: rgba(197, 160, 89, 0.08);
  border: 1px solid rgba(197, 160, 89, 0.2);
  padding: 0.3rem 0.85rem;
  border-radius: var(--radius-full);
  margin-bottom: 1rem;
  letter-spacing: 0.06em;
  text-transform: uppercase;
}

.hero-title {
  font-size: 2.5rem;
  font-weight: 800;
  line-height: 1.2;
  letter-spacing: -0.03em;
  color: var(--text-primary);
  margin-bottom: 1rem;
```

```
}

.hero-desc {
  color: var(--text-secondary);
  font-size: 1.05rem;
  line-height: 1.7;
  max-width: 60ch;
  margin: 0 auto;
}

/* ================================================================================
   4. CONTROL BAR: DANH MỤC, TÌM KIẾM & SẮP XẾP (TIÊU CHÍ B4 & B6)
   ================================================================================ */
.control-bar {
  padding: 1.5rem 0 2rem 0;
  display: flex;
  flex-direction: column;
  gap: 1.25rem;
}

.category-pills {
  display: flex;
  align-items: center;
  justify-content: center;
  gap: 0.5rem;
  overflow-x: auto;
  padding-bottom: 0.5rem;
}

.cat-pill {
  white-space: nowrap;
  font-size: 0.85rem;
  font-weight: 500;
  padding: 0.5rem 1.15rem;
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-full);
  color: var(--text-secondary);
  box-shadow: var(--shadow-subtle);
  transition: var(--transition-smooth);
}

.cat-pill:hover {
  color: var(--text-primary);
  border-color: var(--border-hover);
}

.cat-pill.active {
  color: #ffffff;
  background: var(--brand-black);
  border-color: var(--brand-black);
  font-weight: 600;
}

.filter-actions {
  display: flex;
  align-items: center;
  justify-content: space-between;
  flex-wrap: wrap;
  gap: 1rem;
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-md);
  padding: 0.75rem 1.25rem;
  box-shadow: var(--shadow-subtle);
}

.search-form {
  display: flex;
```

```
  align-items: center;
  background: var(--bg-elevated);
  border: 1px solid transparent;
  border-radius: var(--radius-full);
  padding: 0.2rem 0.6rem;
  width: 100%;
  max-width: 320px;
  transition: var(--transition-smooth);
}

.search-form:focus-within {
  background: #ffffff;
  border-color: var(--border-focus);
}

.search-input {
  background: transparent;
  border: none;
  outline: none;
  color: var(--text-primary);
  font-family: var(--font-main);
  font-size: 0.88rem;
  padding: 0.45rem 0.6rem;
  width: 100%;
}

.search-btn {
  background: transparent;
  border: none;
  color: var(--text-muted);
  cursor: pointer;
  padding: 0.4rem;
  display: flex;
  align-items: center;
  justify-content: center;
}

.search-btn:hover {
  color: var(--text-primary);
}

.sort-group {
  display: flex;
  align-items: center;
  gap: 0.6rem;
  font-size: 0.82rem;
  color: var(--text-secondary);
}

.sort-select {
  background: var(--bg-elevated);
  border: 1px solid transparent;
  color: var(--text-primary);
  font-family: var(--font-main);
  font-size: 0.82rem;
  font-weight: 500;
  padding: 0.45rem 0.95rem;
  border-radius: var(--radius-full);
  outline: none;
  cursor: pointer;
  transition: var(--transition-smooth);
}

.sort-select:focus {
  background: #ffffff;
  border-color: var(--border-focus);
}

.result-count {
```

```
  font-size: 0.82rem;
  color: var(--text-muted);
  font-weight: 500;
}

/* ================================================================================
   5. PRODUCT GRID: LƯỚI SẢN PHẨM RESPONSIVE (TIÊU CHÍ A4 & A5)
   Desktop: 4 cột | Laptop (901-1100px): 3 cột | Tablet: 2 cột | Mobile: 1 cột
   ================================================================================ */
.product-grid {
  display: grid;
  grid-template-columns: repeat(4, 1fr);
  gap: 1.5rem;
  margin-bottom: 3rem;
}

@media (max-width: 1100px) and (min-width: 901px) {
  .product-grid {
    grid-template-columns: repeat(3, 1fr); /* Chuẩn tiêu chí A5 đề thi */
  }
}

@media (max-width: 900px) and (min-width: 601px) {
  .product-grid {
    grid-template-columns: repeat(2, 1fr);
  }
}

@media (max-width: 600px) {
  .product-grid {
    grid-template-columns: 1fr;
  }
}

/* Minimalist Luxury Product Card */
.precision-card {
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-md);
  position: relative;
  display: flex;
  flex-direction: column;
  transition: var(--transition-smooth);
  box-shadow: var(--shadow-card);
  overflow: hidden;
}

.precision-card:hover {
  border-color: var(--border-hover);
  transform: translateY(-4px);
  box-shadow: var(--shadow-hover);
}

.card-top-meta {
  display: flex;
  justify-content: space-between;
  align-items: center;
  padding: 0.85rem 1rem 0.2rem 1rem;
  font-size: 0.72rem;
  color: var(--text-muted);
}

.sku-badge {
  font-family: var(--font-mono);
  font-weight: 500;
  letter-spacing: 0.05em;
  color: var(--text-muted);
}
```

```
.stock-tag {
  display: inline-flex;
  align-items: center;
  gap: 0.35rem;
  font-size: 0.72rem;
  font-weight: 600;
}

.stock-tag.low { color: var(--status-pending); }
.stock-tag.ready { color: var(--status-live); }

.card-img-wrap {
  background: #f8f9fa;
  padding: 1.5rem 1rem;
  display: flex;
  align-items: center;
  justify-content: center;
  position: relative;
}

.card-img-wrap img {
  max-height: 160px;
  width: auto;
  object-fit: contain;
  transition: transform 300ms ease;
}

.precision-card:hover .card-img-wrap img {
  transform: scale(1.04);
}

.card-body {
  padding: 1.15rem 1rem;
  display: flex;
  flex-direction: column;
  flex-grow: 1;
}

.card-title {
  font-size: 0.96rem;
  font-weight: 600;
  line-height: 1.4;
  margin-bottom: 0.5rem;
  color: var(--text-primary);
  display: -webkit-box;
  -webkit-line-clamp: 2;
  -webkit-box-orient: vertical;
  overflow: hidden;
  height: 2.7rem;
}

.card-title:hover {
  color: var(--accent-gold);
}

/* Micro-spec Chips thanh nhã */
.spec-chips {
  display: flex;
  flex-wrap: wrap;
  gap: 0.35rem;
  margin-bottom: 1rem;
}

.spec-chip {
  font-size: 0.7rem;
  color: var(--text-secondary);
  background: var(--bg-elevated);
  padding: 0.2rem 0.55rem;
  border-radius: var(--radius-full);
```

```
}

.card-footer-meta {
  margin-top: auto;
  padding-top: 0.85rem;
  border-top: 1px solid #f1f2f5;
  display: flex;
  align-items: center;
  justify-content: space-between;
}

.card-price {
  font-size: 1.05rem;
  font-weight: 700;
  color: var(--text-primary);
  letter-spacing: -0.01em;
}

.card-actions {
  display: flex;
  gap: 0.4rem;
}

.btn-icon {
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  color: var(--text-secondary);
  padding: 0.4rem 0.75rem;
  border-radius: var(--radius-full);
  cursor: pointer;
  font-size: 0.82rem;
  font-weight: 500;
  transition: var(--transition-smooth);
}

.btn-icon:hover {
  color: var(--text-primary);
  background-color: var(--bg-hover);
  border-color: var(--border-hover);
}

.btn-action-primary {
  background: var(--brand-black);
  color: #ffffff;
  border: 1px solid var(--brand-black);
  padding: 0.45rem 0.85rem;
  border-radius: var(--radius-full);
  font-size: 0.82rem;
  font-weight: 600;
  cursor: pointer;
  display: inline-flex;
  align-items: center;
  gap: 0.35rem;
  transition: var(--transition-smooth);
}

.btn-action-primary:hover {
  background: var(--brand-black-hover);
  box-shadow: 0 4px 12px rgba(17, 24, 39, 0.15);
}

.btn-action-primary:active {
  transform: translateY(1px);
}

/* ================================================================================
   6. BẢNG THÔNG SỐ KỸ THUẬT A2 (EDITORIAL SPEC SHEET)
   ================================================================================ */
.spec-sheet-container {
```

```
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-md);
  margin: 2.5rem 0;
  overflow: hidden;
  box-shadow: var(--shadow-card);
}

.spec-sheet-header {
  background: #fbfbfc;
  padding: 1rem 1.5rem;
  border-bottom: 1px solid var(--border-subtle);
  display: flex;
  align-items: center;
  justify-content: space-between;
  font-size: 0.88rem;
  font-weight: 700;
  color: var(--text-primary);
}

.spec-table {
  width: 100%;
  border-collapse: collapse;
}

.spec-table th, .spec-table td {
  padding: 1rem 1.5rem;
  text-align: left;
  border-bottom: 1px solid #f1f2f5;
}

.spec-table tr:last-child th, .spec-table tr:last-child td {
  border-bottom: none;
}

.spec-table th {
  width: 30%;
  color: var(--text-muted);
  font-weight: 500;
  font-size: 0.88rem;
  background: #fdfdfe;
}

.spec-table td {
  color: var(--text-primary);
  font-weight: 500;
  font-size: 0.9rem;
}

/* ================================================================================
   7. GIỎ HÀNG & MANIFEST CARD
   ================================================================================ */
.manifest-card {
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-md);
  padding: 1.75rem;
  box-shadow: var(--shadow-card);
}

.cart-table {
  width: 100%;
  border-collapse: collapse;
  margin-bottom: 1.5rem;
}

.cart-table th {
  font-size: 0.75rem;
  font-weight: 600;
```

```
  color: var(--text-muted);
  text-transform: uppercase;
  letter-spacing: 0.05em;
  padding: 0.75rem 0.5rem;
  border-bottom: 1px solid var(--border-subtle);
  text-align: left;
}

.cart-table td {
  padding: 1rem 0.5rem;
  border-bottom: 1px solid #f1f2f5;
  vertical-align: middle;
}

.cart-qty-input {
  background: var(--bg-elevated);
  border: 1px solid var(--border-subtle);
  color: var(--text-primary);
  font-size: 0.9rem;
  font-weight: 600;
  width: 55px;
  padding: 0.35rem 0.5rem;
  border-radius: var(--radius-sm);
  text-align: center;
  outline: none;
}

.cart-qty-input:focus {
  border-color: var(--border-focus);
  background: #ffffff;
}

.cart-subtotal {
  font-weight: 700;
  color: var(--text-primary);
}

/* ================================================================================
   8. PHÂN TRANG (TIÊU CHÍ D8)
   ================================================================================ */
.pagination {
  display: flex;
  align-items: center;
  justify-content: center;
  gap: 0.4rem;
  margin: 2.5rem 0;
}

.page-item {
  display: inline-flex;
  align-items: center;
  justify-content: center;
  min-width: 38px;
  height: 38px;
  padding: 0 0.5rem;
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-full);
  color: var(--text-secondary);
  font-size: 0.88rem;
  font-weight: 500;
  box-shadow: var(--shadow-subtle);
  transition: var(--transition-smooth);
}

.page-item:hover {
  color: var(--text-primary);
  border-color: var(--border-hover);
}
```

```
.page-item.active {
  background: var(--brand-black);
  color: #ffffff;
  border-color: var(--brand-black);
  font-weight: 600;
}

/* ================================================================================
   9. FORMS & INPUTS (TIÊU CHÍ A3, C1, D10)
   ================================================================================ */
.form-card {
  max-width: 480px;
  margin: 3.5rem auto;
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-md);
  padding: 2.5rem;
  box-shadow: var(--shadow-card);
}

.form-group {
  margin-bottom: 1.25rem;
}

.form-label {
  display: block;
  font-size: 0.85rem;
  font-weight: 600;
  color: var(--text-secondary);
  margin-bottom: 0.4rem;
}

.form-control {
  width: 100%;
  background: var(--bg-elevated);
  border: 1px solid transparent;
  color: var(--text-primary);
  font-family: var(--font-main);
  font-size: 0.92rem;
  padding: 0.7rem 0.95rem;
  border-radius: var(--radius-sm);
  outline: none;
  transition: var(--transition-smooth);
}

.form-control:focus {
  background: #ffffff;
  border-color: var(--border-focus);
  box-shadow: 0 0 0 3px rgba(17, 24, 39, 0.06);
}

/* Flash Alerts */
.alert {
  padding: 0.95rem 1.25rem;
  border-radius: var(--radius-sm);
  font-size: 0.88rem;
  font-weight: 500;
  margin-bottom: 1.5rem;
  display: flex;
  align-items: center;
  gap: 0.6rem;
}

.alert-success { background: #ecfdf5; border: 1px solid #a7f3d0; color: #065f46; }
.alert-danger { background: #fef2f2; border: 1px solid #fecaca; color: #991b1b; }
.alert-warning { background: #fffbeb; border: 1px solid #fde68a; color: #92400e; }
.alert-info { background: #eff6ff; border: 1px solid #bfdbfe; color: #1e40af; }
```

```css
/* ================================================================================
   10. CHÂN TRANG FOOTER (MỤC 2 & 5 BẮT BUỘC)
   ================================================================================ */
.main-footer {
  margin-top: auto;
  background: #ffffff;
  border-top: 1px solid var(--border-subtle);
  padding: 3rem 0 2rem 0;
  font-size: 0.88rem;
  color: var(--text-secondary);
}

.footer-grid {
  display: grid;
  grid-template-columns: 2fr 1fr 1fr;
  gap: 2.5rem;
  margin-bottom: 2.5rem;
}

@media (max-width: 768px) {
  .footer-grid { grid-template-columns: 1fr; }
}

.footer-brand-title {
  color: var(--text-primary);
  font-size: 1.15rem;
  font-weight: 700;
  margin-bottom: 0.5rem;
}

.footer-mandatory-id {
  display: inline-block;
  background: var(--bg-elevated);
  border: 1px solid var(--border-subtle);
  padding: 0.45rem 1rem;
  border-radius: var(--radius-full);
  color: var(--text-primary);
  font-size: 0.85rem;
  font-weight: 600;
  margin-top: 0.75rem;
}

.footer-bottom {
  border-top: 1px solid var(--border-subtle);
  padding-top: 1.5rem;
  display: flex;
  justify-content: space-between;
  align-items: center;
  flex-wrap: wrap;
  gap: 0.5rem;
  font-size: 0.8rem;
  color: var(--text-muted);
}

/* ================================================================================
   SVG VECTOR ICONS SYSTEM
   ================================================================================ */
.svg-icon {
  display: inline-flex;
  align-items: center;
  justify-content: center;
  vertical-align: middle;
  flex-shrink: 0;
  transition: transform 150ms ease, stroke 150ms ease;
}

.btn-action-primary .svg-icon,
.btn-icon .svg-icon,
.nav-link .svg-icon,
```

```
.cart-pill .svg-icon {
  margin-right: 0.35rem;
}

.svg-icon.no-margin {
  margin: 0 !important;
}

/* ================================================================================
   11. QUIET LUXURY ADMIN CONTROL PLANE (TIÊU CHÍ D1 - D11)
   ================================================================================ */
.admin-subbar {
  background: var(--bg-surface);
  border-bottom: 1px solid var(--border-subtle);
  padding: 0.75rem 0;
  box-shadow: var(--shadow-subtle);
  margin-bottom: 2rem;
}

.admin-subbar-inner {
  display: flex;
  align-items: center;
  justify-content: space-between;
  flex-wrap: wrap;
  gap: 1rem;
}

.admin-subbar-badge {
  display: inline-flex;
  align-items: center;
  gap: 0.5rem;
  font-size: 0.8rem;
  font-weight: 700;
  letter-spacing: 0.05em;
  color: var(--text-primary);
  text-transform: uppercase;
}

.admin-subbar-dot {
  width: 8px;
  height: 8px;
  border-radius: 50%;
  background: var(--accent-gold);
  box-shadow: 0 0 6px rgba(197, 160, 89, 0.5);
}

.admin-nav-tabs {
  display: flex;
  align-items: center;
  gap: 0.35rem;
  overflow-x: auto;
}

.admin-tab {
  font-size: 0.82rem;
  font-weight: 500;
  color: var(--text-secondary);
  padding: 0.45rem 0.95rem;
  border-radius: var(--radius-full);
  border: 1px solid transparent;
  transition: var(--transition-smooth);
}

.admin-tab:hover {
  color: var(--text-primary);
  background: var(--bg-elevated);
}

.admin-tab.active {
```

```
  background: var(--brand-black);
  color: #ffffff;
  font-weight: 600;
}

.admin-kpi-grid {
  display: grid;
  grid-template-columns: repeat(4, 1fr);
  gap: 1.25rem;
  margin-bottom: 2.5rem;
}

@media (max-width: 1024px) {
  .admin-kpi-grid {
    grid-template-columns: repeat(2, 1fr);
  }
}

@media (max-width: 600px) {
  .admin-kpi-grid {
    grid-template-columns: 1fr;
  }
}

.admin-kpi-card {
  background: var(--bg-surface);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-md);
  padding: 1.5rem;
  box-shadow: var(--shadow-card);
  transition: var(--transition-smooth);
  display: flex;
  flex-direction: column;
}

.admin-kpi-card:hover {
  transform: translateY(-2px);
  box-shadow: var(--shadow-hover);
  border-color: var(--border-hover);
}

.admin-kpi-label {
  font-size: 0.72rem;
  font-weight: 600;
  text-transform: uppercase;
  letter-spacing: 0.05em;
  color: var(--text-muted);
  margin-bottom: 0.5rem;
}

.admin-kpi-value {
  font-size: 1.65rem;
  font-weight: 800;
  color: var(--text-primary);
  letter-spacing: -0.02em;
  line-height: 1.2;
}

.admin-kpi-sub {
  font-size: 0.78rem;
  color: var(--text-secondary);
  margin-top: 0.5rem;
}

/* Status Badges */
.badge-status {
  display: inline-flex;
  align-items: center;
  gap: 0.35rem;
```

```
  font-size: 0.72rem;
  font-weight: 600;
  padding: 0.25rem 0.65rem;
  border-radius: var(--radius-full);
  text-transform: uppercase;
  letter-spacing: 0.03em;
}

.badge-pending {
  background: #fef3c7;
  color: #92400e;
  border: 1px solid #fde68a;
}

.badge-shipping {
  background: #eff6ff;
  color: #1e40af;
  border: 1px solid #bfdbfe;
}

.badge-completed {
  background: #ecfdf5;
  color: #065f46;
  border: 1px solid #a7f3d0;
}

.badge-cancelled {
  background: #fef2f2;
  color: #991b1b;
  border: 1px solid #fecaca;
}

.admin-thumb {
  width: 50px;
  height: 50px;
  object-fit: contain;
  background: #f8f9fa;
  padding: 4px;
  border-radius: var(--radius-sm);
  border: 1px solid var(--border-subtle);
}

/* ================================================================================
   12. TIỆN ÍCH TRẢI NGHIỆM CAO CẤP: TOAST, STEPPER, PASSWORD & PRINT
   ================================================================================ */

/* Floating Toast Notification System */
.toast-container {
  position: fixed;
  top: 1.5rem;
  right: 1.5rem;
  z-index: 99999;
  display: flex;
  flex-direction: column;
  gap: 0.75rem;
  pointer-events: none;
}

.toast-message {
  pointer-events: auto;
  background: #ffffff;
  border: 1px solid var(--border-subtle);
  border-left: 4px solid var(--status-live);
  border-radius: var(--radius-sm);
  padding: 0.9rem 1.25rem;
  box-shadow: 0 10px 25px -5px rgba(0, 0, 0, 0.1), 0 8px 10px -6px rgba(0, 0, 0, 0.05);
  display: flex;
  align-items: center;
  gap: 0.75rem;
```

```
  font-size: 0.88rem;
  font-weight: 500;
  color: var(--text-primary);
  min-width: 280px;
  max-width: 380px;
  transform: translateX(120%);
  opacity: 0;
  transition: transform 250ms cubic-bezier(0.16, 1, 0.3, 1), opacity 250ms ease;
}

.toast-message.show {
  transform: translateX(0);
  opacity: 1;
}

.toast-message.toast-warning {
  border-left-color: #f59e0b;
}

.toast-message.toast-error {
  border-left-color: var(--status-alert);
}

/* Ergonomic Quantity Stepper */
.qty-stepper {
  display: inline-flex;
  align-items: center;
  background: var(--bg-elevated);
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-full);
  padding: 2px;
  user-select: none;
}

.qty-btn {
  width: 34px;
  height: 34px;
  border-radius: 50%;
  border: none;
  background: transparent;
  color: var(--text-primary);
  font-size: 1.1rem;
  font-weight: 700;
  cursor: pointer;
  display: inline-flex;
  align-items: center;
  justify-content: center;
  transition: background-color 150ms ease, transform 100ms ease;
}

.qty-btn:hover:not(:disabled) {
  background: #ffffff;
  box-shadow: 0 1px 3px rgba(0,0,0,0.08);
}

.qty-btn:active:not(:disabled) {
  transform: scale(0.92);
}

.qty-btn:disabled {
  opacity: 0.35;
  cursor: not-allowed;
}

.qty-stepper input.cart-qty-input {
  border: none !important;
  background: transparent !important;
  text-align: center;
  width: 44px;
```

```
  padding: 0;
  font-weight: 700;
  font-size: 0.95rem;
  box-shadow: none !important;
  -moz-appearance: textfield;
}

.qty-stepper input.cart-qty-input::-webkit-outer-spin-button,
.qty-stepper input.cart-qty-input::-webkit-inner-spin-button {
  -webkit-appearance: none;
  margin: 0;
}

/* Express Buy Button */
.btn-express-buy {
  background: #1e293b;
  color: #ffffff;
  border: 1px solid #334155;
  padding: 0.85rem 1.75rem;
  border-radius: var(--radius-full);
  font-size: 0.92rem;
  font-weight: 600;
  cursor: pointer;
  display: inline-flex;
  align-items: center;
  gap: 0.5rem;
  transition: var(--transition-smooth);
}

.btn-express-buy:hover {
  background: #0f172a;
  border-color: #0f172a;
  transform: translateY(-1px);
  box-shadow: 0 4px 14px rgba(0, 0, 0, 0.15);
}

/* Password Visibility Toggle */
.password-wrapper {
  position: relative;
  display: flex;
  align-items: center;
}

.password-wrapper .form-control {
  padding-right: 2.75rem;
}

.password-toggle-btn {
  position: absolute;
  right: 0.75rem;
  background: transparent;
  border: none;
  color: var(--text-muted);
  cursor: pointer;
  padding: 0.25rem;
  display: inline-flex;
  align-items: center;
  justify-content: center;
  transition: color 150ms ease;
}

.password-toggle-btn:hover {
  color: var(--text-primary);
}

/* VietQR & Payment Tab Styling */
.payment-tabs {
  display: grid;
  grid-template-columns: 1fr 1fr;
```

```
  gap: 0.75rem;
  margin-bottom: 1.5rem;
}

.payment-tab-option {
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-sm);
  padding: 1rem;
  background: var(--bg-surface);
  cursor: pointer;
  transition: var(--transition-smooth);
  display: flex;
  align-items: flex-start;
  gap: 0.75rem;
}

.payment-tab-option:hover {
  border-color: var(--border-hover);
}

.payment-tab-option.active {
  border-color: var(--brand-black);
  background: #fafafc;
  box-shadow: 0 0 0 1px var(--brand-black);
}

.vietqr-card {
  background: #ffffff;
  border: 1px solid var(--border-subtle);
  border-radius: var(--radius-sm);
  padding: 1.5rem;
  margin-bottom: 1.5rem;
  display: grid;
  grid-template-columns: 140px 1fr;
  gap: 1.5rem;
  align-items: center;
}

@media (max-width: 600px) {
  .vietqr-card {
    grid-template-columns: 1fr;
    text-align: center;
  }
  .vietqr-card img {
    margin: 0 auto;
  }
}

/* Voucher Code Styling */
.voucher-box {
  display: flex;
  gap: 0.5rem;
  margin-bottom: 1.25rem;
}

.voucher-input {
  flex: 1;
  text-transform: uppercase;
  font-family: var(--font-mono);
  letter-spacing: 0.05em;
  font-weight: 600;
}

.voucher-discount-row {
  display: flex;
  justify-content: space-between;
  align-items: center;
  color: var(--status-live);
  font-weight: 600;
```

```
  font-size: 0.95rem;
  margin-bottom: 0.75rem;
}

/* Floating Back to Top Button */
#back-to-top {
  position: fixed;
  bottom: 2rem;
  right: 2rem;
  width: 42px;
  height: 42px;
  border-radius: 50%;
  background: var(--brand-black);
  color: #ffffff;
  border: 1px solid rgba(255, 255, 255, 0.2);
  display: flex;
  align-items: center;
  justify-content: center;
  box-shadow: 0 4px 16px rgba(0, 0, 0, 0.15);
  cursor: pointer;
  z-index: 999;
  opacity: 0;
  visibility: hidden;
  transform: translateY(10px);
  transition: opacity 200ms ease, transform 200ms ease, visibility 200ms ease;
}

#back-to-top.show {
  opacity: 1;
  visibility: visible;
  transform: translateY(0);
}

#back-to-top:hover {
  background: var(--brand-black-hover);
  transform: translateY(-2px);
}

/* Search Clear Button */
.search-clear-btn {
  background: transparent;
  border: none;
  color: var(--text-muted);
  cursor: pointer;
  padding: 0 0.4rem;
  font-size: 0.95rem;
  display: inline-flex;
  align-items: center;
  transition: color 150ms ease;
}

.search-clear-btn:hover {
  color: var(--text-primary);
}

/* Mobile & Table Overflow Protection */
.table-responsive {
  width: 100%;
  overflow-x: auto;
  -webkit-overflow-scrolling: touch;
}

/* Order Progress Stepper */
.order-stepper {
  display: flex;
  align-items: center;
  justify-content: space-between;
  position: relative;
  margin: 2rem 0;
```

```
}

.order-stepper::before {
  content: '';
  position: absolute;
  top: 20px;
  left: 30px;
  right: 30px;
  height: 2px;
  background: var(--border-subtle);
  z-index: 1;
}

.stepper-item {
  position: relative;
  z-index: 2;
  text-align: center;
  display: flex;
  flex-direction: column;
  align-items: center;
}

.stepper-icon {
  width: 40px;
  height: 40px;
  border-radius: 50%;
  background: #ffffff;
  border: 2px solid var(--border-subtle);
  display: flex;
  align-items: center;
  justify-content: center;
  font-size: 0.85rem;
  font-weight: 700;
  color: var(--text-muted);
  margin-bottom: 0.5rem;
  transition: var(--transition-smooth);
}

.stepper-item.active .stepper-icon {
  border-color: var(--brand-black);
  background: var(--brand-black);
  color: #ffffff;
}

.stepper-item.completed .stepper-icon {
  border-color: var(--status-live);
  background: var(--status-live);
  color: #ffffff;
}

.stepper-label {
  font-size: 0.78rem;
  font-weight: 600;
  color: var(--text-muted);
  text-transform: uppercase;
  letter-spacing: 0.03em;
}

.stepper-item.active .stepper-label,
.stepper-item.completed .stepper-label {
  color: var(--text-primary);
}

/* ================================================================================
   13. STYLESHEET DÀNH CHO IN HÓA ĐƠN (@MEDIA PRINT)
   ================================================================================ */
@media print {
  body {
    background: #ffffff !important;
```

```
    color: #000000 !important;
    font-size: 11pt !important;
  }

  .top-utility-bar,
  .main-header,
  .main-footer,
  .nav-link,
  .btn-icon,
  .btn-action-primary,
  .btn-express-buy,
  #back-to-top,
  .toast-container,
  form button[type="submit"] {
    display: none !important;
  }

  .container {
    width: 100% !important;
    max-width: 100% !important;
    padding: 0 !important;
    margin: 0 !important;
  }

  .manifest-card {
    border: 1px solid #cccccc !important;
    box-shadow: none !important;
    border-radius: 0 !important;
    padding: 1.5rem !important;
  }

  .print-invoice-header {
    display: block !important;
    margin-bottom: 2rem !important;
    border-bottom: 2px solid #000000 !important;
    padding-bottom: 1rem !important;
  }
}
```

js/main.js

```
/**
 * JAVASCRIPT ĐIỀU HÀNH TƯƠNG TÁC THỜI GIAN THỰC & TIỆN ÍCH TRẢI NGHIỆM
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Tiêu chí A7, A8, Ajax Add-to-cart, Stepper, Eye Toggle, Toast & Back-to-Top
 */

document.addEventListener('DOMContentLoaded', function () {

  // ================================================================================
  // 0. HỆ THỐNG TOAST THÔNG BÁO NỔI SANG TRỌNG (FLOATING TOAST)
  // ================================================================================
  let toastContainer = document.querySelector('.toast-container');
  if (!toastContainer) {
    toastContainer = document.createElement('div');
    toastContainer.className = 'toast-container';
    document.body.appendChild(toastContainer);
  }

  window.showToast = function (message, type = 'success') {
    const toast = document.createElement('div');
    toast.className = `toast-message toast-${type}`;

    // Icon vector tương ứng
    let iconSvg = '<svg class="svg-icon" width="18" height="18" viewBox="0 0 24 24" fill="none"
stroke="currentColor" stroke-width="2"><path d="M22 11.08V12a10 10 0 1 1-5.93-9.14"></path><polyline
```

```
points="22 4 12 14.01 9 11.01"></polyline></svg>';
    if (type === 'warning') {
      iconSvg = '<svg class="svg-icon" width="18" height="18" viewBox="0 0 24 24" fill="none"
stroke="currentColor" stroke-width="2"><path d="m21.73 18-8-14a2 2 0 0 0-3.48 0l-8 14A2 2 0 0 0 4 21h16a2
2 0 0 0 1.73-3Z"></path><line x1="12" y1="9" x2="12" y2="13"></line><line x1="12" y1="17" x2="12.01"
y2="17"></line></svg>';
    } else if (type === 'error' || type === 'danger') {
      iconSvg = '<svg class="svg-icon" width="18" height="18" viewBox="0 0 24 24" fill="none"
stroke="currentColor" stroke-width="2"><circle cx="12" cy="12" r="10"></circle><line x1="15" y1="9" x2="9"
y2="15"></line><line x1="9" y1="9" x2="15" y2="15"></line></svg>';
    }

    toast.innerHTML = `${iconSvg} <span>${message}</span>`;
    toastContainer.appendChild(toast);

    // Kích hoạt animation trượt vào
    requestAnimationFrame(() => {
      toast.classList.add('show');
    });

    // Tự động mờ và biến mất sau 3 giây
    setTimeout(() => {
      toast.classList.remove('show');
      setTimeout(() => {
        if (toast.parentNode) {
          toast.parentNode.removeChild(toast);
        }
      }, 250);
    }, 3200);
  };

  // Cập nhật số đếm giỏ hàng trên Header với hiệu ứng nhịp tim
  window.updateHeaderCartCount = function (count) {
    const headerCartEl = document.getElementById('header-cart-count');
    if (headerCartEl) {
      headerCartEl.textContent = count;
      headerCartEl.style.transform = 'scale(1.35)';
      headerCartEl.style.transition = 'transform 180ms ease';
      setTimeout(() => {
        headerCartEl.style.transform = 'scale(1)';
      }, 200);
    }
  };

  // ================================================================================
  // 1. AJAX THÊM VÀO GIỎ HÀNG KHÔNG GIÁN ĐOẠN TRANG CHỦ
  // ================================================================================
  document.addEventListener('click', function (e) {
    const btn = e.target.closest('.btn-add-cart-ajax');
    if (!btn) return;

    e.preventDefault();
    const productId = btn.getAttribute('data-id');
    const productName = btn.getAttribute('data-name') || 'Thiết bị';
    const csrfToken = window.CSRF_TOKEN || '';

    // Trạng thái loading nhẹ
    const originalText = btn.innerHTML;
    btn.innerHTML = '...';
    btn.disabled = true;

    fetch(`${window.BASE_URL || ''}cart-add.php`, {
      method: 'POST',
      headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
      body:
`product_id=${encodeURIComponent(productId)}&quantity=1&ajax=1&csrf_token=${encodeURIComponent(csrfToken)}
`
    })
      .then(res => res.json())
```

```
    .then(data => {
      btn.innerHTML = originalText;
      btn.disabled = false;
      if (data.success) {
        window.showToast(`Đã thêm <strong>${productName}</strong> vào giỏ!`, 'success');
        if (typeof data.cart_count !== 'undefined') {
          window.updateHeaderCartCount(data.cart_count);
        }
      } else {
        window.showToast(data.message || 'Không thể thêm sản phẩm.', 'warning');
      }
    })
    .catch(err => {
      btn.innerHTML = originalText;
      btn.disabled = false;
      console.error('Lỗi thêm giỏ hàng:', err);
      window.showToast('Lỗi kết nối máy chủ.', 'error');
    });
});

// ============================================================================
// 2. BỘ NÚT TĂNG GIẢM SỐ LƯỢNG (STEPPER [-] [1] [+])
// ============================================================================
document.addEventListener('click', function (e) {
  const minusBtn = e.target.closest('.qty-btn-minus');
  const plusBtn = e.target.closest('.qty-btn-plus');

  if (minusBtn) {
    const stepper = minusBtn.closest('.qty-stepper');
    if (!stepper) return;
    const input = stepper.querySelector('input.cart-qty-input');
    if (!input) return;
    let val = parseInt(input.value, 10) || 1;
    const min = parseInt(input.getAttribute('min') || '1', 10);
    if (val > min) {
      input.value = val - 1;
      input.dispatchEvent(new Event('change', { bubbles: true }));
    }
  }

  if (plusBtn) {
    const stepper = plusBtn.closest('.qty-stepper');
    if (!stepper) return;
    const input = stepper.querySelector('input.cart-qty-input');
    if (!input) return;
    let val = parseInt(input.value, 10) || 1;
    const max = parseInt(input.getAttribute('max') || '999', 10);
    if (val < max) {
      input.value = val + 1;
      input.dispatchEvent(new Event('change', { bubbles: true }));
    } else {
      window.showToast(`Số lượng tối đa trong kho là ${max} chiếc.`, 'warning');
    }
  }
});

// ============================================================================
// 3. TIÊU CHÍ A8: GIỎ HÀNG TÍNH LẠI THÀNH TIỀN NGAY KHI ĐỔI SỐ LƯỢNG (REAL-TIME)
// ============================================================================
const cartTable = document.querySelector('.cart-table');
if (cartTable) {
  const qtyInputs = cartTable.querySelectorAll('.cart-qty-input');
  const grandTotalEl = document.getElementById('cart-grand-total');

  function formatVND(amount) {
    return new Intl.NumberFormat('vi-VN').format(amount) + ' ₫';
  }

  qtyInputs.forEach(input => {
```

```
      input.addEventListener('change', function () {
        let qty = parseInt(this.value, 10);
        const maxStock = parseInt(this.getAttribute('data-stock') || '99', 10);
        const price = parseFloat(this.getAttribute('data-price') || '0');
        const productId = this.getAttribute('data-id');

        if (isNaN(qty) || qty < 1) {
          qty = 1;
          this.value = 1;
        } else if (qty > maxStock) {
          window.showToast(`Kho chỉ còn ${maxStock} chiếc`, 'warning');
          qty = maxStock;
          this.value = maxStock;
        }

        // Tính lại dòng con
        const subtotal = qty * price;
        const rowSubtotalEl = document.querySelector(`.subtotal-${productId}`);
        if (rowSubtotalEl) {
          rowSubtotalEl.textContent = formatVND(subtotal);
        }

        // Tính lại tổng tiền cả giỏ
        let grandTotal = 0;
        qtyInputs.forEach(item => {
          const itemPrice = parseFloat(item.getAttribute('data-price') || '0');
          const itemQty = parseInt(item.value, 10) || 0;
          grandTotal += itemPrice * itemQty;
        });

        if (grandTotalEl) {
          grandTotalEl.textContent = formatVND(grandTotal);
        }

        // Gửi ngầm Ajax cập nhật vào Session phía máy chủ kèm CSRF Token & đồng bộ badge
        fetch(`${window.BASE_URL || ''}cart-update.php`, {
          method: 'POST',
          headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
          body:
`product_id=${encodeURIComponent(productId)}&quantity=${encodeURIComponent(qty)}&ajax=1&csrf_token=${encod
eURIComponent(window.CSRF_TOKEN || '')}`
        })
          .then(res => res.json())
          .then(data => {
            if (data && typeof data.cart_count !== 'undefined') {
              window.updateHeaderCartCount(data.cart_count);
            }
          })
          .catch(err => console.error('Lỗi đồng bộ giỏ hàng:', err));
      });
    });
  }

  // ================================================================================
  // 4. TIÊU CHÍ A7: KIỂM TRA MẬT KHẨU KHỚP NHAU
  // ================================================================================
  const registerForm = document.querySelector('form#register-form');
  if (registerForm) {
    const passwordInput = registerForm.querySelector('input[name="password"]');
    const confirmInput = registerForm.querySelector('input[name="confirm_password"]');
    const errorMsg = document.createElement('div');
    errorMsg.className = 'field-error-msg';
    errorMsg.style.color = '#ef4444';
    errorMsg.style.fontSize = '0.8rem';
    errorMsg.style.marginTop = '0.35rem';
    errorMsg.style.fontFamily = 'var(--font-mono)';
    confirmInput.parentNode.appendChild(errorMsg);

    function validatePasswordMatch() {
```

```
    if (confirmInput.value && passwordInput.value !== confirmInput.value) {
      errorMsg.textContent = 'Mật khẩu xác nhận không khớp!';
      confirmInput.style.borderColor = '#ef4444';
      return false;
    } else {
      errorMsg.textContent = '';
      confirmInput.style.borderColor = '';
      return true;
    }
  }

  confirmInput.addEventListener('input', validatePasswordMatch);
  passwordInput.addEventListener('input', validatePasswordMatch);

  registerForm.addEventListener('submit', function (e) {
    if (!validatePasswordMatch()) {
      e.preventDefault();
      confirmInput.focus();
    }
  });
}

// ============================================================================
// 5. TIÊU CHÍ A7: FORM LIÊN HỆ CHẶN NỘI DUNG DƯỚI 10 KÝ TỰ
// ============================================================================
const contactForm = document.querySelector('form#contact-form');
if (contactForm) {
  const messageInput = contactForm.querySelector('textarea[name="message"]');
  const charCounter = document.createElement('div');
  charCounter.className = 'char-counter';
  charCounter.style.fontSize = '0.78rem';
  charCounter.style.fontFamily = 'var(--font-mono)';
  charCounter.style.marginTop = '0.35rem';
  charCounter.style.color = 'var(--text-muted)';
  messageInput.parentNode.appendChild(charCounter);

  function updateCounter() {
    const len = messageInput.value.trim().length;
    if (len < 10) {
      charCounter.textContent = `Độ dài: ${len}/10 ký tự (Yêu cầu tối thiểu 10 ký tự)`;
      charCounter.style.color = '#f59e0b';
    } else {
      charCounter.textContent = `✓ Đã đạt ${len} ký tự (Hợp lệ)`;
      charCounter.style.color = '#10b981';
    }
  }

  messageInput.addEventListener('input', updateCounter);
  updateCounter();

  contactForm.addEventListener('submit', function (e) {
    if (messageInput.value.trim().length < 10) {
      e.preventDefault();
      window.showToast('Nội dung tin nhắn liên hệ phải có tối thiểu 10 ký tự!', 'warning');
      messageInput.focus();
    }
  });
}

// ============================================================================
// 6. NÚT MẮT ẨN / HIỆN MẬT KHẨU (EYE TOGGLE)
// ============================================================================
document.querySelectorAll('.password-toggle-btn').forEach(btn => {
  btn.addEventListener('click', function () {
    const wrapper = this.closest('.password-wrapper');
    if (!wrapper) return;
    const input = wrapper.querySelector('input');
    if (!input) return;
```

```
      const isPassword = input.type === 'password';
      input.type = isPassword ? 'text' : 'password';

      // Đổi icon SVG
      if (isPassword) {
        // Icon mắt mở
        this.innerHTML = '<svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>';
        this.title = 'Ẩn mật khẩu';
      } else {
        // Icon mắt gạch chéo
        this.innerHTML = '<svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M17.94 17.94A10.07 10.07 0 0 1 12 20c-7 0-11-
8-11-8a18.45 18.45 0 0 1 5.06-5.94M9.9 4.24A9.12 9.12 0 0 1 12 4c7 0 11 8 11 8a18.5 18.5 0 0 1-2.16 3.19m-
6.72-1.07a3 3 0 1 1-4.24-4.24"></path><line x1="1" y1="1" x2="23" y2="23"></line></svg>';
        this.title = 'Hiện mật khẩu';
      }
    });
  });

  // ================================================================================
  // 7. NÚT XÓA TỪ KHÓA TÌM KIẾM NHANH (CLEAR SEARCH)
  // ================================================================================
  const searchInput = document.querySelector('.search-input');
  const searchClearBtn = document.querySelector('.search-clear-btn');
  if (searchInput && searchClearBtn) {
    searchClearBtn.addEventListener('click', function () {
      searchInput.value = '';
      searchInput.focus();
      const form = searchInput.closest('form');
      if (form) form.submit();
    });
  }

  // ================================================================================
  // 8. XEM TRƯỚC ẢNH SẢN PHẨM TRONG ADMIN (LIVE IMAGE PREVIEW)
  // ================================================================================
  const prodImgInput = document.getElementById('prod-img');
  const prodImgPreview = document.getElementById('prod-img-preview');
  if (prodImgInput && prodImgPreview) {
    prodImgInput.addEventListener('change', function () {
      const file = this.files[0];
      if (file) {
        const reader = new FileReader();
        reader.onload = function (e) {
          prodImgPreview.src = e.target.result;
          prodImgPreview.style.display = 'block';
        };
        reader.readAsDataURL(file);
      }
    });
  }

  // ================================================================================
  // 9. NÚT CUỘN NHANH LÊN ĐẦU TRANG (BACK TO TOP)
  // ================================================================================
  const backToTopBtn = document.getElementById('back-to-top');
  if (backToTopBtn) {
    window.addEventListener('scroll', function () {
      if (window.scrollY > 350) {
        backToTopBtn.classList.add('show');
      } else {
        backToTopBtn.classList.remove('show');
      }
    });

    backToTopBtn.addEventListener('click', function () {
      window.scrollTo({
```

```
        top: 0,
        behavior: 'smooth'
      });
    });
  }

  // ============================================================================
  // 10. HỘP THOẠI XÁC NHẬN [data-confirm]
  // ============================================================================
  const confirmActions = document.querySelectorAll('[data-confirm]');
  confirmActions.forEach(el => {
    // Không bắt sự kiện submit của form có cơ chế ajax riêng
    if (el.closest('.cart-remove-form, .cart-clear-form, .order-cancel-form, .order-detail-cancel-form'))
{
      return;
    }
    el.addEventListener('click', function (e) {
      const message = this.getAttribute('data-confirm') || 'Bạn có chắc chắn muốn thực hiện thao tác
này?';
      if (!confirm(message)) {
        e.preventDefault();
      }
    });
  });

  // ============================================================================
  // 11. ZERO-RELOAD: LỌC DANH MỤC, PHÂN TRANG & SẮP XẾP QUA AJAX
  // ============================================================================
  function loadCatalogAjax(url) {
    const container = document.getElementById('catalog-ajax-container');
    if (!container) return;

    container.style.opacity = '0.4';
    container.style.pointerEvents = 'none';

    fetch(url)
      .then(res => res.text())
      .then(html => {
        const parser = new DOMParser();
        const doc = parser.parseFromString(html, 'text/html');
        const newContainer = doc.getElementById('catalog-ajax-container');
        if (newContainer) {
          container.innerHTML = newContainer.innerHTML;
          window.history.pushState({}, '', url);
        }
      })
      .catch(err => {
        console.error('Lỗi tải danh mục:', err);
        window.location.href = url;
      })
      .finally(() => {
        container.style.opacity = '1';
        container.style.pointerEvents = 'auto';
      });
  }

  document.addEventListener('click', function (e) {
    const pill = e.target.closest('#catalog-ajax-container .category-pills .cat-pill');
    const pageItem = e.target.closest('#catalog-ajax-container .pagination .page-item');
    if (pill && pill.href) {
      e.preventDefault();
      loadCatalogAjax(pill.href);
      return;
    }
    if (pageItem && pageItem.href) {
      e.preventDefault();
      loadCatalogAjax(pageItem.href);
      return;
    }
```

```
  });

  document.addEventListener('change', function (e) {
    if (e.target && e.target.id === 'sort-select' && e.target.closest('#catalog-ajax-container')) {
      e.preventDefault();
      const form = e.target.closest('form');
      if (form) {
        const formData = new FormData(form);
        const params = new URLSearchParams(formData);
        const url = form.action.split('?')[0] + '?' + params.toString();
        loadCatalogAjax(url);
      }
    }
  });

  // ================================================================================
  // 12. ZERO-RELOAD: XÓA DÒNG GIỎ HÀNG & XÓA SẠCH GIỎ QUA AJAX
  // ================================================================================
  document.addEventListener('click', function (e) {
    const removeBtn = e.target.closest('.btn-cart-remove-ajax');
    if (!removeBtn) return;

    e.preventDefault();
    const form = removeBtn.closest('form');
    if (!form) return;

    const confirmMsg = removeBtn.getAttribute('data-confirm') || 'Xóa sản phẩm này khỏi giỏ?';
    if (!confirm(confirmMsg)) return;

    const productId = removeBtn.getAttribute('data-id');
    const row = document.getElementById(`cart-row-${productId}`);
    const csrfToken = window.CSRF_TOKEN || '';

    fetch(form.action, {
      method: 'POST',
      headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
      body:
`action=remove&product_id=${encodeURIComponent(productId)}&ajax=1&csrf_token=${encodeURIComponent(csrfToke
n)}`
    })
      .then(res => res.json())
      .then(data => {
        if (data.success) {
          if (row) {
            row.style.opacity = '0';
            row.style.transform = 'translateX(20px)';
            setTimeout(() => row.remove(), 250);
          }
          const grandTotalEl = document.getElementById('cart-grand-total');
          if (grandTotalEl) {
            grandTotalEl.textContent = data.formatted_grand_total;
          }
          window.updateHeaderCartCount(data.cart_count);
          window.showToast(data.message || 'Đã loại bỏ thiết bị khỏi giỏ!', 'info');

          if (data.is_empty) {
            setTimeout(() => {
              window.location.reload();
            }, 600);
          }
        }
      })
      .catch(err => console.error('Lỗi xóa giỏ hàng:', err));
  });

  document.addEventListener('click', function (e) {
    const clearBtn = e.target.closest('.btn-cart-clear-ajax');
    if (!clearBtn) return;
```

```
    e.preventDefault();
    const form = clearBtn.closest('form');
    if (!form) return;

    const confirmMsg = clearBtn.getAttribute('data-confirm') || 'Bạn có chắc chắn muốn xóa tất cả sản phẩm
khỏi giỏ hàng?';
    if (!confirm(confirmMsg)) return;

    const csrfToken = window.CSRF_TOKEN || '';

    fetch(form.action, {
      method: 'POST',
      headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
      body: `action=clear&ajax=1&csrf_token=${encodeURIComponent(csrfToken)}`
    })
      .then(res => res.json())
      .then(data => {
        if (data.success) {
          window.updateHeaderCartCount(0);
          window.showToast('Đã xóa sạch giỏ hàng.', 'info');
          setTimeout(() => {
            window.location.reload();
          }, 350);
        }
      })
      .catch(err => console.error('Lỗi làm sạch giỏ:', err));
  });

  // ================================================================================
  // 13. ZERO-RELOAD: ÁP DỤNG VOUCHER THANH TOÁN QUA AJAX
  // ================================================================================
  const voucherForm = document.getElementById('voucher-form');
  if (voucherForm) {
    voucherForm.addEventListener('submit', function (e) {
      e.preventDefault();
      const codeInput = document.getElementById('voucher-input-code');
      const code = codeInput ? codeInput.value.trim() : '';
      const csrfToken = window.CSRF_TOKEN || '';

      fetch(voucherForm.action, {
        method: 'POST',
        headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
        body:
`action_voucher=1&voucher_code=${encodeURIComponent(code)}&ajax=1&csrf_token=${encodeURIComponent(csrfToke
n)}`
      })
        .then(res => res.json())
        .then(data => {
          const discountWrap = document.getElementById('voucher-discount-wrap');
          const originalWrap = document.getElementById('original-total-wrap');
          const feedbackMsg = document.getElementById('voucher-feedback-msg');
          const errorText = document.getElementById('voucher-error-text');
          const labelDisplay = document.getElementById('voucher-label-display');
          const amountDisplay = document.getElementById('voucher-amount-display');
          const finalTotalEl = document.getElementById('checkout-final-total');
          const btnTotalEl = document.getElementById('checkout-btn-total');
          const vietqrTotalEl = document.getElementById('vietqr-total-display');
          const vietqrImg = document.getElementById('vietqr-img');

          if (data.success) {
            if (discountWrap) discountWrap.style.display = 'block';
            if (originalWrap) originalWrap.style.display = 'block';
            if (feedbackMsg) feedbackMsg.style.display = 'none';

            if (labelDisplay) labelDisplay.textContent = `Ưu đãi (${data.voucher_code} -
${data.discount_percent}%):`;
            if (amountDisplay) amountDisplay.textContent = `-${data.formatted_discount}`;
            if (finalTotalEl) finalTotalEl.textContent = data.formatted_final_total;
            if (btnTotalEl) btnTotalEl.textContent = data.formatted_final_total;
```

```
            if (vietqrTotalEl) vietqrTotalEl.textContent = data.formatted_final_total;

            if (vietqrImg) {
              vietqrImg.src = `https://api.qrserver.com/v1/create-qr-
code/?size=130x130&data=${encodeURIComponent("2|99|0987654321|LAM NHUT HAI DANG||0|0|" + data.final_total
+ "|MSSV N25DTCN007|transfer_myqr")}`;
            }

            window.showToast(data.message, 'success');
          } else {
            if (discountWrap) discountWrap.style.display = 'none';
            if (originalWrap) originalWrap.style.display = 'none';
            if (feedbackMsg) feedbackMsg.style.display = 'block';
            if (errorText) errorText.textContent = data.message;
            if (finalTotalEl) finalTotalEl.textContent = data.formatted_final_total;
            if (btnTotalEl) btnTotalEl.textContent = data.formatted_final_total;

            window.showToast(data.message, 'warning');
          }
        })
        .catch(err => {
          console.error('Lỗi áp dụng voucher:', err);
          window.showToast('Lỗi kết nối máy chủ.', 'error');
        });
    });
  }

  // ============================================================================
  // 14. ZERO-RELOAD: ADMIN ĐỔI TRẠNG THÁI ĐƠN HÀNG QUA AJAX
  // ============================================================================
  document.addEventListener('change', function (e) {
    if (e.target && e.target.name === 'status' && e.target.closest('.cart-table') &&
e.target.closest('form[action*="admin/orders.php"]')) {
      const select = e.target;
      const form = select.closest('form');
      if (!form) return;

      const orderIdInput = form.querySelector('input[name="order_id"]');
      const orderId = orderIdInput ? orderIdInput.value : '';
      const newStatus = select.value;
      const csrfToken = window.CSRF_TOKEN || '';

      fetch(form.action, {
        method: 'POST',
        headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
        body:
`order_id=${encodeURIComponent(orderId)}&status=${encodeURIComponent(newStatus)}&ajax=1&csrf_token=${encod
eURIComponent(csrfToken)}`
      })
        .then(res => res.json())
        .then(data => {
          if (data.success) {
            window.showToast(data.message, 'success');
          } else {
            window.showToast('Không thể cập nhật trạng thái đơn.', 'warning');
          }
        })
        .catch(err => console.error('Lỗi cập nhật trạng thái đơn:', err));
    }
  });

  // ============================================================================
  // 15. ZERO-RELOAD: KHÁCH HỦY ĐƠN HÀNG QUA AJAX
  // ============================================================================
  document.addEventListener('submit', function (e) {
    const cancelForm = e.target.closest('.order-cancel-form, .order-detail-cancel-form');
    if (!cancelForm) return;

    e.preventDefault();
```

```
    const confirmBtn = cancelForm.querySelector('[data-confirm]');
    const confirmMsg = confirmBtn ? confirmBtn.getAttribute('data-confirm') : 'Bạn có chắc chắn muốn hủy
đơn hàng này không?';
    if (!confirm(confirmMsg)) return;

    const orderIdInput = cancelForm.querySelector('input[name="order_id"]');
    const orderId = orderIdInput ? orderIdInput.value : '';
    const csrfToken = window.CSRF_TOKEN || '';

    fetch(cancelForm.action, {
      method: 'POST',
      headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
      body: `order_id=${encodeURIComponent(orderId)}&ajax=1&csrf_token=${encodeURIComponent(csrfToken)}`
    })
      .then(res => res.json())
      .then(data => {
        if (data.success) {
          window.showToast(data.message, 'info');

          // Cập nhật giao diện orders.php
          const statusCell = document.getElementById(`order-status-${orderId}`);
          if (statusCell) {
            statusCell.innerHTML = '<span class="badge-status badge-cancelled"><svg class="svg-icon"
width="12" height="12" viewBox="0 0 24 24" fill="none" stroke="currentColor" stroke-width="1.6"><circle
cx="12" cy="12" r="10"/><line x1="15" y1="9" x2="9" y2="15"/><line x1="9" y1="9" x2="15" y2="15"/></svg>
Đã hủy</span>';
          }
          cancelForm.remove();

          // Cập nhật giao diện order-detail.php
          const stepper = document.querySelector('.order-stepper');
          if (stepper) {
            const stepperCard = stepper.closest('.manifest-card');
            if (stepperCard) {
              stepperCard.outerHTML = '<div class="alert alert-danger" style="margin-bottom:
2rem;"><span><svg class="svg-icon" width="18" height="18" viewBox="0 0 24 24" fill="none"
stroke="currentColor" stroke-width="1.6"><circle cx="12" cy="12" r="10"/><line x1="15" y1="9" x2="9"
y2="15"/><line x1="9" y1="9" x2="15" y2="15"/></svg></span> <div><strong>Đơn hàng này đã bị hủy.</strong>
Các linh kiện phần cứng đã được hệ thống tự động hoàn trả tồn kho.</div></div>';
            }
          }
        } else {
          window.showToast(data.message || 'Không thể hủy đơn hàng.', 'warning');
        }
      })
      .catch(err => console.error('Lỗi hủy đơn:', err));
  });

});
```

8.3. Trang khách xem hàng

index.php

```
<?php
/**
 * TRANG CHỦ PHÒNG LAB CÔNG NGHỆ (TIÊU CHÍ B4, B6, B7, D8, A4, A5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

$page_title = 'Bộ Sưu Tập Thiết Bị Công Nghệ';

// 1. Thu thập bộ lọc & Từ khóa tìm kiếm (Tiêu chí B4)
$category_id = isset($_GET['cat']) ? (int)$_GET['cat'] : 0;
```

```php
$keyword = trim($_GET['q'] ?? '');

// 2. Sắp xếp an toàn theo Whitelist (Tiêu chí B6: Không ghép tham số vào SQL)
$sort = $_GET['sort'] ?? 'newest';
$sort_whitelist = [
    'price_asc'  => 'p.price ASC',
    'price_desc' => 'p.price DESC',
    'newest'     => 'p.id DESC'
];
$order_by = $sort_whitelist[$sort] ?? 'p.id DESC';

// 3. Xây dựng điều kiện truy vấn động (Dùng 100% Prepared Statements)
$where_clauses = ['1=1'];
$params = [];

if ($category_id > 0) {
    $where_clauses[] = 'p.category_id = ?';
    $params[] = $category_id;
}

if (!empty($keyword)) {
    $where_clauses[] = '(p.name LIKE ? OR p.sku LIKE ? OR p.description LIKE ?)';
    $like = '%' . $keyword . '%';
    $params[] = $like;
    $params[] = $like;
    $params[] = $like;
}

$where_sql = implode(' AND ', $where_clauses);

// 4. Đếm tổng số lượng kết quả (Tiêu chí B7 & D8)
$count_stmt = $pdo->prepare("SELECT COUNT(*) FROM products p WHERE $where_sql");
$count_stmt->execute($params);
$total_products = (int)$count_stmt->fetchColumn();

// 5. Tính toán phân trang 8 sản phẩm/trang (Tiêu chí D8)
$page = isset($_GET['page']) ? max(1, (int)$_GET['page']) : 1;
$limit = PRODUCTS_PER_PAGE;
$total_pages = max(1, (int)ceil($total_products / $limit));
if ($page > $total_pages) {
    $page = $total_pages;
}
$offset = ($page - 1) * $limit;

// 6. Truy vấn danh sách sản phẩm trang hiện tại
$query = "
    SELECT p.*, c.name AS category_name, c.slug AS category_slug
    FROM products p
    JOIN categories c ON p.category_id = c.id
    WHERE $where_sql
    ORDER BY $order_by
    LIMIT $limit OFFSET $offset
";
$stmt = $pdo->prepare($query);
$stmt->execute($params);
$products = $stmt->fetchAll();

// 7. Lấy danh sách toàn bộ danh mục để hiển thị Bộ điều hướng
$categories = $pdo->query("SELECT * FROM categories ORDER BY id ASC")->fetchAll();

require_once __DIR__ . '/includes/header.php';
?>

<!-- HERO SECTION: TINH TẾ & THOÁNG ĐÃNG -->
<section class="hero-section">
    <div class="container">
        <div class="hero-box">
            <span class="hero-tag">BỘ SƯU TẬP CAO CẤP 2026</span>
            <h1 class="hero-title">
```

```
                Thiết Bị Công Nghệ & Studio Tuyển Chọn
            </h1>
            <p class="hero-desc">
                Tuyển chọn những sản phẩm phần cứng tinh tế với trải nghiệm gõ phím cơ xúc giác, âm thanh
trung thực và hiệu năng vượt bậc, mang dấu ấn cá nhân của nhà sáng lập Lâm Nhựt Hải Đăng.
            </p>
        </div>
    </div>
</section>

<!-- BỘ LỌC DANH MỤC, TÌM KIẾM & LƯỚI SẢN PHẨM (AJAX ZERO-RELOAD CONTAINER) -->
<div id="catalog-ajax-container" style="transition: opacity 150ms ease;">
<section class="container control-bar">
    <!-- Cụm nút Danh mục dạng Pills tròn sang trọng -->
    <div class="category-pills">
        <a href="<?= BASE_URL ?>" class="cat-pill <?= $category_id === 0 ? 'active' : '' ?>">
            Tất cả sản phẩm
        </a>
        <?php foreach ($categories as $cat): ?>
            <a href="<?= BASE_URL ?>?cat=<?= $cat['id'] ?><?= !empty($keyword) ? '&q=' .
urlencode($keyword) : '' ?><?= $sort !== 'newest' ? '&sort=' . e($sort) : '' ?>"
               class="cat-pill <?= $category_id == $cat['id'] ? 'active' : '' ?>">
                <?= e($cat['name']) ?>
            </a>
        <?php endforeach; ?>
    </div>

    <!-- Thanh tìm kiếm & Sắp xếp -->
    <div class="filter-actions">
        <!-- Form tìm kiếm theo tên (Tiêu chí B4) -->
        <form action="<?= BASE_URL ?>" method="GET" class="search-form">
            <?php if ($category_id > 0): ?>
                <input type="hidden" name="cat" value="<?= $category_id ?>">
            <?php endif; ?>
            <?php if ($sort !== 'newest'): ?>
                <input type="hidden" name="sort" value="<?= e($sort) ?>">
            <?php endif; ?>
            <input type="text" name="q" value="<?= e($keyword) ?>" placeholder="Tìm kiếm theo tên thiết
bị, SKU..." class="search-input">
            <?php if (!empty($keyword)): ?>
                <button type="button" class="search-clear-btn" title="Xóa tìm kiếm"><?= icon('x', 'no-
margin', 14) ?></button>
            <?php endif; ?>
            <button type="submit" class="search-btn" title="Tìm kiếm"><?= icon('search', 'no-margin', 16)
?></button>
        </form>

        <div style="display: flex; align-items: center; gap: 1.5rem;">
            <!-- Tiêu chí B7: Hiển thị thông báo Tìm thấy N sản phẩm -->
            <div class="result-count">
                Tìm thấy <strong><?= $total_products ?></strong> sản phẩm
            </div>

            <!-- Tiêu chí B6: Bộ chọn Sắp xếp theo giá tăng/giảm -->
            <form action="<?= BASE_URL ?>" method="GET" class="sort-group" id="sort-form">
                <?php if ($category_id > 0): ?>
                    <input type="hidden" name="cat" value="<?= $category_id ?>">
                <?php endif; ?>
                <?php if (!empty($keyword)): ?>
                    <input type="hidden" name="q" value="<?= e($keyword) ?>">
                <?php endif; ?>
                <label for="sort-select" style="font-weight: 500; display: inline-flex; align-items:
center; gap: 0.3rem;">
                    <?= icon('sliders', '', 14) ?> Sắp xếp:
                </label>
                <select name="sort" id="sort-select" class="sort-select"
onchange="document.getElementById('sort-form').submit();">
                    <option value="newest" <?= $sort === 'newest' ? 'selected' : '' ?>>Mới nhất</option>
                    <option value="price_asc" <?= $sort === 'price_asc' ? 'selected' : '' ?>>Giá tăng
```

```
dần</option>
                    <option value="price_desc" <?= $sort === 'price_desc' ? 'selected' : '' ?>>Giá giảm
dần</option>
                </select>
            </form>
        </div>
    </div>
</section>

<!-- LƯỚI SẢN PHẨM RESPONSIVE (TIÊU CHÍ A4 & A5) -->
<section class="container" style="padding-top: 0.5rem;">
    <?php if (empty($products)): ?>
        <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 4rem 2rem; text-align: center; box-shadow: var(--shadow-card);">
            <div style="margin-bottom: 0.75rem; color: var(--text-muted);"><?= icon('box', '', 44)
?></div>
            <h3 style="font-size: 1.15rem; font-weight: 700; margin-bottom: 0.5rem;">Không tìm thấy sản
phẩm phù hợp</h3>
            <p style="color: var(--text-muted); font-size: 0.9rem; margin-bottom: 1.5rem;">Vui lòng thử
lại với từ khóa khác hoặc xóa bộ lọc danh mục.</p>
            <a href="<?= BASE_URL ?>" class="btn-action-primary" style="padding: 0.65rem 1.5rem;">Xem Tất
Cả Sản Phẩm</a>
        </div>
    <?php else: ?>
        <div class="product-grid">
            <?php foreach ($products as $prod): ?>
                <article class="precision-card">
                    <!-- Top Metadata -->
                    <div class="card-top-meta">
                        <span class="sku-badge"><?= e($prod['sku']) ?></span>
                        <?php if ($prod['stock'] <= 3): ?>
                            <span class="stock-tag low" title="Sắp hết hàng">
                                ● Còn <?= $prod['stock'] ?> chiếc
                            </span>
                        <?php else: ?>
                            <span class="stock-tag ready">
                                ● Sẵn hàng
                            </span>
                        <?php endif; ?>
                    </div>

                    <!-- Ảnh sản phẩm -->
                    <a href="<?= BASE_URL ?>product.php?id=<?= $prod['id'] ?>" class="card-img-wrap">
                        <img src="<?= BASE_URL ?>uploads/<?= e($prod['image']) ?>" alt="<?=
e($prod['name']) ?>" loading="lazy">
                    </a>

                    <!-- Nội dung thẻ -->
                    <div class="card-body">
                        <h2 class="card-title">
                            <a href="<?= BASE_URL ?>product.php?id=<?= $prod['id'] ?>">
                                <?= e($prod['name']) ?>
                            </a>
                        </h2>

                        <!-- Micro-spec Chips -->
                        <?php
                        $specs = json_decode($prod['specifications'] ?? '', true);
                        if (!empty($specs) && is_array($specs)):
                            $chip_count = 0;
                        ?>
                            <div class="spec-chips">
                                <?php foreach ($specs as $key => $val): ?>
                                    <?php if ($chip_count < 2): ?>
                                        <span class="spec-chip"><?= e(mb_substr($val, 0, 24)) ?></span>
                                        <?php $chip_count++; ?>
                                    <?php endif; ?>
                                <?php endforeach; ?>
                            </div>
```

```
                        <?php endif; ?>

                        <!-- Footer Card: Giá & Nút hành động -->
                        <div class="card-footer-meta">
                            <div class="card-price">
                                <?= format_currency($prod['price']) ?>
                            </div>
                            <div class="card-actions">
                                <a href="<?= BASE_URL ?>product.php?id=<?= $prod['id'] ?>" class="btn-
icon" title="Xem chi tiết">
                                    Chi tiết
                                </a>
                                <form action="<?= BASE_URL ?>cart-add.php" method="POST" style="margin:
0;">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="product_id" value="<?= $prod['id'] ?>">
                                    <input type="hidden" name="quantity" value="1">
                                    <button type="submit" class="btn-action-primary btn-add-cart-ajax"
data-id="<?= $prod['id'] ?>" data-name="<?= e($prod['name']) ?>" title="Thêm vào giỏ">
                                        <?= icon('plus', '', 13) ?> Thêm
                                    </button>
                                </form>
                            </div>
                        </div>
                    </div>
                </article>
            <?php endforeach; ?>
        </div>

        <!-- PHÂN TRANG (TIÊU CHÍ D8: Giữ bộ lọc danh mục và từ khóa khi chuyển trang) -->
        <?php if ($total_pages > 1): ?>
            <div class="pagination">
                <?php
                $query_params = [];
                if ($category_id > 0) $query_params['cat'] = $category_id;
                if (!empty($keyword)) $query_params['q'] = $keyword;
                if ($sort !== 'newest') $query_params['sort'] = $sort;

                for ($i = 1; $i <= $total_pages; $i++):
                    $query_params['page'] = $i;
                    $page_url = BASE_URL . '?' . http_build_query($query_params);
                ?>
                    <a href="<?= e($page_url) ?>" class="page-item <?= $i === $page ? 'active' : '' ?>">
                        <?= $i ?>
                    </a>
                <?php endfor; ?>
            </div>
        <?php endif; ?>
    <?php endif; ?>
</section>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

product.php

```
<?php
/**
 * TRANG CHI TIẾT SẢN PHẨM & BẢNG THÔNG SỐ (TIÊU CHÍ B5, A2, B7)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

// 1. Kiểm tra tham số id sản phẩm
$id = isset($_GET['id']) ? (int)$_GET['id'] : 0;
```

```
if ($id <= 0) {
    http_response_code(404);
    require_once __DIR__ . '/404.php';
    exit;
}

// 2. Truy vấn chi tiết sản phẩm bằng Prepared Statement (Tiêu chí B3 & B5)
$stmt = $pdo->prepare("
    SELECT p.*, c.name AS category_name, c.slug AS category_slug
    FROM products p
    JOIN categories c ON p.category_id = c.id
    WHERE p.id = ?
");
$stmt->execute([$id]);
$product = $stmt->fetch();

// Tiêu chí B5: Trả về mã 404 khi không tìm thấy sản phẩm trong CSDL
if (!$product) {
    http_response_code(404);
    require_once __DIR__ . '/404.php';
    exit;
}

$page_title = $product['name'] . ' (' . $product['sku'] . ')';

// 3. Tiêu chí B7: Lấy tối đa 3 sản phẩm liên quan cùng danh mục
$rel_stmt = $pdo->prepare("
    SELECT * FROM products
    WHERE category_id = ? AND id != ?
    ORDER BY id DESC
    LIMIT 3
");
$rel_stmt->execute([$product['category_id'], $id]);
$related_products = $rel_stmt->fetchAll();

// 4. Giải mã bảng thông số kỹ thuật (Tiêu chí A2)
$specs = json_decode($product['specifications'] ?? '', true);

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 1.5rem; padding-bottom: 4rem;">
    <!-- Breadcrumbs thanh lịch -->
    <div style="font-size: 0.82rem; color: var(--text-muted); margin-bottom: 1.75rem;">
        <a href="<?= BASE_URL ?>" style="color: var(--text-secondary);">Trang chủ</a>
        <span style="margin: 0 0.4rem; opacity: 0.4;">/</span>
        <a href="<?= BASE_URL ?>?cat=<?= $product['category_id'] ?>" style="color: var(--text-
secondary);"><?= e($product['category_name']) ?></a>
        <span style="margin: 0 0.4rem; opacity: 0.4;">/</span>
        <span style="color: var(--text-primary); font-weight: 500;"><?= e($product['name']) ?></span>
    </div>

    <!-- KHỐI CHI TIẾT SẢN PHẨM -->
    <div style="display: grid; grid-template-columns: 1fr 1fr; gap: 3rem; margin-bottom: 3.5rem;
background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius: var(--radius-md);
padding: 2.5rem; box-shadow: var(--shadow-card);">
        <!-- Cột trái: Ảnh sản phẩm khung Studio -->
        <div style="background: #f8f9fa; border: 1px solid var(--border-subtle); border-radius: var(--
radius-sm); padding: 2.5rem; display: flex; align-items: center; justify-content: center;">
            <img src="<?= BASE_URL ?>uploads/<?= e($product['image']) ?>" alt="<?= e($product['name']) ?>"
style="max-height: 340px; width: auto; object-fit: contain;">
        </div>

        <!-- Cột phải: Thông tin, Giá & Mua hàng -->
        <div style="display: flex; flex-direction: column;">
            <div style="font-size: 0.78rem; font-weight: 600; color: var(--accent-gold); text-transform:
uppercase; letter-spacing: 0.05em; margin-bottom: 0.5rem;">
                <?= e($product['category_name']) ?> · Mã: <?= e($product['sku']) ?>
            </div>
```

```
            <h1 style="font-size: 1.85rem; font-weight: 800; line-height: 1.3; margin-bottom: 0.75rem;
color: var(--text-primary);">
                <?= e($product['name']) ?>
            </h1>

            <div style="font-size: 1.75rem; font-weight: 800; color: var(--text-primary); margin-bottom:
1.25rem;">
                <?= format_currency($product['price']) ?>
            </div>

            <!-- Tình trạng tồn kho -->
            <div style="margin-bottom: 1.5rem; font-size: 0.88rem; font-weight: 500;">
                Tình trạng kho:
                <?php if ($product['stock'] > 0): ?>
                    <span style="color: var(--status-live); font-weight: 600;">
                        ● Sẵn hàng (Còn <?= $product['stock'] ?> chiếc)
                    </span>
                <?php else: ?>
                    <span style="color: var(--status-alert); font-weight: 600; display: inline-flex;
align-items: center; gap: 0.35rem;">
                        <?= icon('x-circle', '', 14) ?> Tạm hết hàng
                    </span>
                <?php endif; ?>
            </div>

            <!-- Mô tả ngắn -->
            <div style="color: var(--text-secondary); font-size: 0.95rem; line-height: 1.7; margin-bottom:
2rem; border-left: 2px solid var(--brand-black); padding-left: 1.25rem;">
                <?= nl2br(e($product['description'])) ?>
            </div>

            <!-- Form Thêm Giỏ Hàng & Mua Ngay -->
            <?php if ($product['stock'] > 0): ?>
                <form action="<?= BASE_URL ?>cart-add.php" method="POST" style="margin-top: auto; display:
flex; flex-wrap: wrap; align-items: center; gap: 1rem;">
                    <?= csrf_field() ?>
                    <input type="hidden" name="product_id" value="<?= $product['id'] ?>">

                    <div style="display: flex; align-items: center; gap: 0.65rem; font-size: 0.88rem;
font-weight: 600;">
                        <span>Số lượng:</span>
                        <div class="qty-stepper">
                            <button type="button" class="qty-btn qty-btn-minus" title="Giảm số lượng">-
</button>
                            <input type="number" id="qty-input" name="quantity" value="1" min="1" max="<?=
$product['stock'] ?>" class="cart-qty-input" data-stock="<?= $product['stock'] ?>">
                            <button type="button" class="qty-btn qty-btn-plus" title="Tăng số
lượng">+</button>
                        </div>
                    </div>

                    <div style="display: flex; align-items: center; gap: 0.75rem; flex-wrap: wrap;">
                        <button type="submit" class="btn-action-primary" style="padding: 0.85rem 1.75rem;
font-size: 0.92rem;">
                            <?= icon('bag', '', 18) ?> Thêm Vào Giỏ
                        </button>
                        <button type="submit" name="express" value="1" class="btn-express-buy" title="Thêm
vào giỏ và tiến hành thanh toán ngay lập tức">
                            <?= icon('check', '', 16) ?> Mua Ngay
                        </button>
                    </div>
                </form>
            <?php endif; ?>
        </div>
    </div>

    <!-- TIÊU CHÍ A2: BẢNG THÔNG SỐ KỸ THUẬT SANG TRỌNG -->
    <div class="spec-sheet-container">
```

```
        <div class="spec-sheet-header">
            <span>BẢNG THÔNG SỐ KỸ THUẬT (TIÊU CHÍ A2)</span>
            <span style="font-size: 0.75rem; color: var(--text-muted); font-weight: 500;">KIỂM ĐỊNH CHÍNH
HÃNG</span>
        </div>
        <table class="spec-table">
            <tbody>
                <tr>
                    <th>Mã sản phẩm (SKU)</th>
                    <td><?= e($product['sku']) ?></td>
                </tr>
                <tr>
                    <th>Danh mục thiết bị</th>
                    <td><?= e($product['category_name']) ?></td>
                </tr>
                <tr>
                    <th>Số lượng tồn kho</th>
                    <td><?= $product['stock'] ?> chiếc sẵn sàng xuất kho</td>
                </tr>
                <?php if (!empty($specs) && is_array($specs)): ?>
                    <?php foreach ($specs as $param => $val): ?>
                        <tr>
                            <th><?= e($param) ?></th>
                            <td><?= e($val) ?></td>
                        </tr>
                    <?php endforeach; ?>
                <?php endif; ?>
            </tbody>
        </table>
    </div>

    <!-- TIÊU CHÍ B7: CUỐI TRANG CHI TIẾT HIỂN THỊ TỐI ĐA 3 SẢN PHẨM CÙNG DANH MỤC -->
    <?php if (!empty($related_products)): ?>
        <div style="margin-top: 4rem;">
            <div style="font-size: 1.15rem; font-weight: 700; color: var(--text-primary); margin-bottom:
1.5rem;">
                Sản phẩm cùng danh mục (Tối đa 3 sản phẩm)
            </div>
            <div style="display: grid; grid-template-columns: repeat(3, 1fr); gap: 1.5rem;">
                <?php foreach ($related_products as $rel): ?>
                    <article class="precision-card">
                        <div class="card-top-meta">
                            <span class="sku-badge"><?= e($rel['sku']) ?></span>
                            <span class="stock-tag ready">● Còn <?= $rel['stock'] ?></span>
                        </div>
                        <a href="<?= BASE_URL ?>product.php?id=<?= $rel['id'] ?>" class="card-img-wrap">
                            <img src="<?= BASE_URL ?>uploads/<?= e($rel['image']) ?>" alt="<?=
e($rel['name']) ?>" style="max-height: 130px;">
                        </a>
                        <div class="card-body">
                            <h3 class="card-title" style="font-size: 0.92rem; height: 2.5rem;">
                                <a href="<?= BASE_URL ?>product.php?id=<?= $rel['id'] ?>"><?=
e($rel['name']) ?></a>
                            </h3>
                            <div class="card-footer-meta">
                                <div class="card-price" style="font-size: 1rem;"><?=
format_currency($rel['price']) ?></div>
                                <a href="<?= BASE_URL ?>product.php?id=<?= $rel['id'] ?>" class="btn-
action-primary" style="padding: 0.35rem 0.85rem; font-size: 0.8rem;">
                                    Chi tiết
                                </a>
                            </div>
                        </div>
                    </article>
                <?php endforeach; ?>
            </div>
        </div>
    <?php endif; ?>
</div>
```

```
<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

about.php

```
<?php
/**
 * TRANG GIỚI THIỆU PHÒNG LAB (TIÊU CHÍ A2: CÓ BẢNG THÔNG SỐ)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

$page_title = 'Giới Thiệu Studio & Nhà Sáng Lập';

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 2rem; padding-bottom: 5rem;">
    <!-- Giới thiệu chính -->
    <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 3rem; margin-bottom: 3rem; box-shadow: var(--shadow-card);">
        <span class="hero-tag">ABOUT OUR STUDIO</span>
        <h1 style="font-size: 2.2rem; font-weight: 800; margin-bottom: 1.25rem; color: var(--text-
primary);">
            Không Gian Công Nghệ Tuyển Chọn<br>
            Sáng Lập Bởi <span style="color: var(--accent-gold);"><?= e(APP_FOUNDER) ?></span>
        </h1>
        <p style="color: var(--text-secondary); font-size: 1.05rem; line-height: 1.8; margin-bottom:
1.5rem; max-width: 75ch;">
            Chào mừng bạn đến với Studio Công nghệ được xây dựng bởi sinh viên <strong><?= e(APP_FOUNDER)
?></strong> (Mã số sinh viên: <strong><?= e(APP_STUDENT_ID) ?></strong>) tại Học viện Công nghệ Bưu chính
Viễn thông (PTIT). Định hướng của chúng tôi là mang đến những thiết bị phần cứng tối giản, tinh tế, sở hữu
độ hoàn thiện cơ học cao nhất phục vụ cho các lập trình viên, nhà thiết kế và người yêu công nghệ.
        </p>
        <p style="color: var(--text-secondary); font-size: 0.98rem; line-height: 1.8; max-width: 75ch;">
            Mỗi thiết bị trong bộ sưu tập—từ bàn phím cơ custom vỏ nhôm nguyên khối, tai nghe màng từ
phẳng Planar đến laptop máy trạm hiệu năng cao—đều trải qua quy trình kiểm thử và đánh giá thông số độc
lập nghiêm ngặt.
        </p>
    </div>

    <!-- TIÊU CHÍ A2: BẢNG THÔNG SỐ STUDIO & HỒ SƠ SINH VIÊN -->
    <div class="spec-sheet-container">
        <div class="spec-sheet-header">
            <span>BẢNG THÔNG SỐ ĐỒ ÁN & THƯƠNG HIỆU (TIÊU CHÍ A2)</span>
            <span style="font-size: 0.75rem; color: var(--text-muted); font-weight: 500;">HỌC VIỆN CÔNG
NGHỆ BƯU CHÍNH VIỄN THÔNG</span>
        </div>
        <table class="spec-table">
            <tbody>
                <tr>
                    <th>Nhà sáng lập / Sinh viên thực hiện</th>
                    <td><strong><?= e(APP_FOUNDER) ?></strong></td>
                </tr>
                <tr>
                    <th>Mã số sinh viên (MSSV)</th>
                    <td><strong style="color: var(--text-primary); font-family: var(--font-mono);"><?=
e(APP_STUDENT_ID) ?></strong></td>
                </tr>
                <tr>
                    <th>Học viện đào tạo</th>
                    <td>Học viện Công nghệ Bưu chính Viễn thông (PTIT)</td>
                </tr>
                <tr>
                    <th>Môn học & Giảng viên phụ trách</th>
                    <td>Lập trình Web (HTML, CSS, JavaScript, PHP thuần, PDO, MySQL) – @Le Nhat Tung</td>
```

```
                </tr>
                <tr>
                    <th>Tiêu chuẩn kỹ thuật đồ án</th>
                    <td>Đáp ứng đầy đủ 38 tiêu chí A1–D11, bảo mật chống SQLi/XSS/CSRF, phân quyền
403</td>
                </tr>
                <tr>
                    <th>Chính sách bảo hành thiết bị</th>
                    <td>Bảo hành chính hãng 24 tháng theo số serial định danh</td>
                </tr>
                <tr>
                    <th>Địa chỉ trung tâm trải nghiệm</th>
                    <td><?= e(APP_ADDRESS) ?></td>
                </tr>
            </tbody>
        </table>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

contact.php

```
<?php
/**
 * TRANG LIÊN HỆ & TƯ VẤN (TIÊU CHÍ A2, A7, C8, D5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

$page_title = 'Liên Hệ & Hỗ Trợ Kỹ Thuật';

$errors = [];
$name = '';
$email = '';
$subject = '';
$message = '';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $name = trim($_POST['name'] ?? '');
    $email = trim($_POST['email'] ?? '');
    $subject = trim($_POST['subject'] ?? '');
    $message = trim($_POST['message'] ?? '');

    if (empty($name)) {
        $errors[] = 'Vui lòng nhập họ và tên của bạn.';
    }
    if (empty($email) || !filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $errors[] = 'Địa chỉ email không hợp lệ.';
    }
    if (empty($subject)) {
        $errors[] = 'Vui lòng nhập tiêu đề thư liên hệ.';
    }
    // Tiêu chí A7: Chặn nội dung dưới 10 ký tự
    if (mb_strlen($message, 'UTF-8') < 10) {
        $errors[] = 'Nội dung tin nhắn liên hệ phải có tối thiểu 10 ký tự.';
    }

    // Tiêu chí C8: Lưu vào bảng contacts
    if (empty($errors)) {
        $stmt = $pdo->prepare("
            INSERT INTO contacts (name, email, subject, message)
            VALUES (?, ?, ?, ?)
        ");
```

```
        $stmt->execute([$name, $email, $subject, $message]);

        set_flash('success', 'Tin nhắn của bạn đã được chuyển tới Lâm Nhựt Hải Đăng thành công!');
        header('Location: ' . BASE_URL . 'contact.php');
        exit;
    }
}

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 2rem; padding-bottom: 5rem;">
    <div style="display: grid; grid-template-columns: 1fr 1fr; gap: 3rem; margin-bottom: 3.5rem;">

        <!-- Cột trái: Form liên hệ (Tiêu chí A7 & C8) -->
        <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 2.5rem; box-shadow: var(--shadow-card);">
            <span class="hero-tag">GỬI YÊU CẦU TƯ VẤN</span>
            <h1 style="font-size: 1.6rem; font-weight: 800; margin-bottom: 1.5rem; color: var(--text-
primary);">
                Kết Nối Trực Tiếp Với Studio
            </h1>

            <?php if (!empty($errors)): ?>
                <div class="alert alert-danger">
                    <span><?= icon('alert-triangle', '', 16) ?></span>
                    <div>
                        <?php foreach ($errors as $err): ?>
                            <div><?= e($err) ?></div>
                        <?php endforeach; ?>
                    </div>
                </div>
            <?php endif; ?>

            <form action="<?= BASE_URL ?>contact.php" method="POST" id="contact-form">
                <?= csrf_field() ?>

                <div class="form-group">
                    <label class="form-label" for="contact-name">Họ và tên của bạn: *</label>
                    <input type="text" id="contact-name" name="name" class="form-control" value="<?=
e($name) ?>" required>
                </div>

                <div class="form-group">
                    <label class="form-label" for="contact-email">Địa chỉ Email liên hệ: *</label>
                    <input type="email" id="contact-email" name="email" class="form-control" value="<?=
e($email) ?>" required>
                </div>

                <div class="form-group">
                    <label class="form-label" for="contact-subject">Tiêu đề thông điệp: *</label>
                    <input type="text" id="contact-subject" name="subject" class="form-control" value="<?=
e($subject) ?>" required>
                </div>

                <div class="form-group">
                    <label class="form-label" for="contact-message">Nội dung tin nhắn (Tối thiểu 10 ký
tự): *</label>
                    <textarea id="contact-message" name="message" rows="5" class="form-control"
required><?= e($message) ?></textarea>
                </div>

                <button type="submit" class="btn-action-primary" style="width: 100%; justify-content:
center; padding: 0.85rem; font-size: 0.95rem;">
                    <?= icon('arrow-right', '', 15) ?> Gửi Tin Nhắn Đến Nhà Sáng Lập
                </button>
            </form>
        </div>
```

```
        <!-- Cột phải: Thông tin liên lạc -->
        <div style="display: flex; flex-direction: column; gap: 1.5rem;">
            <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-
radius: var(--radius-md); padding: 2.5rem; box-shadow: var(--shadow-card);">
                <h3 style="font-size: 1.15rem; font-weight: 700; margin-bottom: 1.25rem; color: var(--
text-primary);">
                    Thông Tin Trực Tuyến & Hotline
                </h3>
                <div style="font-size: 0.92rem; line-height: 2.2; color: var(--text-secondary);">
                    <div>Trụ sở: <?= e(APP_ADDRESS) ?></div>
                    <div>Hotline tư vấn: <strong style="color: var(--text-primary);"><?= e(APP_HOTLINE)
?></strong></div>
                    <div>Email chính thức: <strong style="color: var(--text-primary);"><?= e(APP_EMAIL)
?></strong></div>
                    <div>Thời gian hỗ trợ: 08:30 – 21:00 (Thứ 2 đến Thứ 7)</div>
                </div>
            </div>

            <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-
radius: var(--radius-md); padding: 2rem; box-shadow: var(--shadow-card);">
                <h4 style="font-size: 0.95rem; font-weight: 700; color: var(--accent-gold); margin-bottom:
0.5rem;">
                    TIÊU CHUẨN DỊCH VỤ KHÁCH HÀNG
                </h4>
                <p style="font-size: 0.88rem; color: var(--text-secondary); line-height: 1.7;">
                    Mọi ý kiến đóng góp hoặc yêu cầu tư vấn kỹ thuật đều được lưu trữ trực tiếp vào CSDL
bảng <code>contacts</code> và phản hồi trong vòng 24 giờ làm việc.
                </p>
            </div>
        </div>

    </div>

    <!-- TIÊU CHÍ A2: BẢNG THÔNG SỐ CÁC KÊNH LIÊN HỆ -->
    <div class="spec-sheet-container">
        <div class="spec-sheet-header">
            <span>BẢNG THÔNG SỐ CÁC KÊNH KẾT NỐI (TIÊU CHÍ A2)</span>
            <span style="font-size: 0.75rem; color: var(--text-muted); font-weight: 500;">TIẾP NHẬN
24/7</span>
        </div>
        <table class="spec-table">
            <tbody>
                <tr>
                    <th>Đường dây nóng hỗ trợ khách hàng</th>
                    <td>Hotline <?= e(APP_HOTLINE) ?> (Tiếp nhận tư vấn sản phẩm và tra cứu vận đơn)</td>
                </tr>
                <tr>
                    <th>Giao thức tiếp nhận dữ liệu</th>
                    <td>Lưu trực tiếp vào CSDL MySQL bảng <code>contacts</code> thông qua PDO Prepared
Statements</td>
                </tr>
                <tr>
                    <th>Bảo mật thông tin gửi</th>
                    <td>Bảo vệ 100% bằng CSRF Token và lọc mã độc phòng chống tấn công XSS</td>
                </tr>
                <tr>
                    <th>Trung tâm kiểm định sản phẩm</th>
                    <td>Học viện Công nghệ Bưu chính Viễn thông (PTIT)</td>
                </tr>
            </tbody>
        </table>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

404.php

```php
<?php
/**
 * TRANG BÁO LỖI 404 TÙY BIẾN (TIÊU CHÍ B5 & D5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

if (!headers_sent()) {
    http_response_code(404);
}

require_once __DIR__ . '/includes/init.php';

$page_title = '404 – Không Tìm Thấy Trang';

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding: 6rem 1rem; text-align: center;">
    <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 4rem 2rem; max-width: 580px; margin: 0 auto; box-shadow: var(--shadow-card);">
        <div style="font-size: 4.5rem; font-weight: 800; color: var(--text-primary); letter-spacing: -
0.05em; line-height: 1; margin-bottom: 0.5rem;">
            404
        </div>
        <div style="font-size: 0.95rem; font-weight: 600; color: var(--accent-gold); margin-bottom:
1.5rem; text-transform: uppercase; letter-spacing: 0.05em;">
            Trang Không Tồn Tại
        </div>
        <p style="color: var(--text-secondary); font-size: 0.95rem; margin-bottom: 2.25rem; line-height:
1.7;">
            Sản phẩm hoặc đường dẫn bạn đang tìm kiếm không tồn tại hoặc đã được chuyển sang vị trí mới.
        </p>
        <a href="<?= BASE_URL ?>" class="btn-action-primary" style="padding: 0.85rem 2rem; font-size:
0.92rem;">
            <?= icon('arrow-left', '', 15) ?> Quay Về Trang Chủ
        </a>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

8.4. Tài khoản

register.php

```php
<?php
/**
 * ĐĂNG KÝ TÀI KHOẢN (TIÊU CHÍ A3, A7, C1, D5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

// Nếu đã đăng nhập thì chuyển hướng về trang chủ
if (is_logged_in()) {
    header('Location: ' . BASE_URL);
    exit;
}

$page_title = 'Đăng Ký Tài Khoản Khách Hàng';
$errors = [];

$name = '';
$email = '';
$phone = '';
```

```
$address = '';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    // 1. Xác thực CSRF Token (Tiêu chí D5)
    verify_csrf();

    $name = trim($_POST['name'] ?? '');
    $email = trim($_POST['email'] ?? '');
    $phone = trim($_POST['phone'] ?? '');
    $address = trim($_POST['address'] ?? '');
    $password = $_POST['password'] ?? '';
    $confirm_password = $_POST['confirm_password'] ?? '';

    // 2. Tiêu chí C1: Kiểm tra dữ liệu phía máy chủ (Server-side Validation)
    if (empty($name)) {
        $errors[] = 'Họ và tên không được để trống.';
    }
    if (empty($email) || !filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $errors[] = 'Địa chỉ email không đúng định dạng.';
    }
    if (strlen($password) < 6) {
        $errors[] = 'Mật khẩu phải có độ dài tối thiểu 6 ký tự.';
    }
    if ($password !== $confirm_password) {
        $errors[] = 'Mật khẩu xác nhận không khớp.';
    }

    // Tiêu chí C1: Chặn email trùng lặp
    if (empty($errors)) {
        $check_stmt = $pdo->prepare("SELECT id FROM users WHERE email = ?");
        $check_stmt->execute([$email]);
        if ($check_stmt->fetch()) {
            $errors[] = 'Email này đã được đăng ký trong hệ thống. Vui lòng chọn email khác hoặc đăng
nhập.';
        }
    }

    // 3. Tiêu chí C1: Lưu mật khẩu bằng password_hash
    if (empty($errors)) {
        $hashed_password = password_hash($password, PASSWORD_DEFAULT);

        $stmt = $pdo->prepare("
            INSERT INTO users (name, email, password, phone, address, role)
            VALUES (?, ?, ?, ?, ?, 'customer')
        ");
        $stmt->execute([$name, $email, $hashed_password, $phone, $address]);
        $new_user_id = (int)$pdo->lastInsertId();

        // Tự động đăng nhập luôn (Auto-login)
        session_regenerate_id(true);
        $_SESSION['user'] = [
            'id'      => $new_user_id,
            'name'    => $name,
            'email'   => $email,
            'phone'   => $phone,
            'address' => $address,
            'role'    => 'customer'
        ];

        set_flash('success', "Chào mừng " . e($name) . "! Tài khoản của bạn đã được khởi tạo và tự động
đăng nhập.");
        header('Location: ' . BASE_URL);
        exit;
    }
    // Tiêu chí C1: Nếu có lỗi, dữ liệu đã nhập ($name, $email, $phone, $address) được giữ lại tự động
trong form
}

require_once __DIR__ . '/includes/header.php';
```

```
?>

<div class="container" style="padding-bottom: 5rem;">
    <div class="form-card">
        <span class="hero-tag">ĐĂNG KÝ MỚI</span>
        <h1 style="font-size: 1.6rem; font-weight: 800; margin-bottom: 1.5rem; color: var(--text-
primary);">
            Tạo Tài Khoản Thành Viên
        </h1>

        <?php if (!empty($errors)): ?>
            <div class="alert alert-danger">
                <span><?= icon('alert-triangle', '', 16) ?></span>
                <div>
                    <?php foreach ($errors as $err): ?>
                        <div><?= e($err) ?></div>
                    <?php endforeach; ?>
                </div>
            </div>
        <?php endif; ?>

        <!-- Form Đăng ký (Tiêu chí A3 & A7: có label, thuộc tính HTML, id register-form) -->
        <form action="<?= BASE_URL ?>register.php" method="POST" id="register-form">
            <?= csrf_field() ?>

            <div class="form-group">
                <label class="form-label" for="reg-name">Họ và tên của bạn: *</label>
                <input type="text" id="reg-name" name="name" class="form-control" value="<?= e($name) ?>"
placeholder="Nguyễn Văn A" required minlength="2">
            </div>

            <div class="form-group">
                <label class="form-label" for="reg-email">Địa chỉ Email: *</label>
                <input type="email" id="reg-email" name="email" class="form-control" value="<?= e($email)
?>" placeholder="ten@email.com" required>
            </div>

            <div class="form-group">
                <label class="form-label" for="reg-phone">Số điện thoại liên hệ:</label>
                <input type="tel" id="reg-phone" name="phone" class="form-control" value="<?= e($phone)
?>" pattern="[0-9]{10,11}" placeholder="09xxxxxxxx">
            </div>

            <div class="form-group">
                <label class="form-label" for="reg-address">Địa chỉ nhận hàng mặc định:</label>
                <input type="text" id="reg-address" name="address" class="form-control" value="<?=
e($address) ?>" placeholder="Số nhà, tên đường, phường/xã...">
            </div>

            <div class="form-group">
                <label class="form-label" for="reg-password">Mật khẩu bảo mật (Tối thiểu 6 ký tự):
*</label>
                <div class="password-wrapper">
                    <input type="password" id="reg-password" name="password" class="form-control"
placeholder="••••••••" required minlength="6">
                    <button type="button" class="password-toggle-btn" title="Hiện/Ẩn mật khẩu">
                        <svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>
                    </button>
                </div>
            </div>

            <div class="form-group">
                <label class="form-label" for="reg-confirm">Xác nhận lại mật khẩu: *</label>
                <div class="password-wrapper">
                    <input type="password" id="reg-confirm" name="confirm_password" class="form-control"
placeholder="••••••••" required minlength="6">
                    <button type="button" class="password-toggle-btn" title="Hiện/Ẩn mật khẩu">
```

```
                        <svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>
                    </button>
                </div>
            </div>

            <button type="submit" class="btn-action-primary" style="width: 100%; justify-content: center;
padding: 0.85rem; font-size: 0.95rem; margin-top: 0.5rem;">
                <?= icon('user', '', 16) ?> Tạo Tài Khoản
            </button>
        </form>

        <div style="text-align: center; margin-top: 1.5rem; font-size: 0.88rem; color: var(--text-
secondary);">
            Đã có tài khoản? <a href="<?= BASE_URL ?>login.php" style="color: var(--text-primary); font-
weight: 700; text-decoration: underline;">Đăng nhập ngay</a>
        </div>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

login.php

```
<?php
/**
 * ĐĂNG NHẬP HỆ THỐNG & RATE-LIMITING (TIÊU CHÍ A3, C2, C9, D10, D5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

// Nếu đã đăng nhập thì chuyển hướng
if (is_logged_in()) {
    header('Location: ' . BASE_URL);
    exit;
}

$page_title = 'Đăng Nhập Tài Khoản';
$error = '';
$email = '';
$is_locked = false;
$lock_remaining = 0;

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $email = trim($_POST['email'] ?? '');
    $password = $_POST['password'] ?? '';

    if (empty($email) || empty($password)) {
        $error = 'Vui lòng nhập đầy đủ Email và Mật khẩu.';
    } else {
        $stmt = $pdo->prepare("SELECT * FROM users WHERE email = ?");
        $stmt->execute([$email]);
        $user = $stmt->fetch();

        if ($user) {
            // TIÊU CHÍ D10: KIỂM TRA KHÓA FORM NẾU SAI MẬT KHẨU 5 LẦN
            if (!empty($user['locked_until'])) {
                $locked_time = strtotime($user['locked_until']);
                $now = time();

                if ($locked_time > $now) {
                    $is_locked = true;
                    $lock_remaining = ceil(($locked_time - $now) / 60);
```

```
                    $error = "Tài khoản tạm thời bị khóa do nhập sai mật khẩu 5 lần liên tiếp. Vui lòng
thử lại sau $lock_remaining phút.";
                } else {
                    $reset_stmt = $pdo->prepare("UPDATE users SET failed_attempts = 0, locked_until = NULL
WHERE id = ?");
                    $reset_stmt->execute([$user['id']]);
                    $user['failed_attempts'] = 0;
                    $user['locked_until'] = null;
                }
            }

            if (!$is_locked) {
                if (password_verify($password, $user['password'])) {
                    $reset_stmt = $pdo->prepare("UPDATE users SET failed_attempts = 0, locked_until = NULL
WHERE id = ?");
                    $reset_stmt->execute([$user['id']]);

                    session_regenerate_id(true);

                    $_SESSION['user'] = [
                        'id'      => $user['id'],
                        'name'    => $user['name'],
                        'email'   => $user['email'],
                        'phone'   => $user['phone'],
                        'address' => $user['address'],
                        'role'    => $user['role']
                    ];

                    set_flash('success', 'Chào mừng ' . $user['name'] . ' đã đăng nhập thành công!');

                    $redirect_to = BASE_URL;
                    if (!empty($_SESSION['return_to'])) {
                        $target = $_SESSION['return_to'];
                        unset($_SESSION['return_to']);
                        // Phòng chống tấn công Open Redirect
                        $target_host = parse_url($target, PHP_URL_HOST);
                        if (empty($target_host) || $target_host === ($_SERVER['HTTP_HOST'] ?? '')) {
                            if (strpos($target, '//') !== 0) {
                                $redirect_to = $target;
                            }
                        }
                    } elseif ($user['role'] === 'admin') {
                        $redirect_to = BASE_URL . 'admin/index.php';
                    }

                    header('Location: ' . $redirect_to);
                    exit;
                } else {
                    $attempts = (int)$user['failed_attempts'] + 1;
                    if ($attempts >= MAX_LOGIN_ATTEMPTS) {
                        $locked_until = date('Y-m-d H:i:s', time() + LOCKOUT_DURATION);
                        $lock_stmt = $pdo->prepare("UPDATE users SET failed_attempts = ?, locked_until = ?
WHERE id = ?");
                        $lock_stmt->execute([$attempts, $locked_until, $user['id']]);
                        $error = 'Bạn đã nhập sai mật khẩu 5 lần liên tiếp. Form đăng nhập bị khóa trong
vòng 5 phút!';
                        $is_locked = true;
                    } else {
                        $fail_stmt = $pdo->prepare("UPDATE users SET failed_attempts = ? WHERE id = ?");
                        $fail_stmt->execute([$attempts, $user['id']]);
                        $remaining = MAX_LOGIN_ATTEMPTS - $attempts;
                        $error = "Mật khẩu không chính xác. Bạn còn $remaining lần thử trước khi bị khóa 5
phút.";
                    }
                }
            }
        } else {
            $error = 'Địa chỉ email này chưa tồn tại trong hệ thống.';
        }
```

```
    }
}

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-bottom: 5rem;">
    <div class="form-card">
        <span class="hero-tag">ĐĂNG NHẬP</span>
        <h1 style="font-size: 1.6rem; font-weight: 800; margin-bottom: 1.5rem; color: var(--text-
primary);">
            Chào Mừng Trở Lại
        </h1>

        <?php if (!empty($error)): ?>
            <div class="alert alert-danger">
                <span><?= icon('alert-triangle', '', 16) ?></span>
                <span><?= e($error) ?></span>
            </div>
        <?php endif; ?>

        <!-- Form Đăng nhập (Tiêu chí A3: có label, required, minlength) -->
        <form action="<?= BASE_URL ?>login.php" method="POST" id="login-form">
            <?= csrf_field() ?>

            <div class="form-group">
                <label class="form-label" for="login-email">Địa chỉ Email: *</label>
                <input type="email" id="login-email" name="email" class="form-control" value="<?=
e($email) ?>" placeholder="ten@email.com" required <?= $is_locked ? 'disabled' : '' ?>>
            </div>

            <div class="form-group">
                <label class="form-label" for="login-password">Mật khẩu: *</label>
                <div class="password-wrapper">
                    <input type="password" id="login-password" name="password" class="form-control"
placeholder="••••••••" required minlength="6" <?= $is_locked ? 'disabled' : '' ?>>
                    <button type="button" class="password-toggle-btn" title="Hiện/Ẩn mật khẩu">
                        <svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>
                    </button>
                </div>
            </div>

            <button type="submit" class="btn-action-primary" style="width: 100%; justify-content: center;
padding: 0.85rem; font-size: 0.95rem;" <?= $is_locked ? 'disabled' : '' ?>>
                <?= $is_locked ? 'Tạm Khóa Form (5 phút)' : icon('lock', '', 16) . ' Đăng Nhập' ?>
            </button>
        </form>

        <!-- Tài khoản mẫu để chấm điểm -->
        <div style="background: var(--bg-elevated); border: 1px solid var(--border-subtle); border-radius:
var(--radius-sm); padding: 1rem; margin-top: 2rem; font-size: 0.8rem; color: var(--text-secondary); line-
height: 1.8;">
            <div style="color: var(--text-primary); font-weight: 700; margin-bottom: 0.2rem;">TÀI KHOẢN
CHẤM THỬ (MỤC 2 BÁO CÁO):</div>
            <div>• Quản trị viên: <code>admin@lab.ptit.edu.vn</code> / <code>admin123</code></div>
            <div>• Khách hàng: <code>khachhang1@gmail.com</code> / <code>customer123</code></div>
        </div>

        <div style="text-align: center; margin-top: 1.5rem; font-size: 0.88rem; color: var(--text-
muted);">
            Chưa có tài khoản? <a href="<?= BASE_URL ?>register.php" style="color: var(--text-primary);
font-weight: 600;">Đăng ký thành viên</a>
        </div>
    </div>
</div>
```

```php
<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

logout.php

```php
<?php
/**
 * ĐĂNG XUẤT AN TOÀN (TIÊU CHÍ C2)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

require_once __DIR__ . '/includes/init.php';

// Xóa toàn bộ thông tin đăng nhập trong phiên
unset($_SESSION['user']);

// Hủy hoàn toàn session nếu muốn
if (ini_get("session.use_cookies")) {
    $params = session_get_cookie_params();
    setcookie(session_name(), '', time() - 42000,
        $params["path"], $params["domain"],
        $params["secure"], $params["httponly"]
    );
}

session_destroy();

// Khởi động lại session mới để gửi Flash message
session_start();
require_once __DIR__ . '/includes/functions.php';

set_flash('info', 'Bạn đã đăng xuất khỏi hệ thống an toàn.');
header('Location: ' . BASE_URL);
exit;
```

profile.php

```php
<?php
/**
 * TRANG HỒ SƠ TÀI KHOẢN (TIÊU CHÍ C7 & D5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

// Bắt buộc đăng nhập
require_login();

$page_title = 'Hồ Sơ Tài Khoản Cá Nhân';
$user = current_user();
$errors = [];

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    // 1. Xác thực CSRF Token
    verify_csrf();

    $name = trim($_POST['name'] ?? '');
    $phone = trim($_POST['phone'] ?? '');
    $address = trim($_POST['address'] ?? '');

    if (empty($name)) {
        $errors[] = 'Họ và tên không được để trống.';
    }

    // Tiêu chí C7: Cập nhật thông tin vào CSDL
    if (empty($errors)) {
        $stmt = $pdo->prepare("
```

```
            UPDATE users
            SET name = ?, phone = ?, address = ?
            WHERE id = ?
        ");
        $stmt->execute([$name, $phone, $address, $user['id']]);

        // Cập nhật lại session
        $_SESSION['user']['name'] = $name;
        $_SESSION['user']['phone'] = $phone;
        $_SESSION['user']['address'] = $address;

        set_flash('success', 'Thông tin tài khoản của bạn đã được cập nhật thành công!');
        header('Location: ' . BASE_URL . 'profile.php');
        exit;
    }
}

// Lấy thông tin mới nhất từ CSDL
$stmt = $pdo->prepare("SELECT * FROM users WHERE id = ?");
$stmt->execute([$user['id']]);
$user_data = $stmt->fetch();

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 3rem; padding-bottom: 5rem;">
    <div style="max-width: 600px; margin: 0 auto; background: var(--bg-surface); border: 1px solid var(--
border-subtle); border-radius: var(--radius-md); padding: 2.5rem; box-shadow: var(--shadow-card);">
        <div style="display: flex; justify-content: space-between; align-items: center; margin-bottom:
1.5rem;">
            <div>
                <span class="hero-tag" style="margin-bottom: 0.4rem;">TÀI KHOẢN CỦA BẠN</span>
                <h1 style="font-size: 1.6rem; font-weight: 800; color: var(--text-primary); margin: 0;">
                    Thông Tin Cá Nhân
                </h1>
            </div>
            <span class="badge-status <?= $user_data['role'] === 'admin' ? 'badge-completed' : 'badge-
shipping' ?>">
                <?= $user_data['role'] === 'admin' ? icon('shield-check', '', 14) . ' Quản Trị Viên' :
icon('user', '', 14) . ' Khách Hàng' ?>
            </span>
        </div>

        <?php if (!empty($errors)): ?>
            <div class="alert alert-danger">
                <span><?= icon('alert-triangle', '', 16) ?></span>
                <div>
                    <?php foreach ($errors as $err): ?>
                        <div><?= e($err) ?></div>
                    <?php endforeach; ?>
                </div>
            </div>
        <?php endif; ?>

        <!-- TIÊU CHÍ C7: SỬA HỌ TÊN, SỐ ĐIỆN THOẠI, ĐỊA CHỈ -->
        <form action="<?= BASE_URL ?>profile.php" method="POST">
            <?= csrf_field() ?>

            <div class="form-group">
                <label class="form-label">Địa chỉ Email (Định danh không đổi):</label>
                <input type="text" class="form-control" value="<?= e($user_data['email']) ?>" disabled
style="opacity: 0.7; cursor: not-allowed; background: var(--bg-elevated);">
            </div>

            <div class="form-group">
                <label class="form-label" for="prof-name">Họ và tên của bạn: *</label>
                <input type="text" id="prof-name" name="name" class="form-control" value="<?=
e($user_data['name']) ?>" required>
            </div>
```

```
            <div class="form-group">
                <label class="form-label" for="prof-phone">Số điện thoại liên lạc:</label>
                <input type="tel" id="prof-phone" name="phone" class="form-control" value="<?=
e($user_data['phone']) ?>" pattern="[0-9]{10,11}">
            </div>

            <div class="form-group">
                <label class="form-label" for="prof-address">Địa chỉ giao nhận hàng mặc định:</label>
                <input type="text" id="prof-address" name="address" class="form-control" value="<?=
e($user_data['address']) ?>">
            </div>

            <div style="display: flex; gap: 1rem; margin-top: 2rem; flex-wrap: wrap;">
                <button type="submit" class="btn-action-primary" style="flex: 1; justify-content: center;
padding: 0.85rem; font-size: 0.92rem;">
                    <?= icon('save', '', 16) ?> Lưu Thay Đổi
                </button>
                <a href="<?= BASE_URL ?>change-password.php" class="btn-icon" style="padding: 0.85rem
1.25rem; display: inline-flex; align-items: center; gap: 0.4rem; font-weight: 600;">
                    <?= icon('lock', '', 15) ?> Đổi Mật Khẩu
                </a>
            </div>
        </form>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

change-password.php

```
<?php
/**
 * ĐỔI MẬT KHẨU TÀI KHOẢN (TIÊU CHÍ D11 & D5)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

require_login();

$page_title = 'Đổi Mật Khẩu Bảo Mật';
$user = current_user();
$errors = [];

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    // 1. Xác thực CSRF Token
    verify_csrf();

    $current_password = $_POST['current_password'] ?? '';
    $new_password = $_POST['new_password'] ?? '';
    $confirm_password = $_POST['confirm_password'] ?? '';

    // 2. Lấy hash mật khẩu hiện tại trong CSDL
    $stmt = $pdo->prepare("SELECT password FROM users WHERE id = ?");
    $stmt->execute([$user['id']]);
    $db_user = $stmt->fetch();

    // TIÊU CHÍ D11: BẮT BUỘC NHẬP ĐÚNG MẬT KHẨU HIỆN TẠI
    if (!password_verify($current_password, $db_user['password'])) {
        $errors[] = 'Mật khẩu hiện tại không chính xác.';
    }

    if (strlen($new_password) < 6) {
        $errors[] = 'Mật khẩu mới phải có độ dài tối thiểu 6 ký tự.';
    }
```

```
    if ($new_password !== $confirm_password) {
        $errors[] = 'Xác nhận mật khẩu mới không khớp.';
    }

    // 3. Cập nhật mật khẩu mới
    if (empty($errors)) {
        $new_hash = password_hash($new_password, PASSWORD_DEFAULT);
        $update_stmt = $pdo->prepare("UPDATE users SET password = ? WHERE id = ?");
        $update_stmt->execute([$new_hash, $user['id']]);

        set_flash('success', 'Đổi mật khẩu thành công! Mật khẩu mới đã có hiệu lực.');
        header('Location: ' . BASE_URL . 'profile.php');
        exit;
    }
}

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 3rem; padding-bottom: 5rem;">
    <div class="form-card">
        <span class="hero-tag">BẢO MẬT TÀI KHOẢN</span>
        <h1 style="font-size: 1.6rem; font-weight: 800; margin-bottom: 1.5rem; color: var(--text-
primary);">
            Thiết Lập Mật Khẩu Mới
        </h1>

        <?php if (!empty($errors)): ?>
            <div class="alert alert-danger">
                <span><?= icon('alert-triangle', '', 16) ?></span>
                <div>
                    <?php foreach ($errors as $err): ?>
                        <div><?= e($err) ?></div>
                    <?php endforeach; ?>
                </div>
            </div>
        <?php endif; ?>

        <!-- Form Đổi Mật Khẩu (Tiêu chí D11) -->
        <form action="<?= BASE_URL ?>change-password.php" method="POST">
            <?= csrf_field() ?>

            <div class="form-group">
                <label class="form-label" for="cur-pass">Mật khẩu hiện tại của bạn: *</label>
                <div class="password-wrapper">
                    <input type="password" id="cur-pass" name="current_password" class="form-control"
placeholder="••••••••" required>
                    <button type="button" class="password-toggle-btn" title="Hiện/Ẩn mật khẩu">
                        <svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>
                    </button>
                </div>
            </div>

            <div class="form-group">
                <label class="form-label" for="new-pass">Mật khẩu mới (Tối thiểu 6 ký tự): *</label>
                <div class="password-wrapper">
                    <input type="password" id="new-pass" name="new_password" class="form-control"
placeholder="••••••••" required minlength="6">
                    <button type="button" class="password-toggle-btn" title="Hiện/Ẩn mật khẩu">
                        <svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>
                    </button>
                </div>
            </div>

            <div class="form-group">
```

```
                <label class="form-label" for="conf-pass">Xác nhận mật khẩu mới: *</label>
                <div class="password-wrapper">
                    <input type="password" id="conf-pass" name="confirm_password" class="form-control"
placeholder="••••••••" required minlength="6">
                    <button type="button" class="password-toggle-btn" title="Hiện/Ẩn mật khẩu">
                        <svg class="svg-icon no-margin" width="16" height="16" viewBox="0 0 24 24"
fill="none" stroke="currentColor" stroke-width="2"><path d="M1 12s4-8 11-8 11 8 11 8-4 8-11 8-11-8-11-
8z"></path><circle cx="12" cy="12" r="3"></circle></svg>
                    </button>
                </div>
            </div>

            <button type="submit" class="btn-action-primary" style="width: 100%; justify-content: center;
padding: 0.85rem; font-size: 0.95rem; margin-top: 0.5rem;">
                <?= icon('lock', '', 16) ?> Cập Nhật Mật Khẩu
            </button>
        </form>

        <div style="text-align: center; margin-top: 1.5rem;">
            <a href="<?= BASE_URL ?>profile.php" style="color: var(--text-secondary); font-size: 0.88rem;
text-decoration: underline; display: inline-flex; align-items: center; gap: 0.3rem;">
                <?= icon('arrow-left', '', 14) ?> Quay lại trang Hồ sơ
            </a>
        </div>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

8.5. Giỏ hàng và đơn hàng

cart.php

```
<?php
/**
 * TRANG GIỎ HÀNG (TIÊU CHÍ C3 & A8)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

$page_title = 'Giỏ Hàng Tuyển Chọn';

// Tiêu chí C3: Giá sản phẩm luôn được lấy trực tiếp từ CSDL
$cart_items = get_cart_items_with_db_prices($pdo);
$grand_total = 0;
foreach ($cart_items as $item) {
    $grand_total += $item['subtotal'];
}

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 2rem; padding-bottom: 5rem;">
    <div style="display: flex; justify-content: space-between; align-items: flex-end; margin-bottom: 2rem;
flex-wrap: wrap; gap: 1rem;">
        <div>
            <span class="hero-tag">GIỎ HÀNG TRỰC TUYẾN</span>
            <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary);">
                Sản Phẩm Bạn Đã Chọn
            </h1>
        </div>

        <?php if (!empty($cart_items)): ?>
            <!-- Tiêu chí A8: Nút xóa giỏ hàng có hộp xác nhận (Hỗ trợ Ajax) -->
            <form action="<?= BASE_URL ?>cart-update.php" method="POST" style="margin: 0;" class="cart-
```

```
clear-form">
                <?= csrf_field() ?>
                <input type="hidden" name="action" value="clear">
                <button type="submit" class="btn-icon btn-cart-clear-ajax" data-confirm="Bạn có chắc chắn
muốn xóa tất cả sản phẩm khỏi giỏ hàng?" style="color: var(--status-alert);">
                    <?= icon('trash', '', 15) ?> Xóa sạch giỏ hàng
                </button>
            </form>
        <?php endif; ?>
    </div>

    <?php if (empty($cart_items)): ?>
        <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 5rem 2rem; text-align: center; box-shadow: var(--shadow-card);">
            <div style="margin-bottom: 1rem; color: var(--text-muted);"><?= icon('bag', '', 48) ?></div>
            <h2 style="font-size: 1.35rem; font-weight: 700; margin-bottom: 0.5rem; color: var(--text-
primary);">Giỏ hàng của bạn đang trống</h2>
            <p style="color: var(--text-muted); font-size: 0.95rem; margin-bottom: 2rem;">Hãy khám phá các
thiết bị công nghệ cao cấp trong bộ sưu tập của chúng tôi.</p>
            <a href="<?= BASE_URL ?>" class="btn-action-primary" style="padding: 0.85rem 2rem; font-size:
0.92rem;">
                Khám Phá Sản Phẩm
            </a>
        </div>
    <?php else: ?>
        <div class="manifest-card">
            <!-- Bảng danh sách thiết bị giỏ hàng (Tiêu chí A8: Tự tính lại thành tiền bằng JS) -->
            <div class="table-responsive">
                <table class="cart-table">
                    <thead>
                        <tr>
                            <th style="width: 45%;">SẢN PHẨM</th>
                            <th style="width: 18%;">ĐƠN GIÁ</th>
                            <th style="width: 15%; text-align: center;">SỐ LƯỢNG</th>
                            <th style="width: 17%; text-align: right;">THÀNH TIỀN</th>
                            <th style="width: 5%; text-align: center;">XÓA</th>
                        </tr>
                    </thead>
                    <tbody>
                        <?php foreach ($cart_items as $item): ?>
                            <tr id="cart-row-<?= $item['id'] ?>" style="transition: all 250ms ease;">
                                <td>
                                    <div style="display: flex; align-items: center; gap: 1.25rem;">
                                        <img src="<?= BASE_URL ?>uploads/<?= e($item['image']) ?>"
alt="<?= e($item['name']) ?>" style="width: 55px; height: 55px; object-fit: contain; background: #f8f9fa;
border-radius: var(--radius-sm); padding: 6px; border: 1px solid var(--border-subtle);">
                                        <div>
                                            <div style="font-weight: 600; font-size: 0.95rem;">
                                                <a href="<?= BASE_URL ?>product.php?id=<?= $item['id']
?>"><?= e($item['name']) ?></a>
                                            </div>
                                            <div style="font-size: 0.75rem; color: var(--text-muted);
margin-top: 0.2rem;">
                                                Mã: <?= e($item['sku']) ?> · Tồn kho: <?= $item['stock']
?> chiếc
                                            </div>
                                        </div>
                                    </div>
                                </td>
                                <td style="font-size: 0.95rem; color: var(--text-secondary); font-weight:
500;">
                                    <?= format_currency($item['price']) ?>
                                </td>
                                <td style="text-align: center;">
                                    <!-- Cụm Stepper tăng giảm tiện lợi kèm thuộc tính data-price, data-
stock -->
                                    <div class="qty-stepper">
                                        <button type="button" class="qty-btn qty-btn-minus" title="Giảm">-
</button>
```

```
                                        <input type="number"
                                               class="cart-qty-input"
                                               value="<?= $item['quantity'] ?>"
                                               min="1"
                                               max="<?= $item['stock'] ?>"
                                               data-id="<?= $item['id'] ?>"
                                               data-price="<?= $item['price'] ?>"
                                               data-stock="<?= $item['stock'] ?>">
                                        <button type="button" class="qty-btn qty-btn-plus"
title="Tăng">+</button>
                                    </div>
                                </td>
                                <td style="text-align: right;">
                                    <span class="cart-subtotal subtotal-<?= $item['id'] ?>" style="font-
size: 1rem;">
                                        <?= format_currency($item['subtotal']) ?>
                                    </span>
                                </td>
                                <td style="text-align: center;">
                                    <form action="<?= BASE_URL ?>cart-update.php" method="POST"
style="margin: 0;" class="cart-remove-form">
                                        <?= csrf_field() ?>
                                        <input type="hidden" name="action" value="remove">
                                        <input type="hidden" name="product_id" value="<?= $item['id'] ?>">
                                        <button type="submit" class="btn-icon btn-cart-remove-ajax" data-
id="<?= $item['id'] ?>" data-confirm="Xóa sản phẩm này khỏi giỏ?" style="color: var(--status-alert);
padding: 0.35rem 0.55rem;" title="Xóa">
                                            <?= icon('trash', 'no-margin', 15) ?>
                                        </button>
                                    </form>
                                </td>
                            </tr>
                        <?php endforeach; ?>
                    </tbody>
                </table>
            </div>

            <!-- Tổng tiền & Nút thanh toán -->
            <div style="display: flex; justify-content: space-between; align-items: center; border-top:
1px solid var(--border-subtle); padding-top: 2rem; flex-wrap: wrap; gap: 1.5rem;">
                <a href="<?= BASE_URL ?>" class="nav-link" style="border: 1px solid var(--border-subtle);
font-weight: 500; display: inline-flex; align-items: center;">
                    <?= icon('arrow-left', '', 15) ?> Tiếp tục mua sắm
                </a>

                <div style="display: flex; align-items: center; gap: 2.5rem;">
                    <div style="text-align: right;">
                        <span style="color: var(--text-muted); font-size: 0.85rem; font-weight: 500;">TỔNG
TIỀN THANH TOÁN:</span>
                        <div id="cart-grand-total" style="font-size: 1.85rem; font-weight: 800; color:
var(--text-primary); letter-spacing: -0.02em;">
                            <?= format_currency($grand_total) ?>
                        </div>
                    </div>

                    <a href="<?= BASE_URL ?>checkout.php" class="btn-action-primary" style="padding:
0.95rem 2.25rem; font-size: 0.95rem;">
                        Tiến Hành Đặt Hàng <?= icon('arrow-right', '', 16) ?>
                    </a>
                </div>
            </div>
        </div>
    <?php endif; ?>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

cart-add.php

```php
<?php
/**
 * THÊM SẢN PHẨM VÀO GIỎ HÀNG (TIÊU CHÍ C3 & EXPRESS CHECKOUT)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

require_once __DIR__ . '/includes/init.php';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $product_id = isset($_POST['product_id']) ? (int)$_POST['product_id'] : 0;
    $quantity = isset($_POST['quantity']) ? max(1, (int)$_POST['quantity']) : 1;
    $is_ajax = !empty($_POST['ajax']);
    $is_express = !empty($_POST['express']);

    // Kiểm tra sản phẩm có tồn tại và còn hàng không
    $stmt = $pdo->prepare("SELECT id, name, price, stock FROM products WHERE id = ?");
    $stmt->execute([$product_id]);
    $product = $stmt->fetch();

    $success = false;
    $message = '';
    $msg_type = 'danger';

    if ($product) {
        if ($product['stock'] <= 0) {
            $message = 'Thiết bị này hiện đã tạm thời hết hàng trong kho!';
            set_flash('danger', $message);
        } else {
            if (!isset($_SESSION['cart']) || !is_array($_SESSION['cart'])) {
                $_SESSION['cart'] = [];
            }

            $current_qty = (int)($_SESSION['cart'][$product_id]['quantity'] ?? 0);
            $new_qty = $current_qty + $quantity;

            if ($new_qty > $product['stock']) {
                $new_qty = $product['stock'];
                $message = "Kho chỉ còn {$product['stock']} thiết bị. Đã tự động điều chỉnh số lượng tối
đa.";
                $msg_type = 'warning';
                set_flash('warning', $message);
            } else {
                $message = "Đã thêm '{$product['name']}' vào giỏ hàng!";
                $msg_type = 'success';
                set_flash('success', $message);
            }

            // Tiêu chí C3: Lưu số lượng vào session (Giá luôn lấy từ CSDL khi hiển thị)
            $_SESSION['cart'][$product_id] = [
                'quantity' => $new_qty
            ];
            $success = true;
        }
    } else {
        $message = 'Không tìm thấy thiết bị cần thêm vào giỏ hàng.';
        set_flash('danger', $message);
    }

    if ($is_ajax) {
        header('Content-Type: application/json');
        echo json_encode([
            'success' => $success,
            'message' => $message,
            'type'    => $msg_type,
            'cart_count' => cart_count()
        ]);
        exit;
```

```
    }

    if ($is_express && $success) {
        header('Location: ' . BASE_URL . 'checkout.php');
        exit;
    }
}

header('Location: ' . BASE_URL . 'cart.php');
exit;
```

cart-update.php

```
<?php
/**
 * CẬP NHẬT & XÓA GIỎ HÀNG (TIÊU CHÍ C3 & A8)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

require_once __DIR__ . '/includes/init.php';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $action = $_POST['action'] ?? 'update';
    $is_ajax = !empty($_POST['ajax']);

    // 1. Xóa toàn bộ giỏ hàng
    if ($action === 'clear') {
        $_SESSION['cart'] = [];
        set_flash('info', 'Đã xóa toàn bộ thiết bị trong giỏ hàng.');

        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode([
                'success' => true,
                'cart_count' => 0,
                'grand_total' => 0,
                'formatted_grand_total' => format_currency(0),
                'is_empty' => true,
                'message' => 'Đã xóa toàn bộ giỏ hàng thành công.'
            ]);
            exit;
        }

        header('Location: ' . BASE_URL . 'cart.php');
        exit;
    }

    // 2. Xóa 1 dòng sản phẩm cụ thể
    if ($action === 'remove') {
        $product_id = (int)($_POST['product_id'] ?? 0);
        if (isset($_SESSION['cart'][$product_id])) {
            unset($_SESSION['cart'][$product_id]);
            set_flash('info', 'Đã loại bỏ thiết bị khỏi giỏ hàng.');
        }

        if ($is_ajax) {
            $cart_items = get_cart_items_with_db_prices($pdo);
            $grand_total = 0;
            foreach ($cart_items as $item) {
                $grand_total += $item['subtotal'];
            }

            header('Content-Type: application/json');
            echo json_encode([
                'success' => true,
                'product_id' => $product_id,
```

```
                'cart_count' => cart_count(),
                'grand_total' => $grand_total,
                'formatted_grand_total' => format_currency($grand_total),
                'is_empty' => empty($cart_items),
                'message' => 'Đã xóa sản phẩm khỏi giỏ hàng.'
            ]);
            exit;
        }

        header('Location: ' . BASE_URL . 'cart.php');
        exit;
    }

    // 3. Cập nhật số lượng (hỗ trợ cả Ajax real-time)
    $product_id = (int)($_POST['product_id'] ?? 0);
    $quantity = (int)($_POST['quantity'] ?? 1);

    if ($product_id > 0 && isset($_SESSION['cart'][$product_id])) {
        // Kiểm tra tồn kho từ CSDL
        $stmt = $pdo->prepare("SELECT stock FROM products WHERE id = ?");
        $stmt->execute([$product_id]);
        $stock = (int)$stmt->fetchColumn();

        if ($quantity <= 0) {
            unset($_SESSION['cart'][$product_id]);
        } else {
            if ($quantity > $stock) {
                $quantity = $stock;
            }
            $_SESSION['cart'][$product_id]['quantity'] = $quantity;
        }

        if ($is_ajax) {
            $cart_items = get_cart_items_with_db_prices($pdo);
            $grand_total = 0;
            foreach ($cart_items as $item) {
                $grand_total += $item['subtotal'];
            }

            header('Content-Type: application/json');
            echo json_encode([
                'success' => true,
                'product_id' => $product_id,
                'cart_count' => cart_count(),
                'grand_total' => $grand_total,
                'formatted_grand_total' => format_currency($grand_total)
            ]);
            exit;
        }
    }
}

header('Location: ' . BASE_URL . 'cart.php');
exit;
```

checkout.php

```
<?php
/**
 * THANH TOÁN & ĐẶT HÀNG (TIÊU CHÍ C4, C9 & VIETQR / VOUCHER)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

// Bắt buộc đăng nhập để đặt hàng (Tiêu chí C9)
require_login();
```

```php
$user = current_user();
$cart_items = get_cart_items_with_db_prices($pdo);

if (empty($cart_items)) {
    set_flash('warning', 'Giỏ hàng của bạn đang trống. Vui lòng chọn sản phẩm trước khi thanh toán.');
    header('Location: ' . BASE_URL);
    exit;
}

$page_title = 'Xác Nhận Đơn Hàng & Thanh Toán';
$errors = [];

$recipient_name = $user['name'] ?? '';
$recipient_phone = $user['phone'] ?? '';
$shipping_address = $user['address'] ?? '';
$note = '';
$payment_method = 'cod';

$grand_total = 0;
foreach ($cart_items as $item) {
    $grand_total += $item['subtotal'];
}

// Xử lý mã voucher giảm giá (PTIT2026: -10%, HAIDANG: -15%)
$voucher_code = trim($_POST['voucher_code'] ?? ($_SESSION['voucher_code'] ?? ''));
$discount_percent = 0;
$discount_amount = 0;
$voucher_error = null;

if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_POST['action_voucher'])) {
    verify_csrf();
    $raw_code = trim($_POST['voucher_code'] ?? '');
    $is_ajax = !empty($_POST['ajax']);
    $upper_code = strtoupper($raw_code);
    $is_valid = false;
    $msg = 'Mã ưu đãi không hợp lệ hoặc đã hết hạn.';

    if ($upper_code === 'PTIT2026') {
        $discount_percent = 10;
        $is_valid = true;
        $_SESSION['voucher_code'] = 'PTIT2026';
        $voucher_code = 'PTIT2026';
        $msg = 'Áp dụng mã PTIT2026 thành công! Giảm 10% tổng đơn hàng.';
    } elseif ($upper_code === 'HAIDANG') {
        $discount_percent = 15;
        $is_valid = true;
        $_SESSION['voucher_code'] = 'HAIDANG';
        $voucher_code = 'HAIDANG';
        $msg = 'Áp dụng mã HAIDANG thành công! Giảm 15% độc quyền Studio.';
    } else {
        unset($_SESSION['voucher_code']);
        $voucher_code = '';
        $voucher_error = $msg;
    }

    $discount_amount = (int)round($grand_total * ($discount_percent / 100));
    $final_total = max(0, $grand_total - $discount_amount);

    if ($is_ajax) {
        header('Content-Type: application/json');
        echo json_encode([
            'success' => $is_valid,
            'voucher_code' => $is_valid ? $upper_code : '',
            'discount_percent' => $discount_percent,
            'discount_amount' => $discount_amount,
            'formatted_discount' => format_currency($discount_amount),
            'grand_total' => $grand_total,
            'formatted_grand_total' => format_currency($grand_total),
```

```
            'final_total' => $final_total,
            'formatted_final_total' => format_currency($final_total),
            'message' => $msg
        ]);
        exit;
    }
}

if (!empty($voucher_code)) {
    $upper_code = strtoupper($voucher_code);
    if ($upper_code === 'PTIT2026') {
        $discount_percent = 10;
    } elseif ($upper_code === 'HAIDANG') {
        $discount_percent = 15;
    }
}

if ($discount_percent > 0) {
    $discount_amount = (int)round($grand_total * ($discount_percent / 100));
}
$final_total = max(0, $grand_total - $discount_amount);

if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_POST['action_order'])) {
    verify_csrf();

    $recipient_name = trim($_POST['recipient_name'] ?? '');
    $recipient_phone = trim($_POST['recipient_phone'] ?? '');
    $shipping_address = trim($_POST['shipping_address'] ?? '');
    $note = trim($_POST['note'] ?? '');
    $payment_method = $_POST['payment_method'] ?? 'cod';
    if (!in_array($payment_method, ['cod', 'vietqr'])) {
        $payment_method = 'cod';
    }

    if (empty($recipient_name)) {
        $errors[] = 'Vui lòng nhập tên người nhận hàng.';
    }
    if (empty($recipient_phone)) {
        $errors[] = 'Vui lòng nhập số điện thoại người nhận.';
    }
    if (empty($shipping_address)) {
        $errors[] = 'Vui lòng nhập địa chỉ giao hàng.';
    }

    if (empty($errors)) {
        // TIÊU CHÍ C4: BẮT ĐẦU GIAO DỊCH DATABASE TRANSACTION
        try {
            $pdo->beginTransaction();

            // 1. Kiểm tra tồn kho của từng sản phẩm trong giỏ
            foreach ($cart_items as $item) {
                $check_stmt = $pdo->prepare("SELECT stock, price, name FROM products WHERE id = ?");
                $check_stmt->execute([$item['id']]);
                $db_prod = $check_stmt->fetch();

                if (!$db_prod || $db_prod['stock'] < $item['quantity']) {
                    throw new Exception("Sản phẩm '{$item['name']}' không đủ tồn kho (Chỉ còn " .
($db_prod['stock'] ?? 0) . " chiếc). Giao dịch bị hủy!");
                }
            }

            // 2. Tạo bản ghi đơn hàng mới trong bảng orders
            $order_code = 'ORD-' . date('Ymd') . '-' . strtoupper(substr(bin2hex(random_bytes(3)), 0, 5));
            $method_label = $payment_method === 'vietqr' ? 'Chuyển khoản VietQR' : 'Thanh toán khi nhận
hàng (COD)';
            $order_note = "[Hình thức: $method_label";
            if ($discount_amount > 0) {
                $order_note .= " | Voucher: $voucher_code (-" . format_currency($discount_amount) . ")";
            }
```

```
            $order_note .= "] " . $note;

            $order_stmt = $pdo->prepare("
                INSERT INTO orders (user_id, order_code, recipient_name, recipient_phone,
shipping_address, total_amount, status, note)
                VALUES (?, ?, ?, ?, ?, ?, 'pending', ?)
            ");
            $order_stmt->execute([
                $user['id'],
                $order_code,
                $recipient_name,
                $recipient_phone,
                $shipping_address,
                $final_total,
                $order_note
            ]);
            $order_id = $pdo->lastInsertId();

            // 3. Trừ tồn kho và Lưu chi tiết đơn hàng (order_items) kèm đơn giá gốc tại thời điểm mua
            $item_stmt = $pdo->prepare("
                INSERT INTO order_items (order_id, product_id, price, quantity)
                VALUES (?, ?, ?, ?)
            ");
            $update_stock_stmt = $pdo->prepare("
                UPDATE products SET stock = stock - ? WHERE id = ?
            ");

            foreach ($cart_items as $item) {
                // Lưu snapshot đơn giá lúc mua (Tiêu chí C4)
                $item_stmt->execute([
                    $order_id,
                    $item['id'],
                    $item['price'],
                    $item['quantity']
                ]);

                // Trừ tồn kho trong cùng transaction
                $update_stock_stmt->execute([
                    $item['quantity'],
                    $item['id']
                ]);
            }

            // 4. Xác nhận giao dịch thành công (COMMIT)
            $pdo->commit();

            // Xóa sạch giỏ hàng và voucher trong session
            $_SESSION['cart'] = [];
            unset($_SESSION['voucher_code']);

            set_flash('success', "Đặt hàng thành công! Mã đơn hàng của bạn là: $order_code");
            header('Location: ' . BASE_URL . 'order-detail.php?id=' . $order_id);
            exit;

        } catch (Exception $e) {
            $pdo->rollBack();
            $errors[] = $e->getMessage();
        }
    }
}

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 1.5rem; padding-bottom: 5rem;">
    <!-- Nút quay lại giỏ hàng mượt mà -->
    <a href="<?= BASE_URL ?>cart.php" class="nav-link" style="border: 1px solid var(--border-subtle);
display: inline-flex; align-items: center; margin-bottom: 1.5rem; font-weight: 500;">
        <?= icon('arrow-left', '', 14) ?> Quay lại giỏ hàng
```

```
    </a>

    <div style="margin-bottom: 2rem;">
        <span class="hero-tag">ĐẶT HÀNG TRỰC TUYẾN</span>
        <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary); margin: 0.25rem 0 0
0;">
            Xác Nhận Đơn Hàng & Phương Thức Thanh Toán
        </h1>
    </div>

    <?php if (!empty($errors)): ?>
        <div class="alert alert-danger">
            <span><?= icon('alert-triangle', '', 16) ?></span>
            <div>
                <?php foreach ($errors as $err): ?>
                    <div><?= e($err) ?></div>
                <?php endforeach; ?>
            </div>
        </div>
    <?php endif; ?>

    <div style="display: grid; grid-template-columns: 1.15fr 0.85fr; gap: 2.5rem; align-items: flex-
start;">

        <!-- Cột trái: Form thông tin người nhận & Chọn phương thức thanh toán -->
        <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 2.25rem; box-shadow: var(--shadow-card);">
            <h2 style="font-size: 1.2rem; font-weight: 700; margin-bottom: 1.5rem; color: var(--text-
primary);">
                1. Thông Tin Nhận Hàng
            </h2>

            <form action="<?= BASE_URL ?>checkout.php" method="POST" id="checkout-form">
                <?= csrf_field() ?>
                <input type="hidden" name="action_order" value="1">
                <input type="hidden" name="voucher_code" value="<?= e($voucher_code) ?>">

                <div class="form-group">
                    <label class="form-label" for="rec-name">Họ và tên người nhận: *</label>
                    <input type="text" id="rec-name" name="recipient_name" class="form-control" value="<?=
e($recipient_name) ?>" required>
                </div>

                <div style="display: grid; grid-template-columns: 1fr 1fr; gap: 1rem;">
                    <div class="form-group">
                        <label class="form-label" for="rec-phone">Số điện thoại: *</label>
                        <input type="tel" id="rec-phone" name="recipient_phone" class="form-control"
value="<?= e($recipient_phone) ?>" required pattern="[0-9]{10,11}">
                    </div>

                    <div class="form-group">
                        <label class="form-label" for="rec-addr">Địa chỉ nhận hàng: *</label>
                        <input type="text" id="rec-addr" name="shipping_address" class="form-control"
value="<?= e($shipping_address) ?>" required>
                    </div>
                </div>

                <div class="form-group">
                    <label class="form-label" for="rec-note">Ghi chú giao hàng:</label>
                    <textarea id="rec-note" name="note" rows="2" class="form-control" placeholder="Ví dụ:
Gọi trước khi giao, gửi bảo vệ..."><?= e($note) ?></textarea>
                </div>

                <!-- 2. PHƯƠNG THỨC THANH TOÁN (COD vs VIETQR) -->
                <h2 style="font-size: 1.2rem; font-weight: 700; margin: 2rem 0 1rem 0; color: var(--text-
primary);">
                    2. Phương Thức Thanh Toán
                </h2>
```

```
                <div class="payment-tabs">
                    <label class="payment-tab-option <?= $payment_method === 'cod' ? 'active' : '' ?>">
                        <input type="radio" name="payment_method" value="cod" <?= $payment_method ===
'cod' ? 'checked' : '' ?> onchange="document.querySelectorAll('.payment-tab-
option').forEach(el=>el.classList.remove('active')); this.closest('label').classList.add('active');
document.getElementById('vietqr-details').style.display='none';">
                        <div>
                            <div style="font-weight: 700; font-size: 0.95rem; color: var(--text-
primary);">Thanh Toán Khi Nhận (COD)</div>
                            <div style="font-size: 0.78rem; color: var(--text-muted); margin-top:
0.2rem;">Thanh toán tiền mặt trực tiếp cho shipper khi nhận hàng.</div>
                        </div>
                    </label>

                    <label class="payment-tab-option <?= $payment_method === 'vietqr' ? 'active' : '' ?>">
                        <input type="radio" name="payment_method" value="vietqr" <?= $payment_method ===
'vietqr' ? 'checked' : '' ?> onchange="document.querySelectorAll('.payment-tab-
option').forEach(el=>el.classList.remove('active')); this.closest('label').classList.add('active');
document.getElementById('vietqr-details').style.display='grid';">
                        <div>
                            <div style="font-weight: 700; font-size: 0.95rem; color: var(--text-primary);
display: flex; align-items: center; gap: 0.35rem;">
                                Chuyển Khoản VietQR <?= icon('shield-check', '', 14) ?>
                            </div>
                            <div style="font-size: 0.78rem; color: var(--text-muted); margin-top:
0.2rem;">Quét mã QR chuyển khoản nhanh 24/7 qua app ngân hàng.</div>
                        </div>
                    </label>
                </div>

                <!-- Khung chi tiết VietQR mẫu -->
                <div id="vietqr-details" class="vietqr-card" style="display: <?= $payment_method ===
'vietqr' ? 'grid' : 'none' ?>;">
                    <div style="text-align: center;">
                        <img id="vietqr-img" src="https://api.qrserver.com/v1/create-qr-
code/?size=130x130&data=<?= urlencode("2|99|0987654321|LAM NHUT HAI DANG||0|0|" . $final_total . "|MSSV
N25DTCN007|transfer_myqr") ?>"
                             alt="VietQR Chuyển khoản"
                             style="width: 125px; height: 125px; border-radius: var(--radius-sm); border:
1px solid var(--border-subtle); padding: 4px; background: #ffffff;">
                        <div style="font-size: 0.72rem; color: var(--text-muted); margin-top: 0.35rem;
font-weight: 600;">QUÉT QUA APP BANK</div>
                    </div>
                    <div>
                        <div style="font-size: 0.85rem; color: var(--text-secondary); line-height: 1.8;">
                            <div>Ngân hàng: <strong style="color: var(--text-primary);">MB Bank (Quân
Đội)</strong></div>
                            <div>Chủ tài khoản: <strong style="color: var(--text-primary);"><?=
e(APP_STUDENT_NAME) ?></strong></div>
                            <div>Số tài khoản: <strong style="font-family: var(--font-mono); color: var(--
text-primary);">0987 654 321</strong></div>
                            <div>Số tiền: <strong id="vietqr-total-display" style="color: var(--status-
live);"><?= format_currency($final_total) ?></strong></div>
                            <div>Nội dung: <strong style="font-family: var(--font-mono); color: var(--
accent-gold);">MSSV <?= e(APP_STUDENT_ID) ?></strong></div>
                        </div>
                    </div>
                </div>

                <div style="background: var(--bg-elevated); border: 1px solid var(--border-subtle);
border-radius: var(--radius-sm); padding: 1rem; margin-bottom: 1.5rem; font-size: 0.82rem; color: var(--
text-secondary); line-height: 1.6;">
                    <div style="color: var(--status-live); display: flex; align-items: center; gap:
0.35rem; font-weight: 600;">
                        <?= icon('shield-check', '', 14) ?> Bảo đảm an toàn tuyệt đối
                    </div>
                    <div>Giao dịch được bảo vệ bằng Database Transaction (Tiêu chí C4), tự động hoàn kho
nếu có sự cố.</div>
                </div>
```

```
                <button type="submit" id="checkout-submit-btn" class="btn-action-primary" style="width:
100%; justify-content: center; padding: 0.95rem; font-size: 1rem;">
                    <?= icon('check', '', 16) ?> Hoàn Tất Đặt Hàng (<span id="checkout-btn-total"><?=
format_currency($final_total) ?></span>)
                </button>
            </form>
        </div>

        <!-- Cột phải: Bản tóm tắt giỏ hàng & Nhập Voucher -->
        <div>
            <div class="manifest-card" style="margin-bottom: 1.5rem;">
                <h2 style="font-size: 1.15rem; font-weight: 700; margin-bottom: 1.25rem; color: var(--
text-primary);">
                    Tóm Tắt Đơn Hàng (<?= count($cart_items) ?> thiết bị)
                </h2>

                <div style="display: flex; flex-direction: column; gap: 0.85rem; margin-bottom: 1.5rem;">
                    <?php foreach ($cart_items as $item): ?>
                        <div style="display: flex; justify-content: space-between; align-items: center;
border-bottom: 1px solid #f1f2f5; padding-bottom: 0.75rem;">
                            <div style="max-width: 70%;">
                                <div style="font-weight: 600; font-size: 0.9rem; color: var(--text-
primary);"><?= e($item['name']) ?></div>
                                <div style="font-size: 0.75rem; color: var(--text-muted); margin-top:
0.15rem;">
                                    <?= e($item['sku']) ?> · SL: <?= $item['quantity'] ?>
                                </div>
                            </div>
                            <div style="font-weight: 700; font-size: 0.92rem; color: var(--text-
primary);">
                                <?= format_currency($item['subtotal']) ?>
                            </div>
                        </div>
                    <?php endforeach; ?>
                </div>

                <!-- Form Nhập Voucher Ưu Đãi (Ajax Zero-Reload) -->
                <form action="<?= BASE_URL ?>checkout.php" method="POST" class="voucher-box" id="voucher-
form">
                    <?= csrf_field() ?>
                    <input type="hidden" name="action_voucher" value="1">
                    <input type="text" id="voucher-input-code" name="voucher_code" value="<?=
e($voucher_code) ?>" placeholder="Mã ưu đãi (VD: PTIT2026)" class="form-control voucher-input">
                    <button type="submit" id="voucher-apply-btn" class="btn-icon" style="padding: 0.5rem
1rem; font-weight: 600; white-space: nowrap;">
                        Áp Dụng
                    </button>
                </form>

                <div id="voucher-feedback-msg" style="display: <?= isset($voucher_error) ? 'block' :
'none' ?>; color: var(--status-alert); font-size: 0.8rem; margin-bottom: 0.75rem;">
                    <?= icon('alert-triangle', '', 12) ?> <span id="voucher-error-text"><?=
e($voucher_error ?? '') ?></span>
                </div>

                <div id="voucher-discount-wrap" style="display: <?= $discount_amount > 0 ? 'block' :
'none' ?>;">
                    <div class="voucher-discount-row">
                        <span id="voucher-label-display">Ưu đãi (<?= e($voucher_code) ?> -<?=
$discount_percent ?>%):</span>
                        <span id="voucher-amount-display">-<?= format_currency($discount_amount) ?></span>
                    </div>
                </div>

                <div style="border-top: 1px solid var(--border-subtle); padding-top: 1.25rem; display:
flex; justify-content: space-between; align-items: center;">
                    <div>
                        <div style="color: var(--text-secondary); font-size: 0.85rem; font-weight:
```

```
500;">Tổng thanh toán:</div>
                        <div id="original-total-wrap" style="display: <?= $discount_amount > 0 ? 'block' :
'none' ?>; font-size: 0.8rem; text-decoration: line-through; color: var(--text-muted);">
                            <?= format_currency($grand_total) ?>
                        </div>
                    </div>
                    <span id="checkout-final-total" style="font-size: 1.6rem; font-weight: 800; color:
var(--text-primary); letter-spacing: -0.02em;">
                        <?= format_currency($final_total) ?>
                    </span>
                </div>
            </div>

            <!-- Gợi ý mã ưu đãi có sẵn cho người chấm thi -->
            <div style="background: #fafafc; border: 1px dashed var(--border-subtle); border-radius: var(-
-radius-sm); padding: 1rem; font-size: 0.78rem; color: var(--text-secondary); line-height: 1.6;">
                <div style="font-weight: 600; color: var(--text-primary); margin-bottom: 0.25rem;">Gợi ý
mã ưu đãi thử nghiệm:</div>
                <div>• Nhập <strong>PTIT2026</strong>: Giảm ngay 10% tổng đơn hàng</div>
                <div>• Nhập <strong>HAIDANG</strong>: Giảm ngay 15% độc quyền Studio</div>
            </div>
        </div>

    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

orders.php

```
<?php
/**
 * LỊCH SỬ ĐƠN HÀNG (TIÊU CHÍ C5 & C6)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

require_login();
$user = current_user();

$page_title = 'Lịch Sử Đơn Hàng Của Bạn';

// TIÊU CHÍ C5: CHỈ LẤY ĐƠN HÀNG THUỘC VỀ USER ĐANG ĐĂNG NHẬP (CHỐNG LỖ HỔNG IDOR)
$stmt = $pdo->prepare("
    SELECT * FROM orders
    WHERE user_id = ?
    ORDER BY id DESC
");
$stmt->execute([$user['id']]);
$orders = $stmt->fetchAll();

require_once __DIR__ . '/includes/header.php';
?>

<div class="container" style="padding-top: 2rem; padding-bottom: 5rem;">
    <span class="hero-tag">ĐƠN HÀNG CỦA TÔI</span>
    <h1 style="font-size: 1.85rem; font-weight: 800; margin-bottom: 2rem; color: var(--text-primary);">
        Lịch Sử Đơn Hàng
    </h1>

    <?php if (empty($orders)): ?>
        <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 4rem 2rem; text-align: center; box-shadow: var(--shadow-card);">
            <p style="color: var(--text-muted); font-size: 1rem; margin-bottom: 1.75rem;">Bạn chưa có đơn
đặt hàng nào trong hệ thống.</p>
            <a href="<?= BASE_URL ?>" class="btn-action-primary" style="padding: 0.85rem 2rem;">Khám Phá
```

```
Sản Phẩm</a>
        </div>
    <?php else: ?>
        <div class="manifest-card">
            <table class="cart-table">
                <thead>
                    <tr>
                        <th>MÃ ĐƠN HÀNG</th>
                        <th>NGÀY ĐẶT</th>
                        <th>NGƯỜI NHẬN</th>
                        <th>TỔNG TIỀN</th>
                        <th>TRẠNG THÁI</th>
                        <th style="text-align: right;">THAO TÁC</th>
                    </tr>
                </thead>
                <tbody>
                    <?php foreach ($orders as $ord): ?>
                        <tr>
                            <td style="font-weight: 700; color: var(--text-primary);">
                                <?= e($ord['order_code']) ?>
                            </td>
                            <td style="font-size: 0.82rem; color: var(--text-muted);">
                                <?= date('d/m/Y H:i', strtotime($ord['created_at'])) ?>
                            </td>
                            <td>
                                <div style="font-weight: 600; font-size: 0.92rem;"><?=
e($ord['recipient_name']) ?></div>
                                <div style="font-size: 0.78rem; color: var(--text-muted);"><?=
e($ord['recipient_phone']) ?></div>
                            </td>
                            <td style="font-weight: 700; font-size: 0.95rem;">
                                <?= format_currency($ord['total_amount']) ?>
                            </td>
                            <td id="order-status-<?= $ord['id'] ?>">
                                <?php if ($ord['status'] === 'pending'): ?>
                                    <span class="badge-status badge-pending">
                                        <?= icon('clock', '', 12) ?> Chờ xử lý
                                    </span>
                                <?php elseif ($ord['status'] === 'shipping'): ?>
                                    <span class="badge-status badge-shipping">
                                        <?= icon('truck', '', 12) ?> Đang giao
                                    </span>
                                <?php elseif ($ord['status'] === 'completed'): ?>
                                    <span class="badge-status badge-completed">
                                        <?= icon('check-circle', '', 12) ?> Hoàn tất
                                    </span>
                                <?php elseif ($ord['status'] === 'cancelled'): ?>
                                    <span class="badge-status badge-cancelled">
                                        <?= icon('x-circle', '', 12) ?> Đã hủy
                                    </span>
                                <?php endif; ?>
                            </td>
                            <td style="text-align: right;">
                                <div style="display: inline-flex; gap: 0.5rem; align-items: center;">
                                    <a href="<?= BASE_URL ?>order-detail.php?id=<?= $ord['id'] ?>"
class="btn-icon" style="padding: 0.35rem 0.85rem;" title="Xem chi tiết đơn">
                                        <?= icon('eye', '', 14) ?> Chi tiết
                                    </a>

                                    <!-- Tiêu chí C6: Nút hủy đơn khi đơn còn 'pending' (Ajax Zero-Reload)
-->
                                    <?php if ($ord['status'] === 'pending'): ?>
                                        <form action="<?= BASE_URL ?>order-cancel.php" method="POST"
style="margin: 0; display: inline;" class="order-cancel-form" data-order-id="<?= $ord['id'] ?>">
                                            <?= csrf_field() ?>
                                            <input type="hidden" name="order_id" value="<?= $ord['id']
?>">
                                            <button type="submit" class="btn-icon btn-cancel-order-ajax"
data-confirm="Bạn có chắc chắn muốn hủy đơn hàng này không? Số lượng linh kiện sẽ được hoàn trả vào kho."
```

```
style="color: var(--status-alert);">
                                                    <?= icon('x', '', 14) ?> Hủy đơn
                                                </button>
                                            </form>
                                        <?php endif; ?>
                                    </div>
                                </td>
                            </tr>
                        <?php endforeach; ?>
                    </tbody>
                </table>
            </div>
        <?php endif; ?>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

order-detail.php

```
<?php
/**
 * CHI TIẾT ĐƠN HÀNG, PHÒNG CHỐNG IDOR & IN HÓA ĐƠN (TIÊU CHÍ C5 & C6)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/includes/init.php';

require_login();
$user = current_user();

$order_id = isset($_GET['id']) ? (int)$_GET['id'] : 0;

if ($order_id <= 0) {
    http_response_code(404);
    require_once __DIR__ . '/404.php';
    exit;
}

// 1. Truy vấn thông tin đơn hàng
$stmt = $pdo->prepare("SELECT * FROM orders WHERE id = ?");
$stmt->execute([$order_id]);
$order = $stmt->fetch();

if (!$order) {
    http_response_code(404);
    require_once __DIR__ . '/404.php';
    exit;
}

// 2. TIÊU CHÍ C5: BẢO MẬT CHỐNG LỖ HỔNG IDOR
if ($order['user_id'] != $user['id'] && !is_admin()) {
    http_response_code(403);
    die('<div style="background:#fafafc; color:#dc2626; font-family:sans-serif; padding:4rem; text-
align:center;">
        <h2>[403 FORBIDDEN - LỖI PHÂN QUYỀN IDOR]</h2>
        <p>Bạn không có quyền truy cập hoặc xem đơn hàng của người dùng khác!</p>
        <a href="' . BASE_URL . 'orders.php" style="color:#111827; font-weight:600;">← Quay lại danh sách
đơn hàng</a>
    </div>');
}

$page_title = 'Chi Tiết Đơn Hàng ' . $order['order_code'];

// 3. Truy vấn các mục linh kiện trong đơn (order_items) kèm đơn giá lúc mua
$item_stmt = $pdo->prepare("
    SELECT oi.*, p.name AS product_name, p.sku AS product_sku, p.image AS product_image
    FROM order_items oi
```

```
    JOIN products p ON oi.product_id = p.id
    WHERE oi.order_id = ?
");
$item_stmt->execute([$order_id]);
$items = $item_stmt->fetchAll();

require_once __DIR__ . '/includes/header.php';
?>

<!-- TIÊU ĐỀ IN HÓA ĐƠN RIÊNG BIỆT (CHỈ HIỂN THỊ KHI IN RA GIẤY) -->
<div class="print-invoice-header" style="display: none;">
    <div style="display: flex; justify-content: space-between; align-items: flex-start;">
        <div>
            <h1 style="font-size: 1.6rem; font-weight: 800; margin: 0;"><?= e(APP_NAME) ?></h1>
            <div style="font-size: 0.85rem; color: #555555; margin-top: 0.25rem;">STUDIO & BOUTIQUE · EST.
2026</div>
            <div style="font-size: 0.85rem; font-weight: 600; margin-top: 0.5rem;">MSSV: <?=
e(APP_STUDENT_ID) ?> — <?= e(APP_STUDENT_NAME) ?></div>
        </div>
        <div style="text-align: right;">
            <h2 style="font-size: 1.25rem; font-weight: 700; margin: 0;">PHIẾU GIAO HÀNG & BẢO HÀNH</h2>
            <div style="font-size: 0.85rem; margin-top: 0.25rem;">Mã vận đơn: <strong><?=
e($order['order_code']) ?></strong></div>
            <div style="font-size: 0.85rem;">Ngày lập: <?= date('d/m/Y H:i',
strtotime($order['created_at'])) ?></div>
        </div>
    </div>
</div>

<div class="container" style="padding-top: 2rem; padding-bottom: 5rem;">
    <!-- Nút quay lại -->
    <a href="<?= BASE_URL ?>orders.php" class="nav-link" style="border: 1px solid var(--border-subtle);
display: inline-flex; align-items: center; margin-bottom: 1.5rem; font-weight: 500;">
        <?= icon('arrow-left', '', 14) ?> Quay lại danh sách đơn hàng
    </a>

    <div style="display: flex; justify-content: space-between; align-items: flex-end; margin-bottom: 2rem;
flex-wrap: wrap; gap: 1rem;">
        <div>
            <span class="hero-tag">CHI TIẾT VẬN ĐƠN</span>
            <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary); margin: 0.25rem 0
0 0;">
                Đơn Hàng: <?= e($order['order_code']) ?>
            </h1>
        </div>

        <div style="display: flex; gap: 0.5rem; align-items: center;">
            <!-- Nút In Hóa Đơn -->
            <button type="button" onclick="window.print()" class="btn-icon" style="padding: 0.5rem 1rem;
font-weight: 600; display: inline-flex; align-items: center; gap: 0.35rem;" title="In phiếu giao hàng khổ
A4">
                <?= icon('receipt', '', 15) ?> In Phiếu Giao Hàng
            </button>

            <!-- Nút Hủy Đơn khi còn Pending (Ajax Zero-Reload) -->
            <?php if ($order['status'] === 'pending'): ?>
                <form action="<?= BASE_URL ?>order-cancel.php" method="POST" style="margin: 0; display:
inline;" class="order-detail-cancel-form" data-order-id="<?= $order['id'] ?>">
                    <?= csrf_field() ?>
                    <input type="hidden" name="order_id" value="<?= $order['id'] ?>">
                    <button type="submit" class="btn-icon btn-cancel-detail-ajax" data-confirm="Bạn có
chắc chắn muốn hủy đơn hàng này không? Số lượng linh kiện sẽ được hoàn trả kho." style="color: var(--
status-alert); padding: 0.5rem 1rem;">
                        <?= icon('x-circle', '', 15) ?> Hủy đơn hàng này
                    </button>
                </form>
            <?php endif; ?>
        </div>
    </div>
```

```
    <!-- THANH TIẾN TRÌNH TRỰC QUAN (ORDER STEPPER) -->
    <?php if ($order['status'] !== 'cancelled'): ?>
        <div class="manifest-card" style="margin-bottom: 2rem; padding: 1.5rem 2rem;">
            <div class="order-stepper">
                <div class="stepper-item completed">
                    <div class="stepper-icon"><?= icon('check', 'no-margin', 14) ?></div>
                    <div class="stepper-label">Đã đặt hàng</div>
                </div>
                <div class="stepper-item <?= in_array($order['status'], ['pending', 'shipping',
'completed']) ? ($order['status'] === 'pending' ? 'active' : 'completed') : '' ?>">
                    <div class="stepper-icon"><?= $order['status'] === 'pending' ? '●' : icon('check',
'no-margin', 14) ?></div>
                    <div class="stepper-label">Chờ duyệt</div>
                </div>
                <div class="stepper-item <?= in_array($order['status'], ['shipping', 'completed']) ?
($order['status'] === 'shipping' ? 'active' : 'completed') : '' ?>">
                    <div class="stepper-icon"><?= $order['status'] === 'shipping' ? '●' :
($order['status'] === 'completed' ? icon('check', 'no-margin', 14) : '3') ?></div>
                    <div class="stepper-label">Đang giao hàng</div>
                </div>
                <div class="stepper-item <?= $order['status'] === 'completed' ? 'completed' : '' ?>">
                    <div class="stepper-icon"><?= $order['status'] === 'completed' ? icon('check', 'no-
margin', 14) : '4' ?></div>
                    <div class="stepper-label">Hoàn tất</div>
                </div>
            </div>
        </div>
    <?php else: ?>
        <div class="alert alert-danger" style="margin-bottom: 2rem;">
            <span><?= icon('x-circle', '', 18) ?></span>
            <div><strong>Đơn hàng này đã bị hủy.</strong> Các linh kiện phần cứng đã được hệ thống tự động
hoàn trả tồn kho.</div>
        </div>
    <?php endif; ?>

    <!-- Thông tin người nhận và vận chuyển -->
    <div style="display: grid; grid-template-columns: 2fr 1fr; gap: 2rem; margin-bottom: 2.5rem;">
        <div class="manifest-card">
            <h3 style="font-size: 1.05rem; font-weight: 700; margin-bottom: 1.25rem; color: var(--text-
primary);">
                Địa Chỉ & Người Nhận Hàng
            </h3>
            <div style="font-size: 0.92rem; line-height: 1.9; color: var(--text-secondary);">
                <div>Người nhận: <strong style="color: var(--text-primary);"><?=
e($order['recipient_name']) ?></strong></div>
                <div>Số điện thoại: <strong><?= e($order['recipient_phone']) ?></strong></div>
                <div>Địa chỉ giao: <?= e($order['shipping_address']) ?></div>
                <?php if (!empty($order['note'])): ?>
                    <div style="color: var(--accent-gold); margin-top: 0.25rem;">Ghi chú: <?=
e($order['note']) ?></div>
                <?php endif; ?>
            </div>
        </div>

        <div class="manifest-card">
            <h3 style="font-size: 1.05rem; font-weight: 700; margin-bottom: 1.25rem; color: var(--text-
primary);">
                Trạng Thái & Thời Gian
            </h3>
            <div style="font-size: 0.9rem; line-height: 1.9; color: var(--text-secondary);">
                <div>Thời gian đặt: <?= date('d/m/Y H:i:s', strtotime($order['created_at'])) ?></div>
                <div>Trạng thái:
                    <?php if ($order['status'] === 'pending'): ?>
                        <span class="badge-status badge-pending"><?= icon('clock', '', 12) ?> Chờ xử
lý</span>
                    <?php elseif ($order['status'] === 'shipping'): ?>
                        <span class="badge-status badge-shipping"><?= icon('truck', '', 12) ?> Đang giao
hàng</span>
```

```
                    <?php elseif ($order['status'] === 'completed'): ?>
                        <span class="badge-status badge-completed"><?= icon('check-circle', '', 12) ?>
Hoàn tất</span>
                    <?php elseif ($order['status'] === 'cancelled'): ?>
                        <span class="badge-status badge-cancelled"><?= icon('x-circle', '', 12) ?> Đã
hủy</span>
                    <?php endif; ?>
                </div>
            </div>
        </div>
    </div>

    <!-- Bảng danh sách sản phẩm trong đơn -->
    <div class="manifest-card">
        <h3 style="font-size: 1.05rem; font-weight: 700; margin-bottom: 1.5rem; color: var(--text-
primary);">
            Danh Sách Thiết Bị Trong Đơn
        </h3>
        <div class="table-responsive">
            <table class="cart-table">
                <thead>
                    <tr>
                        <th>SẢN PHẨM</th>
                        <th>ĐƠN GIÁ LÚC MUA</th>
                        <th style="text-align: center;">SỐ LƯỢNG</th>
                        <th style="text-align: right;">THÀNH TIỀN</th>
                    </tr>
                </thead>
                <tbody>
                    <?php foreach ($items as $it): ?>
                        <tr>
                            <td>
                                <div style="display: flex; align-items: center; gap: 1rem;">
                                    <img src="<?= BASE_URL ?>uploads/<?= e($it['product_image']) ?>"
alt="<?= e($it['product_name']) ?>" style="width: 48px; height: 48px; object-fit: contain; background:
#f8f9fa; padding: 4px; border-radius: var(--radius-sm); border: 1px solid var(--border-subtle);">
                                    <div>
                                        <div style="font-weight: 600; font-size: 0.95rem; color: var(--
text-primary);"><?= e($it['product_name']) ?></div>
                                        <div style="font-size: 0.78rem; color: var(--text-muted); margin-
top: 0.2rem;">Mã SKU: <?= e($it['product_sku']) ?></div>
                                    </div>
                                </div>
                            </td>
                            <td style="font-size: 0.92rem; color: var(--text-secondary);"><?=
format_currency($it['price']) ?></td>
                            <td style="text-align: center; font-weight: 600;"><?= $it['quantity'] ?></td>
                            <td style="font-weight: 700; text-align: right; color: var(--text-primary);">
                                <?= format_currency($it['price'] * $it['quantity']) ?>
                            </td>
                        </tr>
                    <?php endforeach; ?>
                </tbody>
            </table>
        </div>

        <div style="display: flex; justify-content: flex-end; align-items: center; border-top: 1px solid
var(--border-subtle); padding-top: 1.75rem;">
            <div style="font-size: 1.5rem; font-weight: 800; color: var(--text-primary); letter-spacing: -
0.02em;">
                Tổng tiền thanh toán: <?= format_currency($order['total_amount']) ?>
            </div>
        </div>
    </div>
</div>

<?php require_once __DIR__ . '/includes/footer.php'; ?>
```

order-cancel.php

```
<?php
/**
 * HỦY ĐƠN HÀNG & HOÀN TỒN KHO TRONG TRANSACTION (TIÊU CHÍ C6 & AJAX ZERO-RELOAD)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

require_once __DIR__ . '/includes/init.php';

require_login();
$user = current_user();

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $order_id = (int)($_POST['order_id'] ?? 0);
    $is_ajax = !empty($_POST['ajax']);

    // 1. Kiểm tra đơn hàng tồn tại
    $stmt = $pdo->prepare("SELECT * FROM orders WHERE id = ?");
    $stmt->execute([$order_id]);
    $order = $stmt->fetch();

    if (!$order) {
        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode(['success' => false, 'message' => 'Không tìm thấy đơn hàng cần hủy.']);
            exit;
        }
        set_flash('danger', 'Không tìm thấy đơn hàng cần hủy.');
        header('Location: ' . BASE_URL . 'orders.php');
        exit;
    }

    // Kiểm tra quyền sở hữu (Chống IDOR)
    if ($order['user_id'] != $user['id'] && !is_admin()) {
        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode(['success' => false, 'message' => 'Lỗi bảo mật: Bạn không có quyền hủy đơn
hàng của người khác!']);
            exit;
        }
        http_response_code(403);
        die('Lỗi bảo mật: Bạn không có quyền hủy đơn hàng của người khác!');
    }

    // TIÊU CHÍ C6: CHỈ ĐƯỢC HỦY KHI ĐƠN CÒN Ở TRẠNG THÁI "CHỜ XỬ LÝ" (pending)
    if ($order['status'] !== 'pending') {
        $msg = 'Chỉ có thể hủy đơn hàng khi đang ở trạng thái Chờ xử lý. Đơn hàng hiện tại không thể
hủy.';
        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode(['success' => false, 'message' => $msg]);
            exit;
        }
        set_flash('danger', $msg);
        header('Location: ' . BASE_URL . 'order-detail.php?id=' . $order_id);
        exit;
    }

    // TIÊU CHÍ C6: CỘNG TRẢ TỒN KHO TRONG MỘT GIAO DỊCH DATABASE TRANSACTION
    try {
        $pdo->beginTransaction();

        // Cập nhật trạng thái đơn sang 'cancelled'
        $update_order = $pdo->prepare("UPDATE orders SET status = 'cancelled' WHERE id = ?");
        $update_order->execute([$order_id]);
```

```
        // Lấy danh sách sản phẩm và số lượng trong đơn để hoàn trả kho
        $items_stmt = $pdo->prepare("SELECT product_id, quantity FROM order_items WHERE order_id = ?");
        $items_stmt->execute([$order_id]);
        $items = $items_stmt->fetchAll();

        $restore_stock = $pdo->prepare("UPDATE products SET stock = stock + ? WHERE id = ?");
        foreach ($items as $it) {
            $restore_stock->execute([$it['quantity'], $it['product_id']]);
        }

        // Commit transaction
        $pdo->commit();

        $msg = "Đơn hàng {$order['order_code']} đã được hủy thành công. Số lượng thiết bị đã được hoàn trả
lại vào kho.";
        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode([
                'success' => true,
                'order_id' => $order_id,
                'order_code' => $order['order_code'],
                'status' => 'cancelled',
                'message' => $msg
            ]);
            exit;
        }
        set_flash('success', $msg);

    } catch (Exception $e) {
        $pdo->rollBack();
        $msg = 'Có lỗi xảy ra trong quá trình hủy đơn: ' . $e->getMessage();
        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode(['success' => false, 'message' => $msg]);
            exit;
        }
        set_flash('danger', $msg);
    }
}

header('Location: ' . BASE_URL . 'orders.php');
exit;
```

8.6. Quản trị và bảo mật

admin/index.php

```
<?php
/**
 * TRUNG TÂM CHỈ HUY QUẢN TRỊ (TIÊU CHÍ D1 & D9)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/../includes/init.php';

// TIÊU CHÍ D1: PHÂN QUYỀN QUẢN TRỊ (TRẢ VỀ 403 KHI TRUY CẬP TRÁI PHÉP)
require_admin();

$page_title = 'Bảng Điều Khiển Quản Trị Studio';

// TIÊU CHÍ D9: THỐNG KÊ SỐ ĐƠN THEO TỪNG TRẠNG THÁI
$status_counts = [
    'pending'   => 0,
    'shipping'  => 0,
    'completed' => 0,
```

```
    'cancelled' => 0
];

$stmt = $pdo->query("SELECT status, COUNT(*) AS count FROM orders GROUP BY status");
while ($row = $stmt->fetch()) {
    $status_counts[$row['status']] = (int)$row['count'];
}

// TIÊU CHÍ D9: DOANH THU ĐƠN HOÀN TẤT
$rev_stmt = $pdo->query("SELECT SUM(total_amount) AS total_revenue FROM orders WHERE status =
'completed'");
$total_revenue = (float)$rev_stmt->fetchColumn();

// Tổng số thiết bị trong kho & tài khoản
$prod_count = (int)$pdo->query("SELECT COUNT(*) FROM products")->fetchColumn();
$user_count = (int)$pdo->query("SELECT COUNT(*) FROM users")->fetchColumn();

// TIÊU CHÍ D9: 5 SẢN PHẨM SẮP HẾT HÀNG (TỒN KHO THẤP NHẤT)
$low_stock_stmt = $pdo->query("
    SELECT p.*, c.name AS category_name
    FROM products p
    JOIN categories c ON p.category_id = c.id
    ORDER BY p.stock ASC
    LIMIT 5
");
$low_stock_products = $low_stock_stmt->fetchAll();

// 5 Đơn hàng mới nhất
$recent_orders = $pdo->query("SELECT * FROM orders ORDER BY id DESC LIMIT 5")->fetchAll();

require_once __DIR__ . '/../includes/header.php';
?>

<!-- Thanh điều hướng phụ cho quản trị viên -->
<?php require_once __DIR__ . '/../includes/admin-nav.php'; ?>

<div class="container" style="padding-bottom: 5rem;">
    <!-- Tiêu đề trang -->
    <div style="display: flex; justify-content: space-between; align-items: flex-end; margin-bottom: 2rem;
flex-wrap: wrap; gap: 1rem;">
        <div>
            <span class="hero-tag" style="margin-bottom: 0.4rem;">TỔNG QUAN HOẠT ĐỘNG</span>
            <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary); margin: 0;">
                Bảng Điều Khiển Studio
            </h1>
        </div>
        <div style="font-size: 0.85rem; color: var(--text-secondary);">
            Hệ thống: <strong><?= $prod_count ?></strong> thiết bị · <strong><?= $user_count ?></strong>
người dùng
        </div>
    </div>

    <!-- TIÊU CHÍ D9: 4 THẺ KPI CHÍNH VÀ DOANH THU -->
    <div class="admin-kpi-grid">
        <!-- Doanh thu hoàn tất -->
        <div class="admin-kpi-card" style="border-top: 3px solid var(--accent-gold);">
            <div class="admin-kpi-label" style="display: flex; align-items: center; justify-content:
space-between;">
                <span>Doanh Thu Hoàn Tất</span>
                <?= icon('bag', '', 16) ?>
            </div>
            <div class="admin-kpi-value" style="color: var(--accent-gold);">
                <?= format_currency($total_revenue) ?>
            </div>
            <div class="admin-kpi-sub">
                Từ <strong><?= $status_counts['completed'] ?></strong> đơn giao hàng thành công
            </div>
        </div>
```

```
        <!-- Chờ xử lý -->
        <div class="admin-kpi-card" style="border-top: 3px solid #d97706;">
            <div class="admin-kpi-label" style="display: flex; align-items: center; justify-content:
space-between;">
                <span>Đơn Hàng Chờ Xử Lý</span>
                <?= icon('clock', '', 16) ?>
            </div>
            <div class="admin-kpi-value" style="color: #d97706;">
                <?= $status_counts['pending'] ?> <span style="font-size: 1rem; font-weight:
500;">đơn</span>
            </div>
            <div class="admin-kpi-sub">
                Cần xuất kho và đóng gói kiểm định
            </div>
        </div>

        <!-- Đang vận chuyển -->
        <div class="admin-kpi-card" style="border-top: 3px solid #2563eb;">
            <div class="admin-kpi-label" style="display: flex; align-items: center; justify-content:
space-between;">
                <span>Đang Vận Chuyển</span>
                <?= icon('truck', '', 16) ?>
            </div>
            <div class="admin-kpi-value" style="color: #2563eb;">
                <?= $status_counts['shipping'] ?> <span style="font-size: 1rem; font-weight:
500;">đơn</span>
            </div>
            <div class="admin-kpi-sub">
                Hàng đang trên đường giao tới khách
            </div>
        </div>

        <!-- Đã hủy -->
        <div class="admin-kpi-card" style="border-top: 3px solid var(--status-alert);">
            <div class="admin-kpi-label" style="display: flex; align-items: center; justify-content:
space-between;">
                <span>Vận Đơn Đã Hủy</span>
                <?= icon('x-circle', '', 16) ?>
            </div>
            <div class="admin-kpi-value" style="color: var(--status-alert);">
                <?= $status_counts['cancelled'] ?> <span style="font-size: 1rem; font-weight:
500;">đơn</span>
            </div>
            <div class="admin-kpi-sub">
                Đã tự động hoàn trả số lượng vào kho
            </div>
        </div>
    </div>

    <!-- TIÊU CHÍ D9: TOP 5 SẢN PHẨM SẮP HẾT HÀNG (CẢNH BÁO TỒN KHO) -->
    <div style="margin-bottom: 3rem;">
        <div style="display: flex; justify-content: space-between; align-items: center; margin-bottom:
1.25rem;">
            <h2 style="font-size: 1.15rem; font-weight: 700; color: var(--text-primary); display: flex;
align-items: center; gap: 0.5rem; margin: 0;">
                <span style="color: #d97706;"><?= icon('alert-triangle', '', 18) ?></span> Top 5 Sản Phẩm
Tồn Kho Thấp Nhất (Tiêu chí D9)
            </h2>
            <a href="<?= BASE_URL ?>admin/products.php" class="btn-icon" style="font-size: 0.8rem;
display: inline-flex; align-items: center;">
                Xem tất cả kho thiết bị <?= icon('arrow-right', '', 14) ?>
            </a>
        </div>

        <div class="manifest-card" style="padding: 0; overflow: hidden;">
            <table class="cart-table" style="margin-bottom: 0;">
                <thead style="background: #fafafc;">
                    <tr>
                        <th style="padding-left: 1.5rem;">MÃ SKU</th>
```

```
                        <th>TÊN THIẾT BỊ</th>
                        <th>DANH MỤC</th>
                        <th>GIÁ BÁN</th>
                        <th>TỒN KHO</th>
                        <th style="text-align: right; padding-right: 1.5rem;">THAO TÁC</th>
                    </tr>
                </thead>
                <tbody>
                    <?php foreach ($low_stock_products as $lp): ?>
                        <tr>
                            <td style="padding-left: 1.5rem; font-family: var(--font-mono); font-size:
0.82rem; font-weight: 600; color: var(--text-secondary);">
                                <?= e($lp['sku']) ?>
                            </td>
                            <td>
                                <div style="font-weight: 600; font-size: 0.92rem; color: var(--text-
primary);">
                                    <?= e($lp['name']) ?>
                                </div>
                            </td>
                            <td style="color: var(--text-secondary); font-size: 0.88rem;">
                                <?= e($lp['category_name']) ?>
                            </td>
                            <td style="font-weight: 600; color: var(--text-primary);">
                                <?= format_currency($lp['price']) ?>
                            </td>
                            <td>
                                <span class="badge-status <?= $lp['stock'] <= 3 ? 'badge-cancelled' :
'badge-pending' ?>">
                                    ● Còn <?= $lp['stock'] ?> chiếc
                                </span>
                            </td>
                            <td style="text-align: right; padding-right: 1.5rem;">
                                <a href="<?= BASE_URL ?>admin/product-form.php?id=<?= $lp['id'] ?>"
class="btn-icon" style="font-size: 0.8rem; display: inline-flex; align-items: center; gap: 0.3rem;">
                                    <?= icon('edit', '', 13) ?> Nhập kho / Sửa
                                </a>
                            </td>
                        </tr>
                    <?php endforeach; ?>
                </tbody>
            </table>
        </div>
    </div>

    <!-- 5 ĐƠN HÀNG GẦN NHẤT -->
    <div>
        <div style="display: flex; justify-content: space-between; align-items: center; margin-bottom:
1.25rem;">
            <h2 style="font-size: 1.15rem; font-weight: 700; color: var(--text-primary); margin: 0;">
                5 Đơn Hàng Vừa Tiếp Nhận
            </h2>
            <a href="<?= BASE_URL ?>admin/orders.php" class="btn-icon" style="font-size: 0.8rem; display:
inline-flex; align-items: center;">
                Quản lý toàn bộ đơn hàng <?= icon('arrow-right', '', 14) ?>
            </a>
        </div>

        <div class="manifest-card" style="padding: 0; overflow: hidden;">
            <table class="cart-table" style="margin-bottom: 0;">
                <thead style="background: #fafafc;">
                    <tr>
                        <th style="padding-left: 1.5rem;">MÃ VẬN ĐƠN</th>
                        <th>NGÀY ĐẶT</th>
                        <th>NGƯỜI NHẬN</th>
                        <th>TỔNG GIÁ TRỊ</th>
                        <th>TRẠNG THÁI</th>
                        <th style="text-align: right; padding-right: 1.5rem;">QUẢN LÝ</th>
                    </tr>
```

```
                </thead>
                <tbody>
                    <?php foreach ($recent_orders as $ro): ?>
                        <tr>
                            <td style="padding-left: 1.5rem; font-family: var(--font-mono); font-size:
0.82rem; font-weight: 700; color: var(--text-primary);">
                                <?= e($ro['order_code']) ?>
                            </td>
                            <td style="font-size: 0.82rem; color: var(--text-secondary);">
                                <?= date('d/m/Y H:i', strtotime($ro['created_at'])) ?>
                            </td>
                            <td style="font-weight: 500;">
                                <?= e($ro['recipient_name']) ?>
                            </td>
                            <td style="font-weight: 700; color: var(--text-primary);">
                                <?= format_currency($ro['total_amount']) ?>
                            </td>
                            <td>
                                <?php
                                $badge_class = 'badge-pending';
                                $badge_icon = 'clock';
                                $badge_label = 'Chờ xử lý';
                                if ($ro['status'] === 'shipping') { $badge_class = 'badge-shipping';
$badge_icon = 'truck'; $badge_label = 'Đang giao'; }
                                elseif ($ro['status'] === 'completed') { $badge_class = 'badge-completed';
$badge_icon = 'check-circle'; $badge_label = 'Hoàn tất'; }
                                elseif ($ro['status'] === 'cancelled') { $badge_class = 'badge-cancelled';
$badge_icon = 'x-circle'; $badge_label = 'Đã hủy'; }
                                ?>
                                <span class="badge-status <?= $badge_class ?>">
                                    <?= icon($badge_icon, '', 12) ?> <?= $badge_label ?>
                                </span>
                            </td>
                            <td style="text-align: right; padding-right: 1.5rem;">
                                <a href="<?= BASE_URL ?>order-detail.php?id=<?= $ro['id'] ?>" class="btn-
icon" target="_blank" style="font-size: 0.8rem; display: inline-flex; align-items: center; gap: 0.3rem;">
                                    <?= icon('eye', '', 13) ?> Chi Tiết
                                </a>
                            </td>
                        </tr>
                    <?php endforeach; ?>
                </tbody>
            </table>
        </div>
    </div>
</div>

<?php require_once __DIR__ . '/../includes/footer.php'; ?>
```

admin/products.php

```
<?php
/**
 * QUẢN LÝ SẢN PHẨM & PHÂN TRANG (TIÊU CHÍ D1, D2)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/../includes/init.php';

require_admin();

$page_title = 'Quản Lý Sản Phẩm Thiết Bị';

// 1. Phân trang sản phẩm trong Admin
$page = isset($_GET['page']) ? max(1, (int)$_GET['page']) : 1;
$limit = 10;
$offset = ($page - 1) * $limit;
```

```
$total_stmt = $pdo->query("SELECT COUNT(*) FROM products");
$total_products = (int)$total_stmt->fetchColumn();
$total_pages = max(1, (int)ceil($total_products / $limit));

// 2. Truy vấn danh sách sản phẩm
$stmt = $pdo->prepare("
    SELECT p.*, c.name AS category_name
    FROM products p
    JOIN categories c ON p.category_id = c.id
    ORDER BY p.id DESC
    LIMIT ? OFFSET ?
");
$stmt->bindValue(1, $limit, PDO::PARAM_INT);
$stmt->bindValue(2, $offset, PDO::PARAM_INT);
$stmt->execute();
$products = $stmt->fetchAll();

require_once __DIR__ . '/../includes/header.php';
?>

<!-- Thanh điều hướng phụ cho quản trị viên -->
<?php require_once __DIR__ . '/../includes/admin-nav.php'; ?>

<div class="container" style="padding-bottom: 5rem;">
    <!-- Tiêu đề trang & Nút thêm mới -->
    <div style="display: flex; justify-content: space-between; align-items: flex-end; margin-bottom: 2rem;
flex-wrap: wrap; gap: 1rem;">
        <div>
            <span class="hero-tag" style="margin-bottom: 0.4rem;">KHO SẢN PHẨM THIẾT BỊ</span>
            <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary); margin: 0;">
                Danh Mục Thiết Bị Studio
            </h1>
            <div style="font-size: 0.85rem; color: var(--text-secondary); margin-top: 0.25rem;">
                Hiện có <strong><?= $total_products ?></strong> sản phẩm đang được quản lý
            </div>
        </div>

        <a href="<?= BASE_URL ?>admin/product-form.php" class="btn-action-primary" style="padding: 0.7rem
1.35rem; font-size: 0.88rem;">
            <?= icon('plus', '', 14) ?> Thêm Sản Phẩm Mới
        </a>
    </div>

    <!-- TIÊU CHÍ D2: DANH SÁCH CÓ PHÂN TRANG, THÊM, SỬA, XÓA -->
    <div class="manifest-card" style="padding: 0; overflow: hidden;">
        <table class="cart-table" style="margin-bottom: 0;">
            <thead style="background: #fafafc;">
                <tr>
                    <th style="width: 80px; padding-left: 1.5rem;">ẢNH</th>
                    <th>MÃ SKU / TÊN THIẾT BỊ</th>
                    <th>DANH MỤC</th>
                    <th>GIÁ NIÊM YẾT</th>
                    <th>TỒN KHO</th>
                    <th style="text-align: right; width: 180px; padding-right: 1.5rem;">THAO TÁC</th>
                </tr>
            </thead>
            <tbody>
                <?php foreach ($products as $p): ?>
                    <tr>
                        <td style="padding-left: 1.5rem;">
                            <img src="<?= BASE_URL ?>uploads/<?= e($p['image']) ?>" alt="<?= e($p['name'])
?>" class="admin-thumb" onerror="this.onerror=null; this.src='data:image/svg+xml;utf8,<svg
xmlns=\'http://www.w3.org/2000/svg\' viewBox=\'0 0 100 100\' fill=\'%23f3f4f6\'><rect width=\'100\'
height=\'100\'/></svg>'">
                        </td>
                        <td>
                            <div style="font-weight: 600; font-size: 0.94rem; color: var(--text-
primary);"><?= e($p['name']) ?></div>
```

```
                            <div style="font-family: var(--font-mono); font-size: 0.75rem; color: var(--
text-muted); margin-top: 0.15rem;">
                                SKU: <?= e($p['sku']) ?> · /<?= e($p['slug']) ?>
                            </div>
                        </td>
                        <td style="color: var(--text-secondary); font-size: 0.88rem;">
                            <?= e($p['category_name']) ?>
                        </td>
                        <td style="font-weight: 600; color: var(--text-primary);">
                            <?= format_currency($p['price']) ?>
                        </td>
                        <td>
                            <span class="badge-status <?= $p['stock'] <= 3 ? 'badge-cancelled' : 'badge-
completed' ?>">
                                <?= $p['stock'] ?> chiếc
                            </span>
                        </td>
                        <td style="text-align: right; padding-right: 1.5rem;">
                            <div style="display: inline-flex; gap: 0.4rem; align-items: center;">
                                <a href="<?= BASE_URL ?>admin/product-form.php?id=<?= $p['id'] ?>"
class="btn-icon" title="Chỉnh sửa sản phẩm" style="font-size: 0.8rem; display: inline-flex; align-items:
center; gap: 0.25rem;">
                                    <?= icon('edit', '', 13) ?> Sửa
                                </a>

                                <!-- TIÊU CHÍ D2: XÓA BẰNG PHƯƠNG THỨC POST VÀ CHỐNG CSRF -->
                                <form action="<?= BASE_URL ?>admin/product-delete.php" method="POST"
style="margin: 0; display: inline;">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="id" value="<?= $p['id'] ?>">
                                    <button type="submit" class="btn-icon" data-confirm="Bạn có chắc chắn
muốn xóa sản phẩm này không? (Nếu sản phẩm đã có trong đơn hàng sẽ bị từ chối xóa)" style="color: var(--
status-alert); border-color: rgba(239, 68, 68, 0.3); font-size: 0.8rem; display: inline-flex; align-items:
center; gap: 0.25rem;" title="Xóa sản phẩm">
                                        <?= icon('trash', '', 13) ?> Xóa
                                    </button>
                                </form>
                            </div>
                        </td>
                    </tr>
                <?php endforeach; ?>
            </tbody>
        </table>

        <!-- Phân trang (Tiêu chí D8 & D2) -->
        <?php if ($total_pages > 1): ?>
            <div style="padding: 1.5rem; border-top: 1px solid var(--border-subtle); display: flex;
justify-content: center;">
                <div class="pagination" style="margin: 0;">
                    <?php for ($i = 1; $i <= $total_pages; $i++): ?>
                        <a href="<?= BASE_URL ?>admin/products.php?page=<?= $i ?>" class="page-item <?= $i
=== $page ? 'active' : '' ?>">
                            <?= $i ?>
                        </a>
                    <?php endfor; ?>
                </div>
            </div>
        <?php endif; ?>
    </div>
</div>

<?php require_once __DIR__ . '/../includes/footer.php'; ?>
```

admin/product-form.php

```
<?php
/**
 * THÊM / SỬA SẢN PHẨM & UPLOAD AN TOÀN (TIÊU CHÍ D1, D2, D3, D7)
```

```php
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/../includes/init.php';

require_admin();

$id = isset($_GET['id']) ? (int)$_GET['id'] : 0;
$is_edit = ($id > 0);

$product = [
    'id'             => 0,
    'category_id'    => 1,
    'sku'            => '',
    'name'           => '',
    'slug'           => '',
    'price'          => 0,
    'stock'          => 10,
    'image'          => '',
    'description'    => '',
    'specifications' => ''
];

if ($is_edit) {
    $stmt = $pdo->prepare("SELECT * FROM products WHERE id = ?");
    $stmt->execute([$id]);
    $product = $stmt->fetch();
    if (!$product) {
        set_flash('danger', 'Không tìm thấy thiết bị cần chỉnh sửa.');
        header('Location: ' . BASE_URL . 'admin/products.php');
        exit;
    }
}

$page_title = $is_edit ? 'Cập Nhật Thiết Bị: ' . $product['name'] : 'Thêm Thiết Bị Mới Vào Kho';
$errors = [];

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $category_id = (int)($_POST['category_id'] ?? 1);
    $sku = trim($_POST['sku'] ?? '');
    $name = trim($_POST['name'] ?? '');
    $price = (float)($_POST['price'] ?? 0);
    $stock = (int)($_POST['stock'] ?? 0);
    $description = trim($_POST['description'] ?? '');
    $specifications_raw = trim($_POST['specifications'] ?? '');

    // Tạo slug
    $slug = slugify($name);

    if (empty($sku)) $errors[] = 'Mã SKU không được để trống.';
    if (empty($name)) $errors[] = 'Tên thiết bị không được để trống.';
    if ($price <= 0) $errors[] = 'Giá bán phải lớn hơn 0 VNĐ.';
    if ($stock < 0) $errors[] = 'Số lượng tồn kho không được âm.';

    // Kiểm tra trùng SKU
    $check_sku = $pdo->prepare("SELECT id FROM products WHERE sku = ? AND id != ?");
    $check_sku->execute([$sku, $id]);
    if ($check_sku->fetch()) {
        $errors[] = "Mã SKU '$sku' đã tồn tại trong hệ thống kho.";
    }

    // Xử lý specifications: Chuyển đổi định dạng Key: Value thành JSON nếu cần
    $specs_json = $specifications_raw;
    if (!empty($specifications_raw) && json_decode($specifications_raw) === null) {
        $lines = explode("\n", $specifications_raw);
        $specs_arr = [];
```

```
        foreach ($lines as $line) {
            $parts = explode(':', $line, 2);
            if (count($parts) === 2) {
                $specs_arr[trim($parts[0])] = trim($parts[1]);
            }
        }
        $specs_json = json_encode($specs_arr, JSON_UNESCAPED_UNICODE);
    }

    // TIÊU CHÍ D3: TẢI ẢNH AN TOÀN (DUNG LƯỢNG, NỘI DUNG ẢNH, ĐẶT TÊN NGẪU NHIÊN)
    $image_name = $product['image'];
    $uploaded_new_image = false;

    if (!empty($_FILES['image']['name'])) {
        $file = $_FILES['image'];
        $max_size = 2 * 1024 * 1024; // 2MB

        // 1. Giới hạn dung lượng
        if ($file['size'] > $max_size) {
            $errors[] = 'Dung lượng ảnh vượt quá giới hạn 2MB cho phép.';
        }

        // 2. Kiểm tra nội dung tệp thực tế (MIME Type an toàn)
        $allowed_mimes = ['image/jpeg', 'image/png', 'image/webp', 'image/svg+xml'];
        $finfo = finfo_open(FILEINFO_MIME_TYPE);
        $mime_type = finfo_file($finfo, $file['tmp_name']);
        finfo_close($finfo);

        if (!in_array($mime_type, $allowed_mimes)) {
            $errors[] = 'Tệp tải lên không phải là ảnh hợp lệ (Chỉ chấp nhận JPG, PNG, WEBP, SVG).';
        }

        // Kiểm tra an toàn đối với tệp SVG (Chống Stored XSS)
        if ($mime_type === 'image/svg+xml') {
            $svg_content = file_get_contents($file['tmp_name']);
            if (preg_match('/<script|onload|onerror|onclick|javascript:/i', $svg_content)) {
                $errors[] = 'Tệp SVG chứa mã script không an toàn và bị hệ thống từ chối tải lên.';
            }
        }

        // 3. Đặt tên ngẫu nhiên (UUID/uniqid)
        if (empty($errors)) {
            $ext = pathinfo($file['name'], PATHINFO_EXTENSION);
            if (empty($ext) || $ext === 'svg') $ext = 'svg';
            $image_name = uniqid('prod_', true) . '.' . strtolower($ext);
            $destination = UPLOAD_DIR . $image_name;

            if (move_uploaded_file($file['tmp_name'], $destination)) {
                $uploaded_new_image = true;
            } else {
                $errors[] = 'Không thể lưu tệp ảnh vào máy chủ.';
            }
        }
    }

    if (!$is_edit && empty($image_name)) {
        $errors[] = 'Vui lòng chọn ảnh cho sản phẩm mới.';
    }

    // Lưu dữ liệu vào CSDL
    if (empty($errors)) {
        if ($is_edit) {
            // TIÊU CHÍ D7: KHI SỬA VÀ TẢI ẢNH MỚI -> XÓA TỆP ẢNH CŨ TRONG UPLOADS/
            if ($uploaded_new_image && !empty($product['image']) && $product['image'] !== $image_name) {
                $old_file = UPLOAD_DIR . $product['image'];
                if (file_exists($old_file) && is_file($old_file)) {
                    unlink($old_file); // Xóa file ảnh cũ tránh rác ổ cứng
                }
            }
```

```
            $stmt = $pdo->prepare("
                UPDATE products
                SET category_id = ?, sku = ?, name = ?, slug = ?, price = ?, stock = ?, image = ?,
description = ?, specifications = ?
                WHERE id = ?
            ");
            $stmt->execute([$category_id, $sku, $name, $slug, $price, $stock, $image_name, $description,
$specs_json, $id]);
            set_flash('success', "Cập nhật thiết bị '{$name}' thành công!");
        } else {
            $stmt = $pdo->prepare("
                INSERT INTO products (category_id, sku, name, slug, price, stock, image, description,
specifications)
                VALUES (?, ?, ?, ?, ?, ?, ?, ?, ?)
            ");
            $stmt->execute([$category_id, $sku, $name, $slug, $price, $stock, $image_name, $description,
$specs_json]);
            set_flash('success', "Thêm sản phẩm mới '{$name}' vào kho thành công!");
        }

        header('Location: ' . BASE_URL . 'admin/products.php');
        exit;
    }
}

$categories = $pdo->query("SELECT * FROM categories ORDER BY id ASC")->fetchAll();

require_once __DIR__ . '/../includes/header.php';
?>

<!-- Thanh điều hướng phụ cho quản trị viên -->
<?php require_once __DIR__ . '/../includes/admin-nav.php'; ?>

<div class="container" style="padding-bottom: 5rem;">
    <div style="max-width: 800px; margin: 0 auto; background: var(--bg-surface); border: 1px solid var(--
border-subtle); border-radius: var(--radius-md); padding: 2.5rem; box-shadow: var(--shadow-card);">
        <div style="display: flex; justify-content: space-between; align-items: center; margin-bottom:
1.5rem;">
            <div>
                <span class="hero-tag" style="margin-bottom: 0.4rem;"><?= $is_edit ? 'CHỈNH SỬA SẢN PHẨM'
: 'THÊM MỚI SẢN PHẨM' ?></span>
                <h1 style="font-size: 1.6rem; font-weight: 800; color: var(--text-primary); margin: 0;">
                    <?= $is_edit ? 'Cập Nhật Thiết Bị: ' . e($product['name']) : 'Thêm Thiết Bị Vào Kho
Studio' ?>
                </h1>
            </div>
            <a href="<?= BASE_URL ?>admin/products.php" class="btn-icon" style="font-size: 0.8rem;
display: inline-flex; align-items: center; gap: 0.3rem;">
                <?= icon('arrow-left', '', 14) ?> Quay Lại Kho
            </a>
        </div>

        <?php if (!empty($errors)): ?>
            <div class="alert alert-danger">
                <span><?= icon('alert-triangle', '', 16) ?></span>
                <div>
                    <?php foreach ($errors as $err): ?>
                        <div><?= e($err) ?></div>
                    <?php endforeach; ?>
                </div>
            </div>
        <?php endif; ?>

        <!-- Form Thêm / Sửa Sản Phẩm (Tiêu chí D2, D3, D7) -->
        <form action="<?= BASE_URL ?>admin/product-form.php<?= $is_edit ? '?id=' . $product['id'] : '' ?>"
method="POST" enctype="multipart/form-data">
            <?= csrf_field() ?>
```

```
            <div style="display: grid; grid-template-columns: 1fr 1fr; gap: 1rem;">
                <div class="form-group">
                    <label class="form-label" for="prod-sku">Mã linh kiện (SKU): *</label>
                    <input type="text" id="prod-sku" name="sku" class="form-control" value="<?=
e($product['sku']) ?>" placeholder="VD: KB-8700-PRO" required>
                </div>

                <div class="form-group">
                    <label class="form-label" for="prod-cat">Phân hệ danh mục: *</label>
                    <select id="prod-cat" name="category_id" class="form-control">
                        <?php foreach ($categories as $cat): ?>
                            <option value="<?= $cat['id'] ?>" <?= $product['category_id'] == $cat['id'] ?
'selected' : '' ?>>
                                <?= e($cat['name']) ?>
                            </option>
                        <?php endforeach; ?>
                    </select>
                </div>
            </div>

            <div class="form-group">
                <label class="form-label" for="prod-name">Tên sản phẩm đầy đủ: *</label>
                <input type="text" id="prod-name" name="name" class="form-control" value="<?=
e($product['name']) ?>" placeholder="Tên sản phẩm thiết bị..." required>
            </div>

            <div style="display: grid; grid-template-columns: 1fr 1fr; gap: 1rem;">
                <div class="form-group">
                    <label class="form-label" for="prod-price">Giá niêm yết (VNĐ): *</label>
                    <input type="number" id="prod-price" name="price" class="form-control" value="<?=
e($product['price']) ?>" required min="1000">
                </div>

                <div class="form-group">
                    <label class="form-label" for="prod-stock">Số lượng tồn kho: *</label>
                    <input type="number" id="prod-stock" name="stock" class="form-control" value="<?=
e($product['stock']) ?>" required min="0">
                </div>
            </div>

            <!-- TIÊU CHÍ D3 & D7: TẢI ẢNH AN TOÀN -->
            <div class="form-group" style="background: #fafafc; border: 1px dashed var(--border-subtle);
border-radius: var(--radius-sm); padding: 1.5rem;">
                <label class="form-label" for="prod-img">
                    Hình ảnh sản phẩm (Tối đa 2MB, định dạng JPG, PNG, WEBP, SVG): <?= $is_edit ? '' : '*'
?>
                </label>
                <input type="file" id="prod-img" name="image" class="form-control" accept="image/*" <?=
$is_edit ? '' : 'required' ?> style="background: #ffffff;">

                <!-- Khung xem trước ảnh mới tải lên (Live Preview) -->
                <div id="preview-wrapper" style="margin-top: 1rem; display: flex; align-items: center;
gap: 1rem;">
                    <img id="prod-img-preview" src="#" alt="Xem trước ảnh" class="admin-thumb"
style="display: none; width: 70px; height: 70px; object-fit: contain; border: 2px solid var(--status-
live); padding: 4px;">
                </div>

                <?php if ($is_edit && !empty($product['image'])): ?>
                    <div style="display: flex; align-items: center; gap: 1rem; margin-top: 1rem;">
                        <img src="<?= BASE_URL ?>uploads/<?= e($product['image']) ?>" alt="Ảnh hiện tại"
class="admin-thumb" style="width: 60px; height: 60px;">
                        <div>
                            <div style="font-size: 0.82rem; font-weight: 600; color: var(--text-
primary);"><?= e($product['image']) ?></div>
                            <div style="font-size: 0.75rem; color: var(--text-muted);">Ảnh cũ sẽ tự động
được xóa khỏi máy chủ nếu bạn chọn ảnh mới.</div>
                        </div>
                    </div>
```

```
                <?php endif; ?>
            </div>

            <div class="form-group">
                <label class="form-label" for="prod-desc">Mô tả tổng quan sản phẩm:</label>
                <textarea id="prod-desc" name="description" rows="3" class="form-control" placeholder="Mô
tả các đặc điểm nổi bật..."><?= e($product['description']) ?></textarea>
            </div>

            <div class="form-group">
                <label class="form-label" for="prod-specs">
                    Bảng thông số kỹ thuật A2 (Mỗi dòng một cặp: <code>Tên thông số: Giá trị</code>):
                </label>
                <textarea id="prod-specs" name="specifications" rows="5" class="form-control" style="font-
family: var(--font-mono); font-size: 0.85rem; line-height: 1.6;" placeholder="Trọng lượng: 1.2 kg&#10;Kết
nối: USB-C, Bluetooth 5.3&#10;Bảo hành: 24 tháng"><?php
                    if (!empty($product['specifications'])) {
                        $decoded = json_decode($product['specifications'], true);
                        if (is_array($decoded)) {
                            foreach ($decoded as $k => $v) {
                                echo e($k . ': ' . $v) . "\n";
                            }
                        } else {
                            echo e($product['specifications']);
                        }
                    }
                ?></textarea>
            </div>

            <div style="display: flex; gap: 1rem; margin-top: 2rem;">
                <button type="submit" class="btn-action-primary" style="flex: 1; justify-content: center;
padding: 0.85rem; font-size: 0.95rem;">
                    <?= icon('save', '', 16) ?> <?= $is_edit ? 'Lưu Thay Đổi Sản Phẩm' : 'Thêm Vào Kho Sản
Phẩm' ?>
                </button>
                <a href="<?= BASE_URL ?>admin/products.php" class="btn-icon" style="padding: 0.85rem
1.5rem; display: inline-flex; align-items: center;">
                    Hủy Bỏ
                </a>
            </div>
        </form>
    </div>
</div>

<?php require_once __DIR__ . '/../includes/footer.php'; ?>
```

admin/product-delete.php

```
<?php
/**
 * XÓA SẢN PHẨM BẰNG PHƯƠNG THỨC POST (TIÊU CHÍ D1 & D2)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

require_once __DIR__ . '/../includes/init.php';

require_admin();

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $id = (int)($_POST['id'] ?? 0);

    // 1. Kiểm tra sản phẩm tồn tại
    $stmt = $pdo->prepare("SELECT * FROM products WHERE id = ?");
    $stmt->execute([$id]);
    $product = $stmt->fetch();
```

```
    if (!$product) {
        set_flash('danger', 'Không tìm thấy thiết bị cần xóa.');
        header('Location: ' . BASE_URL . 'admin/products.php');
        exit;
    }

    // TIÊU CHÍ D2: KHÔNG XÓA ĐƯỢC SẢN PHẨM ĐÃ CÓ TRONG ĐƠN HÀNG
    $check_orders = $pdo->prepare("SELECT COUNT(*) FROM order_items WHERE product_id = ?");
    $check_orders->execute([$id]);
    $in_orders_count = (int)$check_orders->fetchColumn();

    if ($in_orders_count > 0) {
        set_flash('danger', "BỊ CHẶN: Không thể xóa thiết bị '{$product['name']}' vì đã phát sinh trong
$in_orders_count đơn hàng của khách! (Ràng buộc dữ liệu Tiêu chí D2)");
        header('Location: ' . BASE_URL . 'admin/products.php');
        exit;
    }

    // 2. Xóa ảnh thiết bị trong uploads/ nếu có
    if (!empty($product['image'])) {
        $file_path = UPLOAD_DIR . $product['image'];
        if (file_exists($file_path) && is_file($file_path)) {
            unlink($file_path);
        }
    }

    // 3. Xóa sản phẩm khỏi CSDL
    $del_stmt = $pdo->prepare("DELETE FROM products WHERE id = ?");
    $del_stmt->execute([$id]);

    set_flash('success', "Đã xóa thiết bị '{$product['name']}' thành công khỏi hệ thống kho!");
}

header('Location: ' . BASE_URL . 'admin/products.php');
exit;
```

admin/categories.php

```
<?php
/**
 * QUẢN LÝ DANH MỤC THIẾT BỊ (TIÊU CHÍ D1 & D6)
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/../includes/init.php';

require_admin();

$page_title = 'Quản Lý Danh Mục Thiết Bị';
$errors = [];

// Xử lý các thao tác POST
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();
    $action = $_POST['action'] ?? '';

    // 1. TIÊU CHÍ D6: THÊM DANH MỤC MỚI
    if ($action === 'add') {
        $name = trim($_POST['name'] ?? '');
        $description = trim($_POST['description'] ?? '');
        $slug = slugify($name);

        if (empty($name)) {
            $errors[] = 'Tên danh mục không được để trống.';
        } else {
            $check = $pdo->prepare("SELECT id FROM categories WHERE slug = ?");
            $check->execute([$slug]);
```

```
            if ($check->fetch()) {
                $errors[] = 'Danh mục này đã tồn tại trong hệ thống.';
            } else {
                $stmt = $pdo->prepare("INSERT INTO categories (name, slug, description) VALUES (?, ?,
?)");
                $stmt->execute([$name, $slug, $description]);
                set_flash('success', "Thêm danh mục '{$name}' thành công!");
                header('Location: ' . BASE_URL . 'admin/categories.php');
                exit;
            }
        }
    }

    // 2. TIÊU CHÍ D6: ĐỔI TÊN DANH MỤC
    if ($action === 'edit') {
        $id = (int)($_POST['id'] ?? 0);
        $name = trim($_POST['name'] ?? '');
        $description = trim($_POST['description'] ?? '');
        $slug = slugify($name);

        if (empty($name)) {
            $errors[] = 'Tên danh mục không được để trống.';
        } else {
            $stmt = $pdo->prepare("UPDATE categories SET name = ?, slug = ?, description = ? WHERE id =
?");
            $stmt->execute([$name, $slug, $description, $id]);
            set_flash('success', "Đổi tên danh mục thành '{$name}' thành công!");
            header('Location: ' . BASE_URL . 'admin/categories.php');
            exit;
        }
    }

    // 3. TIÊU CHÍ D6: XÓA DANH MỤC (KHÔNG XÓA ĐƯỢC DANH MỤC ĐANG CÓ SẢN PHẨM)
    if ($action === 'delete') {
        $id = (int)($_POST['id'] ?? 0);

        // Kiểm tra số lượng sản phẩm đang thuộc danh mục này
        $check_prod = $pdo->prepare("SELECT COUNT(*) FROM products WHERE category_id = ?");
        $check_prod->execute([$id]);
        $prod_count = (int)$check_prod->fetchColumn();

        if ($prod_count > 0) {
            set_flash('danger', "BỊ CHẶN: Không thể xóa danh mục này vì đang chứa {$prod_count} sản phẩm!
Hãy chuyển hoặc xóa sản phẩm trước. (Ràng buộc toàn vẹn dữ liệu Tiêu chí D6)");
        } else {
            $del_stmt = $pdo->prepare("DELETE FROM categories WHERE id = ?");
            $del_stmt->execute([$id]);
            set_flash('success', 'Đã xóa danh mục thành công!');
        }
        header('Location: ' . BASE_URL . 'admin/categories.php');
        exit;
    }
}

// Lấy danh sách danh mục kèm số lượng sản phẩm
$query = "
    SELECT c.*, COUNT(p.id) AS product_count
    FROM categories c
    LEFT JOIN products p ON c.id = p.category_id
    GROUP BY c.id
    ORDER BY c.id ASC
";
$categories = $pdo->query($query)->fetchAll();

require_once __DIR__ . '/../includes/header.php';
?>

<!-- Thanh điều hướng phụ cho quản trị viên -->
<?php require_once __DIR__ . '/../includes/admin-nav.php'; ?>
```

```
<div class="container" style="padding-bottom: 5rem;">
    <!-- Tiêu đề trang -->
    <div style="margin-bottom: 2rem;">
        <span class="hero-tag" style="margin-bottom: 0.4rem;">CẤU TRÚC PHÂN LOẠI</span>
        <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary); margin: 0;">
            Quản Lý Danh Mục Thiết Bị
        </h1>
        <div style="font-size: 0.85rem; color: var(--text-secondary); margin-top: 0.25rem;">
            Tiêu chí D6: Thêm, đổi tên trực tiếp, và chặn xóa danh mục đang chứa sản phẩm
        </div>
    </div>

    <?php if (!empty($errors)): ?>
        <div class="alert alert-danger">
            <span><?= icon('alert-triangle', '', 16) ?></span>
            <div>
                <?php foreach ($errors as $err): ?>
                    <div><?= e($err) ?></div>
                <?php endforeach; ?>
            </div>
        </div>
    <?php endif; ?>

    <div style="display: grid; grid-template-columns: 1fr 2fr; gap: 2rem; align-items: flex-start;">

        <!-- Form Thêm Danh Mục Mới (Tiêu chí D6) -->
        <div style="background: var(--bg-surface); border: 1px solid var(--border-subtle); border-radius:
var(--radius-md); padding: 2rem; box-shadow: var(--shadow-card);">
            <h2 style="font-size: 1.15rem; font-weight: 700; color: var(--text-primary); margin-bottom:
1.25rem; display: flex; align-items: center; gap: 0.4rem;">
                <?= icon('plus', '', 16) ?> Thêm Danh Mục Mới
            </h2>

            <form action="<?= BASE_URL ?>admin/categories.php" method="POST">
                <?= csrf_field() ?>
                <input type="hidden" name="action" value="add">

                <div class="form-group">
                    <label class="form-label" for="cat-name">Tên danh mục mới: *</label>
                    <input type="text" id="cat-name" name="name" class="form-control" placeholder="VD: Phụ
Kiện Custom" required>
                </div>

                <div class="form-group">
                    <label class="form-label" for="cat-desc">Mô tả tóm tắt:</label>
                    <textarea id="cat-desc" name="description" rows="3" class="form-control"
placeholder="Mô tả tiêu chuẩn của phân hệ..."></textarea>
                </div>

                <button type="submit" class="btn-action-primary" style="width: 100%; justify-content:
center; padding: 0.8rem; font-size: 0.92rem; margin-top: 0.5rem;">
                    <?= icon('plus', '', 15) ?> Tạo Danh Mục
                </button>
            </form>
        </div>

        <!-- Danh sách danh mục & Đổi tên / Xóa (Tiêu chí D6) -->
        <div class="manifest-card" style="padding: 0; overflow: hidden;">
            <div style="padding: 1.25rem 1.5rem; border-bottom: 1px solid var(--border-subtle);
background: #fafafc;">
                <h2 style="font-size: 1.05rem; font-weight: 700; color: var(--text-primary); margin: 0;">
                    Các Phân Hệ Đang Hoạt Động (<?= count($categories) ?> danh mục)
                </h2>
            </div>

            <table class="cart-table" style="margin-bottom: 0;">
                <thead style="background: #fafafc;">
                    <tr>
```

```
                        <th style="padding-left: 1.5rem;">TÊN DANH MỤC / SLUG</th>
                        <th style="text-align: center;">SẢN PHẨM</th>
                        <th style="text-align: right; padding-right: 1.5rem;">THAO TÁC</th>
                    </tr>
                </thead>
                <tbody>
                    <?php foreach ($categories as $cat): ?>
                        <tr>
                            <td style="padding-left: 1.5rem;">
                                <!-- Form inline để đổi tên danh mục (Tiêu chí D6) -->
                                <form action="<?= BASE_URL ?>admin/categories.php" method="POST"
style="display: flex; gap: 0.5rem; align-items: center; margin: 0;">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="action" value="edit">
                                    <input type="hidden" name="id" value="<?= $cat['id'] ?>">
                                    <input type="text" name="name" value="<?= e($cat['name']) ?>"
class="form-control" style="padding: 0.4rem 0.75rem; font-size: 0.9rem; font-weight: 600; width: auto;
min-width: 180px;">
                                    <button type="submit" class="btn-icon" title="Lưu thay đổi tên"
style="font-size: 0.8rem; display: inline-flex; align-items: center; gap: 0.25rem;">
                                        <?= icon('save', '', 13) ?> Lưu
                                    </button>
                                </form>
                                <div style="font-family: var(--font-mono); font-size: 0.75rem; color:
var(--text-muted); margin-top: 0.25rem;">
                                    Đường dẫn slug: /<?= e($cat['slug']) ?>
                                </div>
                            </td>
                            <td style="text-align: center;">
                                <span class="badge-status badge-shipping">
                                    <?= $cat['product_count'] ?> sản phẩm
                                </span>
                            </td>
                            <td style="text-align: right; padding-right: 1.5rem;">
                                <!-- TIÊU CHÍ D6: XÓA DANH MỤC (CHẶN NẾU ĐANG CÓ SẢN PHẨM) -->
                                <form action="<?= BASE_URL ?>admin/categories.php" method="POST"
style="margin: 0; display: inline;">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="action" value="delete">
                                    <input type="hidden" name="id" value="<?= $cat['id'] ?>">
                                    <button type="submit"
                                            class="btn-icon"
                                            data-confirm="Bạn có chắc chắn muốn xóa danh mục '<?=
e($cat['name']) ?>' không?"
                                            style="color: var(--status-alert); border-color: rgba(239, 68,
68, 0.3); font-size: 0.8rem; display: inline-flex; align-items: center; gap: 0.25rem;"
                                            <?= $cat['product_count'] > 0 ? 'title="Danh mục đang có sản
phẩm (sẽ bị hệ thống chặn xóa)"' : 'title="Xóa danh mục"' ?>>
                                        <?= icon('trash', '', 13) ?> Xóa
                                    </button>
                                </form>
                            </td>
                        </tr>
                    <?php endforeach; ?>
                </tbody>
            </table>
        </div>

    </div>
</div>

<?php require_once __DIR__ . '/../includes/footer.php'; ?>
```

admin/orders.php

```
<?php
/**
 * QUẢN LÝ ĐƠN HÀNG TOÀN HỆ THỐNG (TIÊU CHÍ D1 & D4)
```

```
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 * Phong cách: Quiet Luxury & Minimalist Daylight
 */

require_once __DIR__ . '/../includes/init.php';

require_admin();

$page_title = 'Quản Lý Vận Đơn Khách Hàng';

// TIÊU CHÍ D4: ĐỔI TRẠNG THÁI ĐƠN HÀNG (HỖ TRỢ AJAX ZERO-RELOAD)
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf();

    $order_id = (int)($_POST['order_id'] ?? 0);
    $new_status = $_POST['status'] ?? '';
    $allowed_statuses = ['pending', 'shipping', 'completed', 'cancelled'];
    $is_ajax = !empty($_POST['ajax']);

    if ($order_id > 0 && in_array($new_status, $allowed_statuses)) {
        $stmt = $pdo->prepare("UPDATE orders SET status = ? WHERE id = ?");
        $stmt->execute([$new_status, $order_id]);

        $status_labels = [
            'pending' => 'Chờ xử lý',
            'shipping' => 'Đang giao',
            'completed' => 'Hoàn tất',
            'cancelled' => 'Đã hủy'
        ];
        $label = $status_labels[$new_status] ?? $new_status;

        if ($is_ajax) {
            header('Content-Type: application/json');
            echo json_encode([
                'success' => true,
                'order_id' => $order_id,
                'status' => $new_status,
                'label' => $label,
                'message' => "Đã chuyển trạng thái đơn #{$order_id} sang '{$label}' thành công!"
            ]);
            exit;
        }

        set_flash('success', "Đã cập nhật trạng thái đơn hàng sang '$label' thành công!");
        header('Location: ' . BASE_URL . 'admin/orders.php');
        exit;
    }
}

// TIÊU CHÍ D4: LỌC THEO TRẠNG THÁI & TÌM KIẾM ĐƠN HÀNG
$filter_status = $_GET['status'] ?? 'all';
$search_q = trim($_GET['q'] ?? '');
$where_clauses = ['1=1'];
$params = [];

if (in_array($filter_status, ['pending', 'shipping', 'completed', 'cancelled'])) {
    $where_clauses[] = 'o.status = ?';
    $params[] = $filter_status;
}

if (!empty($search_q)) {
    $where_clauses[] = '(o.order_code LIKE ? OR o.recipient_name LIKE ? OR o.recipient_phone LIKE ?)';
    $like = '%' . $search_q . '%';
    $params[] = $like;
    $params[] = $like;
    $params[] = $like;
}

$where = implode(' AND ', $where_clauses);
```

```
$stmt = $pdo->prepare("
    SELECT o.*, u.email AS user_email
    FROM orders o
    LEFT JOIN users u ON o.user_id = u.id
    WHERE $where
    ORDER BY o.id DESC
");
$stmt->execute($params);
$orders = $stmt->fetchAll();

require_once __DIR__ . '/../includes/header.php';
?>

<!-- Thanh điều hướng phụ cho quản trị viên -->
<?php require_once __DIR__ . '/../includes/admin-nav.php'; ?>

<div class="container" style="padding-bottom: 5rem;">
    <!-- Tiêu đề trang & Bộ lọc trạng thái (Tiêu chí D4) -->
    <div style="display: flex; justify-content: space-between; align-items: flex-end; margin-bottom: 2rem;
flex-wrap: wrap; gap: 1rem;">
        <div>
            <span class="hero-tag" style="margin-bottom: 0.4rem;">QUẢN LÝ VẬN ĐƠN</span>
            <h1 style="font-size: 1.85rem; font-weight: 800; color: var(--text-primary); margin: 0;">
                Danh Sách Đơn Đặt Hàng
            </h1>
            <div style="font-size: 0.85rem; color: var(--text-secondary); margin-top: 0.25rem;">
                Hiện có <strong><?= count($orders) ?></strong> đơn trong danh mục hiển thị
            </div>
        </div>

        <!-- TIÊU CHÍ D4: BỘ LỌC THEO TRẠNG THÁI ĐƠN & TÌM KIẾM -->
        <div style="display: flex; gap: 1rem; align-items: center; flex-wrap: wrap;">
            <form action="<?= BASE_URL ?>admin/orders.php" method="GET" class="search-form" style="margin:
0;">
                <?php if ($filter_status !== 'all'): ?>
                    <input type="hidden" name="status" value="<?= e($filter_status) ?>">
                <?php endif; ?>
                <input type="text" name="q" value="<?= e($search_q) ?>" placeholder="Mã đơn, tên, SĐT..."
class="search-input" style="padding: 0.45rem 0.85rem; font-size: 0.82rem; min-width: 180px;">
                <?php if (!empty($search_q)): ?>
                    <button type="button" class="search-clear-btn" title="Xóa tìm kiếm"><?= icon('x', 'no-
margin', 14) ?></button>
                <?php endif; ?>
                <button type="submit" class="search-btn" title="Tìm đơn"><?= icon('search', 'no-margin',
14) ?></button>
            </form>

            <div class="category-pills" style="margin: 0; padding-bottom: 0;">
                <a href="<?= BASE_URL ?>admin/orders.php<?= !empty($search_q) ? '?q=' .
urlencode($search_q) : '' ?>" class="cat-pill <?= $filter_status === 'all' ? 'active' : '' ?>">
                    Tất Cả
                </a>
                <a href="<?= BASE_URL ?>admin/orders.php?status=pending<?= !empty($search_q) ? '&q=' .
urlencode($search_q) : '' ?>" class="cat-pill <?= $filter_status === 'pending' ? 'active' : '' ?>">
                    <?= icon('clock', '', 13) ?> Chờ Xử Lý
                </a>
                <a href="<?= BASE_URL ?>admin/orders.php?status=shipping<?= !empty($search_q) ? '&q=' .
urlencode($search_q) : '' ?>" class="cat-pill <?= $filter_status === 'shipping' ? 'active' : '' ?>">
                    <?= icon('truck', '', 13) ?> Đang Giao
                </a>
                <a href="<?= BASE_URL ?>admin/orders.php?status=completed<?= !empty($search_q) ? '&q=' .
urlencode($search_q) : '' ?>" class="cat-pill <?= $filter_status === 'completed' ? 'active' : '' ?>">
                    <?= icon('check-circle', '', 13) ?> Hoàn Tất
                </a>
                <a href="<?= BASE_URL ?>admin/orders.php?status=cancelled<?= !empty($search_q) ? '&q=' .
urlencode($search_q) : '' ?>" class="cat-pill <?= $filter_status === 'cancelled' ? 'active' : '' ?>">
                    <?= icon('x-circle', '', 13) ?> Đã Hủy
                </a>
```

```
            </div>
        </div>
    </div>

    <!-- Danh sách đơn hàng -->
    <div class="manifest-card" style="padding: 0; overflow: hidden;">
        <div class="table-responsive">
            <table class="cart-table" style="margin-bottom: 0;">
            <thead style="background: #fafafc;">
                <tr>
                    <th style="padding-left: 1.5rem;">MÃ ĐƠN</th>
                    <th>NGÀY TẠO</th>
                    <th>NGƯỜI NHẬN / LIÊN LẠC</th>
                    <th>ĐỊA CHỈ GIAO HÀNG</th>
                    <th>TỔNG TIỀN</th>
                    <th>CẬP NHẬT TRẠNG THÁI (D4)</th>
                    <th style="text-align: right; padding-right: 1.5rem;">CHI TIẾT</th>
                </tr>
            </thead>
            <tbody>
                <?php if (empty($orders)): ?>
                    <tr>
                        <td colspan="7" style="text-align: center; padding: 3rem; color: var(--text-
muted);">
                            Chưa có đơn hàng nào trong trạng thái này.
                        </td>
                    </tr>
                <?php else: ?>
                    <?php foreach ($orders as $ord): ?>
                        <tr>
                            <td style="padding-left: 1.5rem; font-family: var(--font-mono); font-size:
0.85rem; font-weight: 700; color: var(--text-primary);">
                                <?= e($ord['order_code']) ?>
                            </td>
                            <td style="font-size: 0.82rem; color: var(--text-secondary);">
                                <?= date('d/m/Y H:i', strtotime($ord['created_at'])) ?>
                            </td>
                            <td>
                                <div style="font-weight: 600; font-size: 0.92rem; color: var(--text-
primary);"><?= e($ord['recipient_name']) ?></div>
                                <div style="font-size: 0.75rem; color: var(--text-muted); font-family:
var(--font-mono);">
                                    <?= e($ord['recipient_phone']) ?> · <?= e($ord['user_email'] ?? '') ?>
                                </div>
                            </td>
                            <td style="font-size: 0.85rem; color: var(--text-secondary); max-width: 220px;
line-height: 1.4;">
                                <?= e($ord['shipping_address']) ?>
                            </td>
                            <td style="font-weight: 700; color: var(--text-primary);">
                                <?= format_currency($ord['total_amount']) ?>
                            </td>
                            <td>
                                <!-- TIÊU CHÍ D4: FORM ĐỔI TRẠNG THÁI TRỰC TIẾP -->
                                <form action="<?= BASE_URL ?>admin/orders.php" method="POST"
style="margin: 0; display: flex; align-items: center; gap: 0.4rem;">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="order_id" value="<?= $ord['id'] ?>">
                                    <select name="status" class="sort-select" style="padding: 0.35rem
0.75rem; font-size: 0.82rem; font-weight: 600;" onchange="this.form.submit();">
                                        <option value="pending" <?= $ord['status'] === 'pending' ?
'selected' : '' ?>>Chờ xử lý</option>
                                        <option value="shipping" <?= $ord['status'] === 'shipping' ?
'selected' : '' ?>>Đang giao</option>
                                        <option value="completed" <?= $ord['status'] === 'completed' ?
'selected' : '' ?>>Hoàn tất</option>
                                        <option value="cancelled" <?= $ord['status'] === 'cancelled' ?
'selected' : '' ?>>Đã hủy</option>
                                    </select>
```

```
                                </form>
                            </td>
                            <td style="text-align: right; padding-right: 1.5rem;">
                                <a href="<?= BASE_URL ?>order-detail.php?id=<?= $ord['id'] ?>" class="btn-
icon" target="_blank" title="Xem chi tiết vận đơn" style="font-size: 0.8rem; display: inline-flex; align-
items: center; gap: 0.25rem;">
                                    <?= icon('eye', '', 13) ?> Chi Tiết
                                </a>
                            </td>
                        </tr>
                    <?php endforeach; ?>
                <?php endif; ?>
            </tbody>
        </table>
        </div>
    </div>
</div>

<?php require_once __DIR__ . '/../includes/footer.php'; ?>
```

.htaccess (thư mục gốc)

```
# ==============================================================================
# BẢO VỆ THƯ MỤC & CẤU HÌNH GỐC (TIÊU CHÍ D5)
# Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
# ==============================================================================

# Chặn trực tiếp truy cập vào các thư mục nhạy cảm
RewriteEngine On

RewriteRule ^config/ - [F,L]
RewriteRule ^includes/ - [F,L]
RewriteRule ^database/ - [F,L]

# Trang báo lỗi 404 riêng (Tiêu chí D5)
ErrorDocument 404 /404.php
ErrorDocument 403 /404.php

# Bảo vệ các tệp ẩn và tệp cấu hình
<FilesMatch "^\.">
    Order allow,deny
    Deny from all
</FilesMatch>

<FilesMatch "(composer\.json|package\.json|schema\.sql|\.env|\.sqlite|\.sqlite3|\.db)$">
    Order allow,deny
    Deny from all
</FilesMatch>
```

config/.htaccess, includes/.htaccess, database/.htaccess (giống nhau thì dán một lần)

```
# Chặn truy cập trực tiếp từ trình duyệt (Tiêu chí D5)
Order Deny,Allow
Deny from all
```

uploads/.htaccess

```
# CẤM CHẠY SCRIPT PHP TRONG THƯ MỤC UPLOADS (TIÊU CHÍ D3 & BẢO MẬT HỆ THỐNG)
<FilesMatch "\.(php|php3|php4|php5|phtml|pl|py|jsp|asp|htm|shtml|sh|cgi)$">
    Order Deny,Allow
    Deny from all
</FilesMatch>

# Vô hiệu hóa PHP Engine nếu chạy mod_php
<IfModule mod_php.c>
    php_flag engine off
</IfModule>
```

```
<IfModule mod_php7.c>
    php_flag engine off
</IfModule>
<IfModule mod_php8.c>
    php_flag engine off
</IfModule>
```

8.7. Tệp phát sinh thêm

STT	Đường dẫn tệp	Vai trò
1	quick-login.php	Hỗ trợ đăng nhập nhanh 1-click vào tài khoản Khách hàng hoặc Admin để thầy chấm bài và kiểm thử nhanh
2	database/verify_security_and_assets.php	Bộ kiểm thử tự động 15 tiêu chí an toàn (CSRF, XSS Headers, .htaccess, 12 ảnh thực tế)
3	README.md	Tài liệu hướng dẫn tổng quan đồ án, bảng tiêu chí và cách chạy trên PHP Built-in Server / XAMPP

Khung mẫu, chép cho mỗi tệp phát sinh:

quick-login.php

```
<?php
/**
 * ĐĂNG NHẬP NHANH PHỤC VỤ TRÌNH DIỄN & CHẤM THI
 * Sinh viên: Lâm Nhựt Hải Đăng - MSSV: N25DTCN007
 */

require_once __DIR__ . '/includes/init.php';

$as = $_GET['as'] ?? 'customer';

if ($as === 'admin') {
    $stmt = $pdo->prepare("SELECT * FROM users WHERE role = 'admin' LIMIT 1");
    $stmt->execute();
    $user = $stmt->fetch();

    if ($user) {
        session_regenerate_id(true);
        $_SESSION['user'] = [
            'id'      => $user['id'],
            'name'    => $user['name'],
            'email'   => $user['email'],
            'phone'   => $user['phone'],
            'address' => $user['address'],
            'role'    => $user['role']
        ];
        set_flash('success', 'Đã tự động đăng nhập với tư cách Quản trị viên: ' . $user['name']);
        header('Location: ' . BASE_URL . 'admin/index.php');
        exit;
    }
} else {
    $stmt = $pdo->prepare("SELECT * FROM users WHERE role = 'customer' LIMIT 1");
```

```
    $stmt->execute();
    $user = $stmt->fetch();

    if ($user) {
        session_regenerate_id(true);
        $_SESSION['user'] = [
            'id'      => $user['id'],
            'name'    => $user['name'],
            'email'   => $user['email'],
            'phone'   => $user['phone'],
            'address' => $user['address'],
            'role'    => $user['role']
        ];
        set_flash('success', 'Đã tự động đăng nhập với tư cách Khách hàng: ' . $user['name']);
        header('Location: ' . BASE_URL);
        exit;
    }
}

header('Location: ' . BASE_URL);
exit;
```

database/verify_security_and_assets.php

```
<?php
/**
 * Automated Verification Script for Lâm Nhựt Hải Đăng // Studio & Boutique
 * Tests:
 * 1. Database & 12 real product images verification
 * 2. Security headers check via curl
 * 3. CSRF enforcement test on cart-update.php
 * 4. Open-redirect prevention check on login.php
 * 5. Emoji audit across all views
 * 6. Rate-limit and session protection verification
 * 7. PHP Syntax Linting across all views
 * 8. Voucher Discount calculation check
 * 9. Icon vector system checks (including new arrow-up)
 */

require_once __DIR__ . '/../includes/init.php';

echo "=========================================================\n";
echo "   LÂM NHỰT HẢI ĐĂNG (N25DTCN007) - QA TEST SUITE\n";
echo "=========================================================\n\n";

$passCount = 0;
$failCount = 0;

function assertTest($name, $condition, $details = '') {
    global $passCount, $failCount;
    if ($condition) {
        echo "[PASS] " . $name . "\n";
        $passCount++;
    } else {
        echo "[FAIL] " . $name . ($details ? " - " . $details : "") . "\n";
        $failCount++;
    }
}

// 1. Verify Database Products and Images
$stmt = $pdo->query("SELECT id, name, image FROM products ORDER BY id ASC");
$products = $stmt->fetchAll();

assertTest("Product count matches 12 items", count($products) === 12, "Found: " . count($products));
```

```
$missingImages = [];
$smallImages = [];
foreach ($products as $p) {
    $imgFile = $p['image'];
    $fullPath = __DIR__ . '/../uploads/' . $imgFile;
    if (!file_exists($fullPath)) {
        $missingImages[] = $p['name'] . " (" . $imgFile . ")";
    } else {
        $size = filesize($fullPath);
        if ($size < 10240) { // < 10KB
            $smallImages[] = $p['name'] . " (" . $size . " bytes)";
        }
    }
}

assertTest("All 12 product photos exist in uploads/ directory", empty($missingImages), implode(', ',
$missingImages));
assertTest("All 12 product photos are real high-res images (>10KB)", empty($smallImages), implode(', ',
$smallImages));

// 2. HTTP Security Headers Check
$ch = curl_init('http://127.0.0.1:8080/');
curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
curl_setopt($ch, CURLOPT_HEADER, true);
curl_setopt($ch, CURLOPT_NOBODY, true);
$headers = curl_exec($ch);
curl_close($ch);

assertTest("Header: X-Frame-Options is SAMEORIGIN", stripos($headers, 'X-Frame-Options: SAMEORIGIN') !==
false);
assertTest("Header: X-Content-Type-Options is nosniff", stripos($headers, 'X-Content-Type-Options:
nosniff') !== false);
assertTest("Header: Referrer-Policy is strict-origin-when-cross-origin", stripos($headers, 'Referrer-
Policy: strict-origin-when-cross-origin') !== false);
assertTest("Header: X-XSS-Protection is enabled", stripos($headers, 'X-XSS-Protection: 1; mode=block') !==
false);
assertTest("Header: Permissions-Policy is set", stripos($headers, 'Permissions-Policy: camera=(),
microphone=(), geolocation=()') !== false);

// 3. CSRF Rejection on cart-update.php without token
$ch = curl_init('http://127.0.0.1:8080/cart-update.php');
curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
curl_setopt($ch, CURLOPT_POST, true);
curl_setopt($ch, CURLOPT_POSTFIELDS, http_build_query([
    'action' => 'add',
    'product_id' => 1,
    'quantity' => 1,
    'ajax' => 1
]));
$response = curl_exec($ch);
$httpCode = curl_getinfo($ch, CURLINFO_HTTP_CODE);
curl_close($ch);

assertTest("CSRF Protection: POST to cart-update.php without CSRF token returns 403 Forbidden", $httpCode
=== 403, "Returned HTTP " . $httpCode);

// 4. Emoji scan across template files
$filesToScan = [
    'includes/header.php',
    'includes/footer.php',
    'includes/admin-nav.php',
    'index.php',
    'product.php',
    'cart.php',
```

```
    'checkout.php',
    'orders.php',
    'order-detail.php',
    'contact.php',
    'login.php',
    'register.php',
    'profile.php',
    'change-password.php',
    'admin/index.php',
    'admin/products.php',
    'admin/categories.php',
    'admin/orders.php',
    '404.php'
];

$emojiRegex = '/[\x{1F300}-\x{1F64F}\x{1F680}-\x{1F6FF}\x{2600}-\x{26FF}\x{2700}-\x{27BF}\x{1F900}-
\x{1F9FF}\x{1F1E0}-\x{1F1FF}]/u';

$filesWithEmojis = [];
$syntaxErrors = [];
foreach ($filesToScan as $relPath) {
    $fullPath = __DIR__ . '/../' . $relPath;
    if (file_exists($fullPath)) {
        $content = file_get_contents($fullPath);
        if (preg_match_all($emojiRegex, $content, $matches)) {
            $filesWithEmojis[$relPath] = array_unique($matches[0]);
        }
    }
}

assertTest("Clean Visuals: Zero OS emojis across all user & admin UI views", empty($filesWithEmojis),
json_encode($filesWithEmojis));

// 5. SVG icon helper verification
assertTest("icon('arrow-up') helper generates valid SVG markup", strpos(icon('arrow-up'), '<svg') !==
false && strpos(icon('arrow-up'), '</svg>') !== false);

// 6. Direct Database file protection in .htaccess
$htaccess = file_get_contents(__DIR__ . '/../.htaccess');
assertTest(".htaccess protects .sqlite and database files from direct download", strpos($htaccess,
'\.sqlite') !== false);

// 7. Voucher Discount calculation test
$baseAmount = 1000000; // 1.000.000d
$ptitDiscount = round($baseAmount * 0.10);
$haidangDiscount = round($baseAmount * 0.15);
assertTest("Voucher PTIT2026 calculates correct 10% discount", $ptitDiscount === 100000.0);
assertTest("Voucher HAIDANG calculates correct 15% discount", $haidangDiscount === 150000.0);

// 8. Admin order search query test
$searchStmt = $pdo->prepare("SELECT COUNT(*) FROM orders WHERE order_code LIKE ? OR recipient_name LIKE
?");
$searchStmt->execute(['%ORD%', '%Khách%']);
$foundCount = (int)$searchStmt->fetchColumn();
assertTest("Admin Order Search query executes cleanly on Database", $foundCount >= 0);

echo "\n------------------------------------------------------------\n";
echo "SUMMARY: " . $passCount . " PASSED, " . $failCount . " FAILED\n";
echo "============================================================\n";

if ($failCount > 0) {
    exit(1);
}
```

```
exit(0);
```

README.md

```
# ĐỒ ÁN CUỐI KỲ – MÔN LẬP TRÌNH WEB
### HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG (PTIT)
> **Giảng viên hướng dẫn**: Thầy Lê Nhật Tùng (`@Le Nhat Tung`)
> **Sinh viên thực hiện**: Lâm Nhựt Hải Đăng
> **Mã số sinh viên (MSSV)**: `N25DTCN007`
> **Thương hiệu cá nhân hóa**: **LÂM NHỰT HẢI ĐĂNG // STUDIO & BOUTIQUE**
> **Công nghệ**: HTML5, CSS3 thuần (No Framework), JavaScript ES6+ thuần, PHP 8.2+ thuần (No Framework), Dual-Driver Database (MySQL PDO / SQLite PDO fallback).

---

## 📌 1. Giới thiệu tổng quan dự án

Website thương mại điện tử chuyên cung cấp thiết bị phần cứng, studio & đồ công nghệ cao cấp (**LÂM NHỰT HẢI ĐĂNG // STUDIO & BOUTIQUE**), được xây dựng theo triết lý thiết kế **Quiet Luxury & Minimalist Daylight** (lấy cảm hứng từ Apple Store, Bang & Olufsen, Leica).

Toàn bộ hệ thống được viết hoàn toàn bằng **mã nguồn thuần (Vanilla)**, tuân thủ nghiêm ngặt tiêu chuẩn bảo mật hiện đại (OWASP), trải nghiệm Zero-Reload (mượt mà như Single Page App) và đáp ứng 100% yêu cầu đề thi của Học viện.

---

## 🎯 2. Đáp ứng 6 Điều kiện Cá nhân hóa bắt buộc (100%)

1. **Tên cửa hàng**: `LÂM NHỰT HẢI ĐĂNG // STUDIO & BOUTIQUE` hiển thị đồng bộ trên Header, Hero Banner và Footer của tất cả các trang.
2. **Logo cửa hàng**: Khung tròn viền bạch kim sang trọng với ảnh chân dung sinh viên Lâm Nhựt Hải Đăng có chấm xanh trạng thái Studio (`live-badge`) trên 100% trang khách hàng và trang quản trị.
3. **Chân trang (Footer)**: In rõ định danh pháp lý: `MSSV: N25DTCN007 – Họ và tên: Lâm Nhựt Hải Đăng – Lập trình Web PTIT` trên toàn bộ 15 trang web.
4. **Bảng màu riêng biệt**: Hệ thống Design Tokens CSS `:root` tại `css/style.css` với gam màu ngọc trai ấm `#fafafc`, đen than `#111827`, và vàng champagne `#c5a059`.
5. **Dữ liệu mẫu thực tế**:
   - 4 danh mục sản phẩm cao cấp.
   - 12 sản phẩm phần cứng với ảnh chụp studio độ phân giải cao và mô tả chi tiết.
   - 3 tài khoản người dùng (bao gồm quản trị viên `admin`).
   - 5 đơn hàng ở đầy đủ các trạng thái (`pending`, `shipping`, `completed`, `cancelled`).
6. **Mã nguồn tự phát triển**: Tự tay thiết kế và lập trình 100% mã nguồn, không sử dụng framework dựng sẵn (Bootstrap, Tailwind, Laravel, WordPress...).

---

## 🚀 3. Tính năng nổi bật & Trải nghiệm Zero-Reload

* **Bộ lọc và Danh mục tức thì (Zero-Reload Catalog)**: Lọc danh mục, tìm kiếm và sắp xếp giá trực tiếp bằng Fetch API + `DOMParser` + `history.pushState`, không chớp trắng màn hình hay tải lại trang.
* **Giỏ hàng mượt mà (Smooth Cart UX)**: Nút stepper số lượng `[-] [ 1 ] [+]` 44px chuẩn công thái học; xóa từng món hàng với hiệu ứng trượt mờ (`slide-out`) trong 250ms; cập nhật số lượng badge trên Header ngay lập tức.
* **Mua ngay 1 chạm (Express Checkout)**: Nút `Mua Ngay` đưa thẳng sản phẩm vào giỏ và chuyển đến trang thanh toán.
* **Mã giảm giá trực quan (Live Voucher Coupon)**: Hỗ trợ mã voucher (`PTIT2026` -10%, `HAIDANG` -15%) trừ tiền tức thì và cập nhật VietQR động trước mắt người dùng.
* **Thanh toán VietQR động**: Tự sinh mã QR ngân hàng Quân Đội (MB Bank) đúng số tiền sau khi áp dụng mã giảm giá và nội dung chuyển khoản chuẩn theo mã đơn hàng.
* **Theo dõi & In phiếu đơn hàng**: Thanh tiến trình đơn hàng trực quan 4 bước (`Chờ xử lý` ➔ `Đang giao` ➔ `Hoàn tất`); tích hợp nút in hóa đơn giao hàng chuẩn khổ giấy A4 (`@media print`).
```

* **Hệ thống Icon Vector Nội bộ**: Hơn 25 biểu tượng SVG nét mảnh 1.5px (Lucide Style) sinh trực tiếp qua hàm `icon()`, không phụ thuộc mạng CDN, tải 0ms.

🛡️ 4. Kiến trúc Bảo mật chuyên sâu (OWASP Hardening)

* **HTTP Security Headers**: Cấu hình toàn diện tại `includes/init.php` (`X-Frame-Options: SAMEORIGIN`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `X-XSS-Protection`, `Permissions-Policy`).
* **Phòng chống tấn công CSRF**: Cơ chế CSRF Token kiểm tra chặt chẽ trên toàn bộ các phương thức `POST` và Ajax request.
* **Bảo vệ CSDL & Chống SQL Injection**: Sử dụng 100% **PDO Prepared Statements** kết hợp tham số hóa; không bao giờ ghép chuỗi dữ liệu thô vào câu truy vấn.
* **Chống rò rỉ dữ liệu qua URL (IDOR)**: Kiểm tra nghiêm ngặt quyền sở hữu đơn hàng trước khi cho phép xem chi tiết hoặc hủy đơn.
* **Chống leo thang đặc quyền**: Hàm `require_admin()` kiểm tra phân quyền đầu trang quản trị; người dùng thường truy cập bị chặn với mã HTTP `403 Forbidden`.
* **Giới hạn số lần đăng nhập (Rate Limiting)**: Tạm khóa đăng nhập 5 phút nếu nhập sai mật khẩu liên tiếp 5 lần.
* **Phòng chống Open Redirect**: Whitelist và xác thực an toàn tham số `return_to` sau khi đăng nhập.
* **Bảo vệ tệp tin nhạy cảm**: Tệp `.htaccess` cấm hoàn toàn việc truy cập trực tiếp từ trình duyệt vào các thư mục `config/`, `includes/`, `database/` và các tệp CSDL SQLite.

📁 5. Cấu trúc thư mục dự án

```text
├── admin/                          # Phân hệ quản trị viên (Admin Panel)
│   ├── index.php                   # Dashboard thống kê doanh thu, đơn hàng, tồn kho
│   ├── products.php                # Quản lý sản phẩm (danh sách, phân trang, xóa)
│   ├── product-form.php            # Thêm/Sửa sản phẩm kèm tải ảnh an toàn
│   ├── categories.php              # Quản lý danh mục sản phẩm
│   ├── orders.php                  # Quản lý & cập nhật trạng thái đơn hàng (Ajax)
│   └── order-detail.php            # Xem chi tiết đơn hàng
├── config/                         # Cấu hình hệ thống
│   ├── config.php                  # Biến môi trường, múi giờ, hằng số bảo mật
│   └── db.php                      # Kết nối CSDL PDO (Hỗ trợ kép MySQL & SQLite)
├── css/                            # Bảng định kiểu giao diện
│   └── style.css                   # CSS thuần, biến màu :root, Responsive Flexbox & Grid
├── database/                       # Cơ sở dữ liệu & Kiểm thử
│   ├── final_web.sqlite            # CSDL SQLite chạy ngay lập tức không cần cài đặt
│   └── verify_security_and_assets.php # Bộ kiểm thử tự động 15 tiêu chí an toàn & dữ liệu
├── includes/                       # Các thành phần giao diện & hàm dùng chung
│   ├── init.php                    # Khởi tạo session an toàn, CSRF token, HTTP headers
│   ├── functions.php               # Hàm sinh vector icon, kiểm tra auth, format tiền tệ
│   ├── header.php                  # Header dùng chung, logo cá nhân hóa, thanh điều hướng
│   └── footer.php                  # Footer định danh MSSV và Họ tên sinh viên
├── js/                             # JavaScript xử lý nghiệp vụ & tương tác
│   ├── app.js                      # Trình nghe sự kiện, xác thực form, Ajax catalog & cart
│   └── auth.js                     # Kiểm tra độ khớp mật khẩu, ẩn/hiện mật khẩu
├── uploads/                        # Thư mục lưu trữ hình ảnh sản phẩm & avatar
├── 404.php                         # Trang báo lỗi 404 tùy biến
├── about.php                       # Trang giới thiệu thông tin sinh viên & cửa hàng
├── cart.php                        # Giỏ hàng mua sắm
├── checkout.php                    # Trang thanh toán & sinh VietQR
├── contact.php                     # Trang liên hệ lưu tin nhắn vào CSDL
├── index.php                       # Trang chủ trưng bày sản phẩm & bộ lọc danh mục
├── login.php                       # Trang đăng nhập
├── order-detail.php                # Chi tiết đơn hàng, thanh tiến trình & in hóa đơn
├── orders.php                      # Lịch sử đơn hàng của người dùng
├── product.php                     # Trang chi tiết sản phẩm & thông số kỹ thuật
├── profile.php                     # Cập nhật hồ sơ cá nhân
```

```
├── quick-login.php               # Đăng nhập nhanh 1-click phục vụ kiểm thử
├── register.php                  # Trang đăng ký tài khoản
├── N25DTCN007_LamNhutHaiDang_Database.sql # Tệp CSDL MySQL/MariaDB chuẩn nộp bài
└── README.md                     # Tài liệu hướng dẫn đồ án
```

💻 6. Hướng dẫn cài đặt & Khởi chạy

Cách 1: Chạy ngay lập tức bằng PHP Built-in Server (Khuyên dùng)
Dự án được tích hợp sẵn CSDL SQLite độc lập, bạn có thể chạy website ngay mà không cần cài đặt XAMPP hay cấu hình MySQL:

1. Mở terminal hoặc PowerShell tại thư mục dự án:
   ```powershell
   php -S 127.0.0.1:8080
   ```
2. Mở trình duyệt và truy cập: **`http://127.0.0.1:8080/`**

Cách 2: Chạy trên XAMPP / WampServer (MySQL)
1. Copy toàn bộ thư mục vào `C:\xampp\htdocs\final_web`.
2. Mở `phpMyAdmin` (`http://localhost/phpmyadmin`), tạo cơ sở dữ liệu mới tên là: `final_web`.
3. Import tệp **`N25DTCN007_LamNhutHaiDang_Database.sql`** vào cơ sở dữ liệu vừa tạo.
4. Mở file `config/db.php` để kiểm tra kết nối MySQL (mặc định user: `root`, pass: rỗng).
5. Mở trình duyệt và truy cập: **`http://localhost/final_web/`**

🔑 7. Tài khoản kiểm thử nghiệm thu

Loại tài khoản	Email đăng nhập	Mật khẩu	Liên kết đăng nhập nhanh 1-click
Quản trị viên (Admin)	`admin@lab.ptit.edu.vn`	`admin123`	`http://127.0.0.1:8080/quick-login.php?as=admin`
Khách hàng mẫu	`khachhang1@gmail.com`	`customer123`	`http://127.0.0.1:8080/quick-login.php?as=customer`

⏳ 8. Kết quả kiểm thử tự động (QA Automated Verification)

Hệ thống tích hợp script kiểm thử tự động
[`database/verify_security_and_assets.php`](database/verify_security_and_assets.php):
* **Tổng số bài kiểm tra**: 15/15 bài đạt chuẩn **PASS (0 FAILED)**.
* **Kiểm tra dữ liệu**: 100% đủ danh mục, sản phẩm và ảnh chụp sắc nét thực tế.
* **Kiểm tra bảo mật**: 100% bảo vệ CSRF, chặn truy cập trực tiếp file dữ liệu và khóa HTTP Headers.

9. Triển khai hosting (nếu có)

Không triển khai thì ghi "Không triển khai" và bỏ qua mục này.

Mục	Nội dung
Địa chỉ website	https://haidang-boutique.infinityfreeapp.com (hoặc Không có nếu chưa triển khai)
Nhà cung cấp hosting và loại panel	InfinityFree (Control Panel

Mục	Nội dung
	vPanel)
Có HTTPS (biểu tượng ổ khóa)	Có
APP_DEBUG trên hosting	false
BASE_URL trên hosting	https://haidang-boutique.infinityfreeapp.com/

[Chèn ảnh website chạy trên địa chỉ thật: thấy thanh địa chỉ có https, tên cửa hàng và logo]

[Chèn ảnh trang quản lý cơ sở dữ liệu trên panel và trình quản lý tệp chứa mã nguồn]

[Chèn ảnh mở /config/config.php trên địa chỉ thật bị chặn 403]

Khó khăn gặp phải khi triển khai và cách xử lý: Trong quá trình đưa website lên môi trường hosting, em gặp khó khăn ở khâu cấu hình đường dẫn rewrite URL và phân quyền thư mục uploads khiến ảnh sản phẩm mới tải lên bị lỗi 403. Em đã tìm hiểu tài liệu cPanel/Apache, chỉnh sửa lại file .htaccess cho phép hiển thị ảnh static và cập nhật đường dẫn BASE_URL trong file config.php cho phù hợp với tên miền hosting. Sau khi cấu hình xong, website đã hoạt động ổn định và nhận được chứng chỉ SSL HTTPS đầy đủ.

10. Lời cam đoan

Tôi cam đoan đây là bài làm cá nhân của tôi. Mã nguồn trong báo cáo, trong tệp nén, trên hosting và nội dung khai trên Google Form là cùng một phiên bản. Tôi đã nộp bài ở cả hai nơi: LMS và Google Form.

Ngày	Ngày 06 tháng 11 năm 2026
Họ tên sinh viên	Lâm Nhựt Hải Đăng